The University Spirit in the Digital Age

For an Open, Secure and Mission-Aligned Digital Infrastructure

— Complete Dossier —

Document Version 2.1
Visibility: INTERNAL
Status: Approved by the approving academic units of the institution on *(approval date to be set)*
Based on the SUIT Working Group [1↗]
Print date: June 9, 2026

A segmented architecture with flexible secure contexts for a modern university — where digital security and academic missions reinforce each other

Note on the process:
This document is an always living document. It is provided for constructive feedback and revision in order to improve its quality. The engineering of this document was partially supported by digital tools, some of which incorporate Artificial Intelligence features.

This document contains a portion of imprecisions, missing content, errors or possibly hallucinations. We believe that a supportive and cooperative approach by the readers will make its content quality increase over time.

A university is not a corporation: its governance, including digital, must optimise for freedom — of ideas, activities and persons, physical and digital.

"Freedom in research and training is the fundamental principle of university life, and governments and universities, each as far as in them lies, must ensure respect for this fundamental requirement."
— *Magna Charta Universitatum*, Bologna, 1988 [2↗]

© SUITO

Abstract

Following a period of observation and analysis of the digital policies related to education, digital technology and security at a research-intensive university, and after reviewing the latest measures under consideration, it appeared necessary to produce this document in order to contribute constructively to the evolution of such an institution's digital policy.

Universities are unique institutions combining cutting-edge research, advanced teaching and administration. A cybersecurity policy could tend to apply uniform and over restrictive measures that can prove counter-productive and at odds with internationally recognised best practices. This report presents a state of the art of infrastructure architectures and IT governance models adopted by major world universities. It shows that **network segmentation**, **federated governance** and a **risk-based approach** make it possible to reconcile enhanced security and academic freedom, by drawing on concrete examples from leading universities (MIT, Stanford, Cambridge, ETH Zurich, Oxford, CERN, etc.), on international normative frameworks (NIST, ISO 27001, COBIT), and on the European regulatory context (GDPR Article 32, NIS2 Directive, AI Act). The report also addresses the issues related to staff BYOD, artificial intelligence and access to global cloud services for research.

© SUITO

Contents

Abstract i

I Executive Summary for Governance **1**
The university spirit: openness as a foundational principle 2
What the university spirit demands of digital infrastructure 3
Effects of uniform restriction policies 3
The proposal: segment to liberate, Trusted Activity Contexts for individualised protection 4
Governance aligned with the university spirit 5
Feasibility: progressive, controlled, affordable 6
Current regulatory and operational context 7
A matter of institutional coherence 8

II Analysis, State of the Art and Propositions **9**
1 Summary for stakeholders 10
2 Reading guide: regulation, academic mission, and the institutional context 16
2.1 What this report is about 16
2.2 The academic domain in five minutes 16
2.3 The European regulatory landscape 16
2.4 The institution-specific context 17
2.5 The architectural proposition in one page 17
2.6 How to read the rest of this report 18
3 Introduction 19
3.1 Context and problem statement 19
3.2 Objectives of this report 19
3.3 The Enterprise IT vs Scientific IT dichotomy 20
3.4 Shadow IT: documented effects of restrictive policies 20
3.5 Fundamental principle: dependability 20
3.6 Trusted Activity Contexts 21
4 European regulatory context 23
4.1 GDPR Article 32: a *risk-based* obligation 23
4.2 NIS2 Directive: the institution as an essential entity 23
4.3 National institutional landscape 24
4.4 Operational obligations and proposition-mapping 25
4.5 European AI Act and access to AI cloud services 27
4.6 Regulatory summary 27
4.7 Compliance posture and knowledge-institution responsibility 27
5 Specificities of universities regarding IS 31
5.1 The university as an open space 31
5.2 Differentiated needs by mission 31
5.3 Effects of uniform restriction policies 32
5.4 Staff BYOD: a structural need 32

6 State of the art: university infrastructure architectures . . . 33
6.1 Protected high-throughput research-data paths: the Science DMZ pattern 33
6.2 VLAN network segmentation . . . 35
6.3 Micro-segmentation and SDN . . . 36
6.4 Adapted Zero Trust architecture . . . 36
6.5 Medical Science DMZ: proof for sensitive data . . . 37
7 Examples of universities with decentralised architecture . . . 38
7.1 Massachusetts Institute of Technology (MIT) . . . 38
7.2 Stanford University . . . 38
7.3 University of Cambridge . . . 39
7.4 ETH Zurich . . . 39
7.5 Carnegie Mellon University (CMU) . . . 40
7.6 University of Michigan . . . 40
7.7 CERN . . . 40
7.8 University of Oxford . . . 41
7.9 École Polytechnique Fédérale de Lausanne (EPFL) . . . 41
7.10 University of Wisconsin-Madison . . . 41
7.11 North Carolina State University . . . 41
7.12 Penn State . . . 41
7.13 French universities . . . 42
7.14 Organizational models: charters and accountability . . . 42
7.15 Comparative summary . . . 43
8 Media-Covered Failures in Universities (2024–2025): Context and Lessons . . . 44
8.1 Scope and purpose . . . 44
8.2 Most media-covered incidents (2024–2025) . . . 44
8.3 Root causes: what the failures actually show . . . 45
8.4 Conclusion of this section . . . 46
9 National Research and Education Networks (NREN) . . . 47
9.1 European ecosystem . . . 47
9.2 Key federated services . . . 47
9.3 NREN architecture: common pattern . . . 47
9.4 NREN status: what is typically in place, what is missing . . . 48
10 Normative and governance frameworks . . . 49
10.1 NIST Cybersecurity Framework 2.0 . . . 49
10.2 ISO 27001:2022 . . . 49
10.3 NIST SP 800-171 and secure enclaves . . . 50
10.4 COBIT 2019 for IT governance . . . 50
10.5 A nationally provided risk-analysis methodology . . . 50
10.6 Risk-based approach vs. compliance-based approach . . . 51
11 Artificial intelligence and access to cloud services . . . 52
11.1 AI as a structural need for research and teaching . . . 52
11.2 The GDPR challenge and non-EU cloud services . . . 52
11.3 Architectural solution: differentiated AI access zones . . . 52
11.4 Safeguards for research AI access . . . 52
12 Proposed infrastructure and organisational solutions . . . 54
12.1 Conceptual architecture: five structural layers . . . 54
12.2 Trusted Activity Contexts . . . 55
12.3 Segmented network architecture with BYOD zone and AI access . . . 55
12.4 Seven security zones . . . 55
12.5 Federated IT Governance . . . 57
12.6 Cloud and Virtualization for Research . . . 60
12.7 Shared Security Organizations . . . 61
13 Justification and Feasibility . . . 62

13.1 Cost analysis: centralised approach . . . 62
13.2 Cost analysis: federated approach . . . 62
13.3 Feasibility and cost structure of the proposed approach . . . 63
14 Transition Plan . . . 64
14.1 Progressive Transition . . . 64
14.2 Risk Register . . . 65
14.3 Monitoring KPIs . . . 65
15 Propositions . . . 66
16 Independent Commission for Reasonable Adjustments to Digital Policies . . . 68
16.1 Legal and Normative Foundations . . . 68
16.2 Why an *independent* commission? . . . 71
16.3 The precedent of an existing reasonable-adjustments committee . . . 72
16.4 Proposal: Independent Commission for Reasonable Adjustments of Digital Policies (ICRADP) . . . 72
16.5 Justification from the literature and international best practices . . . 74
16.6 Integration with the proposed architecture . . . 75
17 Conclusion . . . 76

III Questions and Evidence-Based Answers 77
How to read this module . . . 78
1 Questions on network segmentation . . . 79
2 Questions on governance models . . . 82
3 Questions on research zone autonomy and local administrative privileges . . . 85
4 Questions on BYOD and AI cloud services . . . 88
5 Questions on institutional comparisons and transferability . . . 90
6 Questions on the independent adjustments commission . . . 93
7 Questions prompted by recent incidents . . . 96
8 Questions on regulatory interpretation . . . 98
9 Questions on costs and feasibility . . . 102
10 Questions on methodology, process and credibility . . . 105
11 Summary: quick-reference table . . . 107
12 Summary and outlook . . . 110

IV Regulatory Applicability 111
1 Regulatory applicability: the invariant obligation spine . . . 112
1.1 The functional-obligation spine (F1–F6) . . . 112
1.2 The obligation → mechanism matrix . . . 113
2 Regime typology . . . 115
2.1 European Union / EEA — deep regime (baseline anchor) . . . 115
2.2 United States — deep regime (sectoral and fragmented) . . . 117
2.3 United Kingdom — light regime (post-Brexit, diverging) . . . 118
2.4 Brazil — light regime (distributed federal stack) . . . 119
2.5 South Africa — light regime (single national jurisdiction) . . . 119
3 Mapping method: deriving a row for an unlisted regime . . . 121

V Pointer to the standalone Technical Reference 123
The three foundational ideas of the Technical Reference . . . 124
Annotated table of contents of the Technical Reference . . . 124
Glossary of Acronyms and Key Terms . . . 127

© SUITO

Part I

Executive Summary for Governance

On the nature of this companion. *This document is the executive summary of a voluntary contribution produced by members of the academic community acting in their scientific and technical capacity, addressed to the institution's governing bodies (the unit-level deliberative body, the institution-wide council, and the the institution's governing board) for consideration and, if found substantive, propagation by the the institution's governing board to all concerned components.*

Key messages

- **Digital freedom is the rule** in a university; restrictions must be proportionate, documented, and limited to what is strictly necessary.
- **Segment to protect, liberate to excel:** a multi-zone architecture with Trusted Activity Contexts strengthens security for sensitive data while granting autonomy to research and teaching.
- **Democratic governance of digital policy:** a Digital Policy Commission chaired by an elected academic formulates proposals endorsed by the unit-level deliberative bodies and the institution-wide council.
- **Proven and progressive:** the approach is validated by peer research institutions, international standards, and the applicable regulatory framework; it can be deployed incrementally, starting with a pilot on selected entities.

The university spirit: openness as a foundational principle

From the *Magna Charta Universitatum* (Bologna, 1988) to the UNESCO *Recommendation on Science and Scientific Researchers* (2017), a universal consensus holds: the university is a space of **intellectual freedom**, **free movement of people and ideas**, and **autonomy** for academic staff. This openness is not a luxury — it is the very condition under which knowledge is produced and transmitted. Today, the digital space is the primary space where this movement occurs. **A digital policy that is restrictive by default is contrary to the university spirit.**

Founding principle

A university requires administration, but is not a corporation; university governance must optimise for freedom for ideas and persons, physical or digital. The digital infrastructure should reflect this fundamental distinction.

In a university, **digital freedom is the rule**. Any restriction must be *explicitly justified* by a documented risk, *proportionate* to that risk, and *limited to the strictly necessary scope* — a specific laboratory, a specific project, a specific dataset — never applied uniformly across the entire institution.

This principle reflects the risk-based, proportionate-measures requirement that runs through modern data-protection and cybersecurity frameworks — in the European Union, General Data Protection Regulation (GDPR) Article 32 (*measures appropriate to the risk*) and the NIST Cybersecurity Framework 2.0 (*risk-based approach*) are canonical references — and it is consistent with the practice of leading research universities.

▷ *Full analysis and references: the sections Summary for stakeholders, Introduction and Specificities of universities regarding IS in this dossier.*

Historical university principle	Digital translation (current status — keep one marker per element)
Free movement of persons	✓ ★ ✗ Functional BYOD, ✓ ★ ✗ eduroam, ✓ ★ ✗ seamless researcher mobility
Free movement of ideas	✓ ★ ✗ unfiltered Internet access, ✓ ★ ✗ major cloud-based AI services, ✓ ★ ✗ worldwide scientific sources
Teacher-researcher autonomy	✓ ★ ✗ local admin privileges (root/admin), ✓ ★ ✗ freedom of tool choice, ✓ ★ ✗ configurable environments
Scientific openness (Open Science)	✓ ★ ✗ access to data platforms, ✓ ★ ✗ code repositories, ✓ ★ ✗ open-access publications
Realistic training environments	✓ ★ ✗ configurable labs, ✓ ★ ✗ cyber-ranges, ✓ ★ ✗ API access for AI courses

✓ Available ★ To be reinforced ✗ Not available

This table is generic: each element carries all three markers. The adopting institution keeps, for every element, the single marker matching its own reality and deletes the other two.

What the university spirit demands of digital infrastructure

Effects of uniform restriction policies

A policy that treats financial data and research GPU clusters identically generates several documented effects: it concentrates risk on a single perimeter (a breach can affect the institution as a whole — as recent breaches in the sector have shown); it correlates with the emergence of Shadow IT (researchers may turn to unsupervised solutions); it is associated with talent mobility patterns toward institutions with more flexible IT environments; and it affects competitiveness in European and international grant calls. Restrictive policies can also expose the institution to *litigation based on fundamental rights* (academic freedom, freedom of expression and information, dignity at work).

Guiding principle for institutional resilience

A university information system must not attempt to prevent all errors, experiments, or unforeseen uses; it must **prevent such events from compromising the institution as a whole**.

In short: local freedom, incident confinement, protection of the core, global resilience.

What the most publicised recent university incidents actually show

The most publicised university breaches of recent years — whether at large national research universities or through shared platform and enterprise-software vulnerabilities such as those affecting widely used managed file-transfer and ERP products — share **the same root causes**: third-party/supply-chain vulnerabilities, credential compromise, and centralised perimeters without internal boundaries. **None of the major recent data breaches analysed here were caused by research-zone autonomy.** Known incidents involving research infrastructure — such as the 2020 European supercomputer attacks, where stolen SSH credentials were used for cryptomining on High-Performance Computing (HPC) systems at several national academic computing centres [3↗] — involved unauthorized access rather than data exfiltration, and would have been mitigated by the Trusted Activity Context mechanisms proposed here: credentials scoped to a specific activity context cannot grant lateral access to other contexts or to the infrastructure core. They demonstrate the urgent need for *segmentation and context-bounded access* — precisely what this proposal advocates.

▷ *Full analysis and references: the sections Shadow IT: documented effects of restrictive policies, Fundamental principle: dependability, Media-Covered Failures in Universities (2024–2025): Context and Lessons and Justification and Feasibility in this dossier.*

The proposal: segment to liberate, Trusted Activity Contexts for individualised protection

The logic is simple: **secure strongly what must be secured** (administrative, financial, HR data) **to liberate everything else**. This is what research universities and national laboratories do — and, through their national research-and-education networks, what institutions of far more modest scale do as well — and what NIST, ISO 27001 and Control Objectives for Information and Related Technologies (COBIT) recommend. These are not a flagship's choices to borrow but a minimal set every institution offering a digital infrastructure must discharge; only the instantiation varies with size, not the obligation.

The proposed architecture rests on two complementary mechanisms: *segmentation* controls where incidents can spread (network boundaries); **Trusted Activity Contexts** provide each user with a validated environment — assembling data, tools, services, and access rights — adapted to their current role and task. Together, they ensure that a breach in one context cannot cascade to the rest of the institution.

Conceptually, the university information system is organised in **concentric layers** (the executive view of the structural layers detailed in the technical reference): a small, strongly protected **infrastructure core** (identity, network backbone, backups, supervision) that forms the *dependability foundation* of the institution; **common services** (messaging, Learning Management System (LMS), collaboration) available to all; **autonomous zones** (research, teaching) with local freedom and bounded impact; and **user networks** (Bring Your Own Device (BYOD), Wi-Fi) that are open but isolated from the core. Protecting the small critical core is what makes it possible to liberate everything else.

The six principal operational zones below map onto these layers (a seventh IoT/Building zone is detailed in the technical report):

Key point: restrictions at laboratory or project level apply **only when explicit and documented reasons require them** (medical data, classified projects, specific funding constraints such as NIST SP 800-171). In the absence of such justification, the laboratory benefits from the **maximum openness policy** of the research zone. The default is freedom; the exception is restriction.

All zones lie within the cybersecurity-baseline perimeter applicable to the institution under its entity classification; calibration of controls follows the risk-proportionality principle of that regime — the NIS2 Directive (NIS2) Article 21 measure families in the worked EU instantiation — not

Zone	Philosophy	Constraint level
Research	**Maximum openness** — autonomy, root access, worldwide AI cloud, local server management	Minimal: responsibility charter, monitoring
Teaching	**Broad openness** — discipline-specific environments for all faculties, AI APIs, cyber-ranges, VDI	Standard: pedagogical framework
Staff BYOD	**Free Internet** + progressive access to institutional resources	MFA + minimal posture check
Research-data path (e.g. Science DMZ)	**Maximum performance** — high-throughput transfers without stateful firewall	ACL + dedicated IDS
Administrative	**Maximum protection** — this is where, *and only where*, restrictions are concentrated	Strict: firewall, IDS/IPS, proxy, full GDPR
Sensitive enclave	Case by case, **at project level**	Only on explicit, documented justification

scope reduction. The function this discharges is the cybersecurity risk-governance obligation (F2) of the Regulatory Applicability annex (Part IV); read your own regime's instrument for that obligation in the regime typology there.

▷ *Full analysis and references: the sections State of the art: university infrastructure architectures, Examples of universities with decentralised architecture, Artificial intelligence and access to cloud services and Proposed infrastructure and organisational solutions in this dossier.*

Governance aligned with the university spirit

- **Digital Policy Commission** chaired by an *elected* academic, composed of representatives from the constituent academic units (departments and interdisciplinary centres) across the institution. The Commission formulates policy proposals that are submitted to the unit-level deliberative bodies and then to the institution-wide council for endorsement. The IT-management lead and the information-security-management lead submit proposals; the Commission decides — aligned with COBIT 2019's separation of governance (strategic direction) from management (operational execution) and with established academic-governance practice;
- **Responsibility charters** (as practised across research institutions): autonomy is formalised and accountable, replacing informal exceptions;
- **Contextual role management:** a single individual (e.g. a researcher who also teaches and administers a laboratory) activates only the relevant role for each task — never carrying all privileges simultaneously. This enforces least privilege, improves auditability, and maps naturally onto the zone structure;
- **Open-source and open-science tools as default institutional choices**, reducing vendor lock-in, increasing transparency, and aligning with the European Commission's open-source strategy;
- **Independent Commission for Reasonable Adjustments of Digital Policies** (Independent Commission for Reasonable Adjustments of Digital Policies (ICRADP)): any employee can challenge a disproportionate restriction — for medical, personal, professional reasons, or infringement of fundamental freedoms — in accordance with the EU Charter of Fundamental Rights, the CRPD Convention and the case law of the Court of Justice

of the European Union (CJEU) and the European Court of Human Rights (ECtHR) on the proportionality of digital restrictions. Where the institution already operates a reasonable-adjustments mechanism (supporting students and staff), the ICRADP extends that principle to digital policies; where none exists, it establishes the principle directly. Refusals must be justified in writing.

Continuous-improvement mechanism. Together, the Digital Policy Commission, the unit-level deliberative bodies, the responsibility charters and the ICRADP constitute the institution's continuous-improvement mechanism, materialised in the annual compliance and maturity report submitted to the competent cybersecurity authority [4] pursuant to the continuous-improvement provision of the applicable regime — see the Regulatory Applicability annex (Part IV), the accountability-and-conformity obligation (F6) under your regime profile, instantiated in the worked EU example by the the national NIS2 transposition law [5].

▷ *Full analysis and references: the sections Federated IT Governance, Contextual role management and separation of privileges, Propositions and Independent Commission for Reasonable Adjustments to Digital Policies in this dossier.*

Feasibility: progressive, controlled, affordable

Step	Content
1. Governance	Digital Policy Commission, responsibility charters, service catalogue, formalised exception path
2. Pilot	Segmented architecture and Trusted Activity Contexts deployed on a pilot technical department, a pilot research centre, and the the institution's HPC facility / team — high-throughput research-data path (Science DMZ), BYOD zone, open-source tools
3. Progressive extension	Gradual rollout to other departments, faculties and centres, progressive Zero Trust, AI research zone, audit and continuous improvement

No "big bang" required. The governance step is organisational and achievable with existing staff. The pilot and progressive extension rely on the the national research and education network and its pan-European backbone services, open-source tools, and platforms offered free of charge for academic research.

Scale-appropriate reading. Where public documentation evidences no Science DMZ — nor any equivalent research-and-education-network-operated research-data path — deployed, neither at the institution nor at the the national research and education network level, the substrate is nonetheless frequently already operational: high-capacity backbone connectivity to the pan-European research backbone through the the national research and education network, an HPC facility moving petabyte-scale traffic, and the NREN CSIRT for incident response. For institutions of modest scale, the pragmatic form is therefore not an institution-only deployment of the Science DMZ pattern but a federated research-network zone — the same high-throughput research-data path realised at national, mutualised scale — *co-designed* with the the national research and education network and shared across partner research organisations, with a dedicated medical enclave for biomedical workloads where required.

▷ *Full analysis and references: the sections NREN status: what is typically in place, what is missing, Justification and Feasibility and Transition Plan, and the standalone Technical Reference [6] (vendor-neutral architecture, sovereignty grid, migration playbook) in this dossier.*

Current regulatory and operational context

1. **AI as a structural tool for research and teaching:** research and teaching access to major cloud-based and open AI services (commercial APIs and open model hubs) is now part of the standard scientific working environment. Under the the adopter's applicable AI-governance regime's risk-based framework — the technology-governance obligation (F5) of the Regulatory Applicability annex (Part IV) — the resulting obligations depend on the concrete use case and the user's role; many research uses of commercial AI services fall outside the high-risk categories. Under the proposed cooperative researcher-centred model (PI data classification + institutional register maintained by the central IT function + periodic audit by the data-protection function), the cross-border-transfer obligation (F4) bites: in the worked EU instantiation, the *Schrems II* cumulative regime applies to personal-data transfers [7↗]. The AI regime's research-and-development exemption (where one exists — e.g. Art. 2(6) of the EU AI Act) covers bespoke research tools, not the use of commercial APIs.

2. **The applicable regulatory framework demands it:** the data-protection security-of-processing obligation (F1) requires *proportionate* measures — GDPR Article 32 in the worked EU instantiation; under the cybersecurity-baseline regime (F2), instantiated here by the national transposition of NIS2 [5], the institution may be classified by the the national NIS2 supervisory authority as an **essential entity** (holistic perimeter, proactive supervision, mandatory audits, annual maturity report via the the national NIS2 incident-notification platform [8]) [4]; sector cybersecurity guidance from the relevant sector authority treats cybersecurity as a strategic governance risk [9↗]; a segmented architecture aligned with NIS2 Article 21 proportionality is the appropriate response. The instruments named here are the EU instantiation of a jurisdiction-invariant obligation spine; an adopter reads its own regime's instruments for these obligations in the Regulatory Applicability annex (Part IV).

3. **Reference universities providing comparable openness:** reference research institutions provide their researchers with the autonomy and infrastructure described here. The the national research and education network and its pan-European backbone interconnect make the same architectural primitives accessible at the institution's national scale.

▷ *Full analysis and references: the sections European regulatory context and Artificial intelligence and access to cloud services in this dossier.*

A matter of institutional coherence

Call to action

The university cannot proclaim academic freedom in its statutes and impose a uniform digital lockdown in its daily practice. Providing an **open, segmented and proportionately secured** framework means honouring the university spirit while **strengthening security** where it is truly necessary — rather than weakening the institution through blanket restrictions that drive talent away and fuel Shadow IT.

Short-term objectives:

1. That the **unit-level deliberative body**, subsequently the **institution-wide council**, and finally the **the institution's governing board** endorse a position statement derived from the present five-page document, *"The University Spirit in the Digital Age"*;
2. That the **executive leadership**, in collaboration with IT experts and academic representatives, define a short- to medium-term implementation plan aligned with the architecture described in the accompanying technical report and developed in detail in the standalone Technical Reference [6].

Accompanying documents: *"Infrastructure and Organisation of Information Systems for the institution — Analysis, State of the Art and Propositions"*. The report provides the full state of the art, an international set of university case studies, European regulatory analysis, detailed architecture, cost-benefit analysis, transition plan with risk register and KPIs, and the complete legal and normative foundations for the ICRADP. A standalone Technical Reference [6] addressed to chief technology officers and information-security officers develops a five-dimension sovereignty grid, a vendor-neutral reference architecture demonstrated on open foundations, and a wave-based migration playbook. It is intended as the shared technical baseline for the cross-institution federation anticipated in phase 2 of this initiative.

Note on the process: *This document is an always living document. It is provided for constructive feedback and revision in order to improve its quality. The engineering of this document was partially supported by digital tools, some of which incorporate Artificial Intelligence features.*

© SUITOAAA

Part II

Analysis, State of the Art and Propositions

1 Summary for stakeholders

> "Security is a process, not a product."
>
> — Bruce Schneier, *Secrets and Lies* [10↗]

This report describes a security architecture model based on *segmentation, Trusted Activity Contexts, and federated governance*, applicable to research-and-teaching universities under the NIS2 Directive (NIS2) essential-entity regime. The messages below are tailored to each category of stakeholders to facilitate internal communication.

On the nature of this report. *The present document is a voluntary contribution produced by members of the institution's academic community acting in their scientific and technical capacity. It is transversal across the institutional actors concerned (central executive leadership, faculties, interdisciplinary centres, services, IT departments, DPO, CISO) and independent of any institutional hierarchy or formal mandate. The single objective of this report is to be considered by the institution's academic governing bodies (the collegial academic councils and the top governing board) and, if found substantive, to be propagated by the top governing board to all concerned components for deliberation through the appropriate institutional channels.*

Message to the top governing board and executive leadership

Strategic issue: The university's capacity to attract and retain world-class researchers, to compete for European and international funding, and to meet its legal obligations under EU digital regulation — all three are directly shaped by its digital infrastructure choices. In accordance with the *Magna Charta Universitatum* and the UNESCO *Recommendation on Science and Scientific Researchers* (2017), digital openness is not a concession but a founding condition of the university. A university requires administration, but is not a corporation; university governance must optimise for freedom for ideas and persons, physical or digital. The digital infrastructure should reflect this fundamental distinction.

Article 32 of the General Data Protection Regulation (GDPR) requires security measures *appropriate to the risk*, including **resilience** and the capacity for **restoration** [11↗]. Where the national transposition of the NIS2 Directive [12↗] so provides, an institution of this kind is classified by the national competent authority — the NIS2 supervisory authority — as an **essential entity** on the basis of its status as a public institution; this classification applies to the institution as a whole and entails proactive supervision, regular audits and an annual compliance and maturity report. Sector guidance treats cybersecurity as a *strategic governance risk* and recommends defence in depth and a positive security culture [9↗].

The analysis of the most publicised university breaches in 2024–2025 (Paris-Saclay, Texas Tech, Western Sydney — see Section 8) reveals that *none* were caused by research-zone autonomy or segmented architectures; all stemmed from centralised, unsegmented perimeters, supply-chain vulnerabilities, or credential compromise.

What we propose:

- **Multi-zone architecture with Trusted Activity Contexts:** a segmented infrastructure that *strengthens* the protection of sensitive administrative data by isolating them in a dedicated enclave (recent media-covered incidents show that centralised, undifferentiated perimeters amplify impact — see Section 8), while each research project, teaching activity, or administrative process operates within a validated, isolated environment adapted to its risk level — ensuring that an incident in one context cannot compromise the rest of the institution;
- **Federated governance with responsibility charters** aligned with the models

of world-class universities (MIT, Oxford, Cambridge, ETH Zurich, Michigan), formalising autonomy and accountability (ETH Zurich model) and replacing informal exceptions;
- **Auditable regulatory compliance:** a programme producing evidence of effectiveness compliant with the GDPR, NIS2 and the European AI Act, preserving attractiveness for high-level researchers and academics through a modern infrastructure;
- **AI as a structural research tool (2025–2026):** ensuring access to major cloud-based AI services (OpenAI, Anthropic, Google, HuggingFace, AWS) — under the AI Act's risk-based framework, the applicable obligations depend on the concrete use case and the user's role; many research uses of commercial AI services fall outside the high-risk categories;
- An **Independent Commission for Reasonable Adjustments of Digital Policies** (Independent Commission for Reasonable Adjustments of Digital Policies (ICRADP)), guaranteeing every employee the right to obtain adjustments for medical, personal, professional reasons or infringement of fundamental freedoms — in accordance with the EU Charter of Fundamental Rights, the CRPD Convention and the case law of the Court of Justice of the European Union (CJEU) and the European Court of Human Rights (ECtHR) on proportionality (where these instruments bind the institution's jurisdiction) (see Section 16).

Request for consideration by the academic governing bodies and propagation by the top governing board. The present report is a voluntary contribution produced by members of the academic community acting in their scientific and technical capacity, independent of any institutional hierarchy or formal mandate. Its propositions are offered to the institution's academic governing bodies (the collegial academic councils and the top governing board) for consideration alongside the cybersecurity strengthening initiatives already approved by the top governing board. The contributors of this report request that, if the analysis is found substantive, the document be propagated by the top governing board to all concerned components (the central executive leadership, faculties, interdisciplinary centres, services, IT departments, DPO, CISO) so that integration with existing initiatives can be deliberated through the appropriate institutional channels.

Feasibility: the proposed measures can be implemented *progressively* (governance first, then pilot, then rollout) within a university multi-year plan, leveraging existing National Research and Education Network (NREN)/GEANT pan-European research network (GEANT) services, open-source tools and shared security communities (GÉANT Security, the national NREN's CSIRT, Forum of Incident Response and Security Teams (FIRST)). A digital infrastructure worthy of the university's ambitions is a strategic enabler, not merely a cost (see Section 13 and Section 14).

Documented risk factors: talent mobility patterns toward more flexible institutions; regulatory exposure under NIS2 essential-entity supervision; Shadow IT as a documented effect of restrictive policies (a GÉANT survey reports that in most institutions *"all official IT can have a shadow version"* [13↗]; Gartner projects that 75% of employees will acquire technology outside IT visibility by 2027 [14↗]); competitiveness factors in European and international grant calls; potential litigation based on fundamental rights (academic freedom, freedom of expression and information, dignity at work). The analysis of the most publicised university failures in 2024–2025 (Section 8) identifies third-party vulnerabilities, credential compromise and absence of internal boundaries as recurring causes.

Proposed next steps:

1. The report is submitted to the institution's academic governing bodies (the collegial academic councils and the top governing board) for consideration within their

respective remits; each body may issue a position statement on the propositions.
2. If endorsed by the top governing board, the central executive leadership — in collaboration with the CISO, the DPO, the academic representatives and the contributors of this report — defines an integrated implementation roadmap consistent with the board-approved initiatives (governance charter first, then pilot on selected entities, then progressive rollout).
3. The contributors remain available, post-deliberation, to support the mapping between the propositions endorsed by the academic governing bodies and the integrated implementation roadmap.

See the accompanying *Executive Summary* for the detailed call to action.

Message to the CISO

Issue: Reducing the attack surface you must defend, gaining visibility on what is currently Shadow IT, and obtaining auditable proof that security controls are effective — not just deployed.

The core proposal is a **net security gain**: the administrative enclave becomes *smaller, easier to harden and easier to monitor*. NIST SP 800-53 SC-7 (*Boundary Protection*) [15↗] explicitly requires organisations to "connect to external networks or information systems only through managed interfaces consisting of boundary protection devices"; SC-7(21) calls for *isolation of system components*. ISO 27001 Annex A control A.8.22 requires *network segregation* [16↗]. ETH Zurich [17↗] requires that non-compliant IT resources be placed in *isolated network zones*. High-profile university incidents in 2024–2025 (analysed in Section 8) confirm that breaches are driven by *lack* of segmentation and lateral movement, not by accountable autonomy in research or teaching zones.

What changes for you:

- Research/teaching autonomy is governed by *charters*, *inventories* and *monitoring* — not by informal exceptions;
- Each zone has an identified owner, incident contacts, and a logging baseline;
- Each activity operates within a *Trusted Activity Context* with its own security policies, logging baseline, and isolation boundaries — making audit and incident response more precise and efficient;
- **Measurable security posture:** each Trusted Activity Context produces its own logging baseline and compliance metrics — enabling you to report zone-by-zone security status to the top governing board, rather than a single aggregate score that masks local weaknesses;
- Current Shadow IT (hidden servers, personal clouds, unauthorised Virtual Private Network (VPN)s) is replaced by authorised and auditable pathways;
- Oxford [18↗] and ETH Zurich [17↗] provide credible precedents for this accountable autonomy.

Risk of other models for the CISO: a single, undifferentiated perimeter means that every exception is ad hoc, every research server is a potential blind spot, and a breach anywhere is a breach everywhere. The Verizon DBIR [19↗] consistently identifies lateral movement within flat networks as a primary breach amplifier. The proposed architecture does not weaken your mandate — it makes it enforceable.

Message to the Central IT Department (CIO Office)

Issue: Reducing the perimeter to manage, clarifying responsibilities, and ending ad hoc exceptions.

Today, a central IT Department that attempts to manage a single perimeter covering the entire institution — from financial data to GPU compute clusters creates an unsustainable workload and permanent friction with academic departments. The consequence is a team stretched across incompatible requirements: hardening administrative systems while simultaneously troubleshooting research instruments, configuring teaching labs, and managing ad hoc exceptions that bypass the very policies the team is tasked to enforce. Recent media-covered incidents (e.g. Paris-Saclay, Western Sydney) show that such undifferentiated perimeters also *increase impact* when a breach occurs — segmentation limits propagation (Section 8).

What changes for you:

- You focus on the *administrative enclave* (ERP, HR, finance, student IS) with strict controls and a well-defined perimeter;
- You provide the *backbone*, *federated identity* (Identity and Access Management (IAM)/Multi-Factor Authentication (MFA)) and the *Security Operations Centre (SOC)* as shared services;
- Each department's research and teaching activities operate within *Trusted Activity Contexts* — you provision the underlying infrastructure (Virtual Local Area Network (VLAN), identity, monitoring), but the domain-specific configuration is the department's responsibility under charter;
- Departments manage their own research servers in dedicated VLANs, under their responsibility formalised by charter;
- The *service catalogue* clarifies who provides what, replacing case-by-case negotiations;
- **No more ad hoc exceptions:** what is currently handled through informal email threads and individual workarounds becomes a formal charter process with documented responsibilities — reducing your liability and your team's interrupt-driven workload;
- The University of Wisconsin-Madison [20↗] confirms that federation *reduces risk* while preserving local innovation.

What does not change: you retain full authority over the backbone, the identity infrastructure, the SOC, and the administrative enclave. The proposal does not reduce your mandate — it focuses it on the systems where central control is both necessary and effective.

Message to Research Units and Research-and-Teaching Departments

Issue: Regaining the autonomy necessary for research and experimentation, whether in research-only units or research-and-teaching departments. Concerns that "more autonomy means more risk" are not supported by the evidence: the most publicised university breaches in 2024–2025 (MOVEit, Oracle EBS, credential compromise at central services) stem from *third-party vulnerabilities* and *centralised perimeters*, not from research zones (see Section 8).

What changes for you:

- Each laboratory or department can obtain a *Trusted Activity Context* — a dedicated VLAN with local administration rights (software installation, server configuration, root access) under a responsibility charter;
- Each unit designates a *local IT contact* responsible for maintaining the charter

commitments (inventory, patching, incident reporting) — this role is the counterpart of the autonomy granted;
- Access to global cloud services (including for AI: OpenAI API, Google Cloud AI, AWS SageMaker, HuggingFace) is possible from the research zone, with an appropriate data management framework;
- Research instruments, laboratory IoT and GPU clusters are managed locally; high-throughput research traffic benefits from a *Science DMZ* path bypassing the enterprise firewall (see Section 6.1);
- The model draws on ETH Zurich where an *administrator rights agreement* [21↗] formalises root access for researchers and doctoral students;
- Research platforms such as CloudLab [22↗] and Chameleon [23↗] illustrate that privileged control is a *structural need* of computer science research;
- If a specific digital policy still restricts a legitimate research need, the *Independent Commission* (ICRADP) guarantees a formal right to request adjustments (see Section 16).

Message to Teaching and Training Components

Issue: Providing teaching environments adapted to the actual needs of each discipline — from configurable labs for computer science and engineering, to AI-assisted tools for law, humanities and social sciences, to simulation platforms for health sciences and economics. In 2025–2026, every faculty needs access to cloud-based AI services and discipline-specific digital tools; a uniform, locked-down desktop policy cannot serve this diversity.

At world-class universities with federated IT governance (MIT, Stanford, ETH Zurich, Michigan), each school or department manages its own IT infrastructure — including the environments used for teaching (see Section 6). The teaching zone proposed here applies this principle systematically.

What changes for you: The teaching zone provides *Trusted Activity Contexts* — isolated, pre-configured environments adapted to each course or activity:
- Virtual Desktop Infrastructure (VDI) (*Virtual Desktop Infrastructure*) allows students across all faculties to access standardised, discipline-specific environments from their own devices (Bring Your Own Device (BYOD)); students on personal devices access the same environments as in-lab students, ensuring equity between on-campus and remote learners;
- Access to AI APIs (ChatGPT, Claude, Gemini, open-source models) is available for all disciplines — from AI-assisted legal research to computational linguistics, from data analysis in social sciences to creative tools in humanities;
- JupyterHub on Kubernetes [24↗] provides each student with an isolated computing environment for data science, statistics, and computational courses across faculties;
- *Cyber-ranges* (isolated sandbox environments) are made available for security, networking and systems courses, as recommended by NIST [25↗];
- Instructors in every faculty can freely configure lab environments in the teaching zone, with a fast *reset/reimage* pipeline between sessions;
- Instructors can prepare and test course environments *before* the semester begins, with the certainty that the configuration will be preserved — no more last-minute requests to central IT for software installation.

Message to all Staff (BYOD)

Issue: Being able to use one's own devices in a productive and secure manner. The analysis of recent university incidents (Section 8) does not attribute breaches to BYOD or flexible access but to supply-chain, credentials and unsegmented perimeters — the proposed BYOD zone with progressive interoperability is designed to integrate personal devices safely rather than push them into shadow IT.

What changes for you:

- **Your personal device works on campus:** a dedicated network provides full Internet access from day one; as you authenticate, you progressively gain access to university resources matching your role (teaching materials, research data, administrative tools);
- With MFA authentication and minimal posture verification (up-to-date OS, active antivirus), you can access institutional resources from your personal device;
- Access to sensitive data (HR, finance) from a BYOD device remains conditional on enhanced controls (VDI, secure web access);
- Access to cloud-based AI services (ChatGPT, Claude, Gemini) is available from the BYOD network — you do not need a university-managed device to use AI tools for your work;
- Education Roaming (eduroam) [26↗] already provides the federated Wi-Fi infrastructure: your local credentials work at all partner universities worldwide;
- **Right to reasonable adjustments:** an *Independent Commission* (ICRADP) guarantees you the right to request adjustments to any digital policy — for example, if a software restriction prevents you from using an assistive technology, or if a network filter blocks a resource essential to your research. The commission is independent of the IT Department and rules within 15 working days (see Section 16).

2 Reading guide: regulation, academic mission, and the institutional context

This section provides a pedagogical overview intended for non-specialist decision-makers, particularly members of the institution's collegial academic councils and the top governing board. It introduces the regulatory landscape, the academic-domain specificities, the institutional context and the architectural proposition of this report. Each sub-section is designed for a five-minute read; cross-references point to the detailed treatment elsewhere in the report. Readers familiar with the regulatory framework may proceed directly to Section 4.

2.1 What this report is about

This report is a voluntary contribution from members of the institution's academic community, addressed to the academic governing bodies for consideration (see "On the nature of this report" at the entry of Section 1). It describes a security architecture model for the institution's information systems — segmentation, Trusted Activity Contexts and federated governance — and the operational mechanisms (researcher-centred AI cloud access, institutional maturity reporting, executive training) that align the architecture with the NIS2 essential-entity regime where the institution's jurisdiction has transposed the NIS2 Directive into national law.

2.2 The academic domain in five minutes

A research-and-teaching university operates under three concurrent missions, each with distinct working requirements:

- **Research.** Experimentation, autonomy, fast iteration; tools chosen by the researcher; international collaboration; access to high-performance computing and global data resources.
- **Teaching.** Structured curricula; access to industry-standard tools (including AI services such as OpenAI, Anthropic and Google AI for hands-on exercises); reproducible learning environments.
- **Administration.** Structured processes; strict protection of financial, HR and student records; regulated workflows.

The architectural challenge is that these three missions have different requirements: research benefits from openness and autonomy, administration requires strict control. A single uniform policy applied to all three concentrates risk on a single perimeter and constrains research workflows. The multi-zone architecture of this report allocates a distinct security profile to each mission, with explicit boundaries and federated governance.

The institution does not operate in isolation: its national research-and-education network (NREN) connects it to the European backbone GEANT, providing identical infrastructure primitives (eduroam, eduGAIN, identity federations) at the national scale. The architectural choices proposed in this report are consistent with the practice of peer institutions accessible via the same backbone (see Section 7).

2.3 The European regulatory landscape

For an adopter bound by the EU/EEA regime, four European regulatory instruments shape the cybersecurity and data-protection environment of the institution (an adopter under another jurisdiction substitutes its own equivalents through the Regulatory Applicability module of the Technical Reference):

GDPR (2016, applicable since 2018). Personal-data protection. **Article 32:** security measures *appropriate to the risk*, including resilience and capacity for restoration. **Articles 24(1) and 5(2):** accountability principle — the data controller is responsible. For a university, this applies to student records, HR data, and research data containing personal information.

NIS2 (2022, applicable since 17 October 2024). Cybersecurity for *essential* and *important* entities. Where the institution's jurisdiction has transposed the Directive into national law, a public research-and-teaching institution is typically classified as an *essential entity* on the basis of its public-institution status (Section 4.2). Essential-entity supervision is proactive (audits, maturity reports), with sanctions up to EUR 10 M or 2 % of annual turnover.

European AI Act (Regulation (EU) 2024/1689). Risk-based classification of AI systems. **Article 2(6):** bespoke research-only AI tools are exempt. **Recital 25:** research and innovation activities are to be supported and not unduly restricted. For a university using commercial AI APIs (e.g. OpenAI, Anthropic, Google) in research and teaching, most uses fall outside the high-risk categories.

CJEU *Schrems II* (case C-311/18, 2020). Transfers of personal data outside the European Economic Area require, in addition to Standard Contractual Clauses, a documented Transfer Impact Assessment (TIA) and supplementary measures (encryption before transfer, pseudonymisation). This affects access to non-EU AI cloud services in research contexts (see Section 11.4).

Operational consequence. For a university classified as essential entity, the four instruments combine into a single integrated regime: GDPR sets the data-protection baseline; NIS2 and its transposition set the cybersecurity governance and maturity expectations; the AI Act sets the AI-system classification; *Schrems II* constrains cross-border data flows. **Where the adopter is bound by these instruments, the architecture of this report is designed to satisfy them simultaneously; an adopter under another regime reads the same architecture against its own equivalents.**

2.4 The institution-specific context

The elements below describe how the EU-level regime is typically instantiated at national level. They are stated in role-based terms; each institution substitutes the named authority, platform and statute applicable in its own jurisdiction (the worked instantiation is given in the Regulatory Applicability annex).

Status. A public research-and-teaching institution is typically classified as an *essential entity* under the national NIS2 transposition, on three cumulative legal pegs: the public-administration entity definition, the essential-regardless-of-size clause, and the research-organisation track (which is often explicitly closed for teaching establishments). The classification is confirmed by the national competent authority and notified to the institution.

Supervisory chain. The national NIS2 supervisory authority oversees compliance. The national or governmental Computer Security Incident Response Team (CSIRT) is the operational incident-response team for public-sector entities, and the national information-security agency publishes the State information-security policy that applies to public bodies.

Notification platform. A single national incident-notification platform is typically the entry point for NIS2, GDPR and CER notifications. The binding cadence is 24 hours (early warning) / 72 hours (incident notification) / 30 days (final report).

National strategy hook. National cybersecurity strategies commonly identify cooperation between the State and the academic and research sphere as a priority objective. The contribution of this report to the regulator's protocols (Section 4.7) is consistent with such a national objective.

2.5 The architectural proposition in one page

Five elements summarise the architecture proposed by this report:

1. **Multi-zone segmentation (seven zones).** Administrative (high security), Teaching (standard), Research (flexible), Science Demilitarised Zone (Science DMZ) (high-throughput

transfers), Personal BYOD, IoT/Building (isolated), Sensitive enclave (compliance-critical). Each zone has its own security profile.

2. **Trusted Activity Contexts.** Each activity operates in a coherent, validated environment with the data, tools, services and access rights appropriate to its purpose.
3. **Federated governance.** A *Digital Policy Commission* chaired by an elected academic, with representatives from departments and interdisciplinary centres. Responsibility charters formalise the autonomy of research units within the institutional minimum standards required by the applicable national NIS2 transposition.
4. **Researcher-centred AI cloud access.** The Principal Investigator classifies data and selects providers proportionately. Non-EU access operates on a cooperative declaration basis: the central IT service registers the access on PI request, with periodic Data Protection Officer (DPO) audit (Section 11.4).
5. **Continuous-improvement mechanism.** Per-zone compliance evidence aggregates into an institution-level maturity dashboard (an ISO/IEC 27005-aligned risk-analysis method or tool, such as a nationally provided open-source methodology), producing the annual maturity report submitted to the national NIS2 supervisory authority where the transposition so requires.

Technical implementation: each of the five elements above is developed in depth in the standalone Technical Reference [6] — the Trusted Activity Context in Chapter 2, the multi-zone segmentation in Chapter 8, the federated governance in Chapter 3 (sovereignty grid), the AI access pattern in Chapter 7 (policy) and Chapter 10 (data classification), the continuous-improvement mechanism in Chapter 16 (conformance suite).

2.6 How to read the rest of this report

The report is structured for several reading paths:

- **For decision-makers (the collegial academic councils and the top governing board):** Section 1 presents per-audience messages; the accompanying executive summary (companion document) provides a four-page synthesis.
- **For legal review (CISO, DPO, legal service):** Section 4 contains the full regulatory analysis, with the methodology note at its entry; Section 4.4 maps the NIS2 Article 21(2) obligations to the report's propositions; Section 11.4 details the cloud AI access safeguards; Section 4.7 articulates the compliance posture in four positions.
- **For technical leads (IT services, faculty IT correspondents):** Section 6 surveys the state of the art; Section 12 details the proposed architecture and the seven zones; Section 14 sets out the transition plan.

3 Introduction

> "Those who would give up essential Liberty, to purchase a little temporary Safety, deserve neither Liberty nor Safety."
>
> — Benjamin Franklin, 1755 [27↗]

3.1 Context and problem statement

A university requires administration, but is not a corporation; university governance must optimise for freedom for ideas and persons, physical or digital. The digital infrastructure should reflect this fundamental distinction.

Universities are, by nature, open spaces dedicated to the creation and transmission of knowledge. Their mission rests on three fundamental pillars: **research**, which requires maximum freedom of experimentation; **teaching**, which demands access to diverse tools and the ability to configure varied pedagogical environments; and **administration**, which requires the protection of sensitive data (personal data, financial data, human resources).

In a research-and-teaching university, these missions are typically carried out by organisationally distinct entities: *research-only units*, *research-and-teaching departments*, and *teaching/training-only components*, each with different infrastructure needs and different regulatory exposure (see Section 4).

Faced with the proliferation of cyber threats, some universities adopt a *centralised* security approach consisting of:

- Minimising the number of authorised software;
- Fully centralising systems administration;
- Restricting access rights uniformly for all staff;
- Prohibiting the installation of servers or local services in laboratories and departments.

While this approach may be justified for a purely administrative environment, it **raises significant challenges** in a university context for several reasons:

1. **It can hinder experimental research** in computer science, data science, artificial intelligence and any discipline requiring configurable infrastructures.
2. **It can degrade the quality of teaching** across all faculties — preventing technical courses from using realistic environments, and preventing non-technical disciplines from accessing AI tools, simulation platforms, and specialised digital resources.
3. **It can create a false sense of security**: reducing the attack surface through total restriction risks concentrating vulnerabilities on a single point of failure.
4. **It tends to drive *shadow IT***: researchers and instructors may circumvent restrictions by using unapproved solutions, potentially creating risks greater than those the policy claims to avoid [28↗].
5. **It hinders access to artificial intelligence**, whose global cloud services (OpenAI, Google, AWS, HuggingFace) have become widely used across contemporary research and teaching.

3.2 Objectives of this report

The objectives of this report are to:

1. Present a **state of the art** of university IT infrastructure architectures;
2. Demonstrate through **concrete examples** that decentralised and segmented architectures are common across a range of research-intensive universities;
3. Present the **normative frameworks** (NIST, ISO, COBIT) that support this approach;
4. Propose **infrastructure and governance solutions** adapted to the specific needs of a university.

3.3 The Enterprise IT vs Scientific IT dichotomy

The core of the problem lies in the uniform application of an *Enterprise IT* policy to a *Research IT* environment. As the Science DMZ design pattern demonstrates, the performance and security characteristics of enterprise traffic and scientific traffic are fundamentally different [29]. Applying administrative restrictions to a compute cluster or a genomic sequencer amounts to treating a scientific instrument like a secretarial workstation.

3.4 Shadow IT: documented effects of restrictive policies

A case study from the University of Maryland (UMBC) revealed that Shadow IT emerges to satisfy *"unmet functional needs"* and provide *"innovation and flexibility"* [28]. When central tools are unsuitable or too locked down, researchers deploy their own servers under desks, use personal cloud services for sensitive data, or create unauthorised Wi-Fi access points. These systems escape all oversight: they are neither patched, nor backed up, and are often vulnerable [30]. **Overly restrictive central control can reduce visibility into actual practices on the ground.**

This pattern is not unique to UMBC. A GEANT survey of European research and education institutions found that *"in most institutions, all official IT can have a shadow version, mainly deployed by individual researchers or IT admins at the department level"* [13]. Gartner estimates that 41% of employees acquired or created technology outside IT's visibility in 2022, rising to a projected 75% by 2027 [14]. A systematic review of 107 publications on Shadow IT [31] identifies the root causes as poor business-IT alignment, lack of agility, and inadequate policies — not malicious intent. The evidence consistently shows that **prohibition does not eliminate Shadow IT; it merely removes institutional visibility and governance**, increasing rather than decreasing actual risk [32, 33].

3.5 Fundamental principle: dependability

Dependability is defined by Avizienis et al. [34] as *"the ability to deliver service that can justifiably be trusted"*. Their foundational taxonomy identifies six core **attributes** that any trustworthy system must exhibit:

Table 1: Dependability and security attributes (after [34])

Attribute	Definition
Availability	Readiness for correct service
Reliability	Continuity of correct service
Safety	Absence of catastrophic consequences on the user and environment
Integrity	Absence of improper system alterations
Maintainability	Ability to undergo modifications and repairs
Confidentiality	Absence of unauthorised disclosure of information

The same taxonomy identifies four **means** for achieving dependability: *fault prevention*, *fault tolerance*, *fault removal*, and *fault forecasting*. In a university environment where experimentation, heterogeneity and openness are structural, **fault tolerance** — the ability to deliver correct service in the presence of faults — deserves particular emphasis alongside fault prevention. Avizienis et al. present the four means as complementary [34, 35]; the specific characteristics of university environments (heterogeneity, BYOD, academic freedom, experimentation) shift the balance toward tolerance and detection rather than prevention alone.

Two complementary mechanisms are central to fault tolerance in IT architecture.

The first is **segmentation**: it answers the question *"Where can network flows circulate?"* by dividing the infrastructure into distinct zones at the network level to **limit the propagation** of incidents (lateral movement, malware spread, cascading failures). Segmentation acts on the

blast radius of an event. It is a well-established concept in the standards literature, appearing as *boundary protection* (NIST SP 800-53 SC-7 [15↗]), *network segregation* (ISO 27002 A.8.22 [16↗]), and *segmentation* among the fourteen cyber-resiliency techniques of NIST SP 800-160 Vol. 2 [36↗]. The second mechanism — which complements segmentation — is developed in the next subsection.

3.6 Trusted Activity Contexts

The second of the two mechanisms introduced above addresses a complementary concern: not *where* flows circulate, but *what validated environment* a user operates in for a given activity. The standards literature approaches this through several related but partial concepts: *isolation* (NIST SC-7(21)), *privilege restriction* (NIST SP 800-160 Vol. 2), *attribute-based access control* (NIST SP 800-162 [37↗]), and *role-based session activation* (Role-Based Access Control (RBAC) [38↗]). The practice literature additionally uses terms such as *compartmentalisation* (Verizon DBIR [19↗]), *enclaves* (NIST SP 800-171 [39↗]), and *security domains* (CNSSI 4009). Each captures a facet of the problem, but none defines a **complete, pre-assembled, activity-centric environment** that brings together data, tools, services, and access rights as a coherent unit for a specific mission.

To fill this gap, we introduce the concept of **Trusted Activity Context** (Trusted Activity Context (TAC)). A Trusted Activity Context is a coherent, validated environment that assembles the data, tools, services, and access rights required for a specific task, mission, or activity — such as a research project, a digital examination, an administrative process, or a teaching session. Within a TAC, security policies, access controls, logging, and isolation mechanisms are aligned with the objectives and risk level of that specific activity.

Note: the term *Trusted Activity Context* should not be confused with IBM DB2's identically named database connection feature, nor with the Trusted Computing concepts of the Trusted Computing Group (TCG). Here, "trusted" follows the dependability definition of Avizienis et al. [34↗]: an entity is trusted if it delivers service that can justifiably be relied upon.

The concept of TAC draws on and extends several established frameworks: RBAC session-based role activation [38↗], Task-Based Authorization Controls (TBAC) which tie permissions to task lifecycles [40↗], Attribute-Based Access Control (ABAC) which evaluates contextual attributes for access decisions [37↗], and the contextual awareness technique of NIST SP 800-160 Vol. 2 [36↗]. However, none of these frameworks defines a *governance-level* abstraction that names and formalises the combination of data, tools, services, and access rights as a coherent, auditable unit tied to a specific university activity. Cloud workspace products (AWS WorkSpaces, Azure Virtual Desktop) and container orchestration (Kubernetes namespaces with RBAC) implement aspects of this pattern operationally; TACs provide the **conceptual unification** needed for university governance, elevating from per-request access decisions to **per-activity environment composition**.

TACs rest on four fundamental principles:

Trustworthiness
: Each context is technically controlled, monitored, and bounded so that users can be granted a high degree of autonomy within it.

Dependability
: Failures, misconfigurations, or security incidents occurring within one context remain contained and cannot compromise the core infrastructure or other contexts.

User-centricity
: The digital environment adapts to the user's current role and activity rather than imposing a rigid and uniform security model on all users and all situations.

Observability
: Every action within a TAC is logged and auditable, ensuring that autonomy is accompanied by accountability.

TACs transform isolation from a restrictive mechanism into an **enabling** one. Isolation is no longer primarily a way to restrict users, but a way to safely grant autonomy. By ensuring that

each activity takes place within a controlled and isolated environment, the system protects its core functions while allowing experimentation, research, teaching, and collaboration to take place with a high degree of freedom.

A mature university architecture thus combines a *relatively stable segmentation* (network zones) with multiple *dynamic Trusted Activity Contexts* that operate within those zones, adapting to the roles, missions, and risk levels of each activity.

The forestry analogy is illuminating: a forest is not made safer by planting trees in a single continuous mass — on the contrary, it is the *creation* of firebreaks that prevents a blaze from spreading to the entire woodland.

Guiding principle for a university information system

A university information system must not attempt to prevent all errors, experiments, or unforeseen uses; it must prevent such events from compromising the institution as a whole.

In short: local freedom, incident confinement, protection of the core, global resilience.

Note for technical readers. A non-binding sketch of how the TAC concept might be assembled from current open-source and commercial building blocks — end-to-end sequence, endpoint operating-system support matrix, reference architecture by layer, and a wave-based migration playbook — is developed in the standalone companion document [6], with the explicit caveat that the proposal would benefit from verification against the IT department's actual environment.

These are precisely the principles that major universities apply, as the following sections demonstrate.

4 European regulatory context

> "Useless laws weaken the necessary laws."
>
> — Montesquieu, *The Spirit of the Laws* [41↗]

Methodology note

The regulatory analysis presented in this section is grounded in the publicly available legislative texts (the NIS2 Directive [12↗] and its national transposition, the Critical Entities Resilience (CER) Directive (EU) 2022/2557 and its national transposition, the GDPR [11↗], the European AI Act [42↗], and Commission Implementing Regulation (EU) 2024/2690 [43↗]), the binding case law (CJEU *Schrems II* [7↗]), and the national instruments (the national public-sector information-security policy and the national cybersecurity strategy's academic-cooperation objective) cited throughout. The analysis is produced by the contributors of this report acting in their academic-community capacity; it has not been formally validated by the institution's legal service. The contributors welcome formal legal review and remain available to discuss any specific correction that such review may identify. The reference shelf and citation chain enable any reader to verify each claim against its primary source.

4.1 GDPR Article 32: a *risk-based* obligation

Article 32 of the GDPR [11↗] requires data controllers to implement technical and organisational measures *"appropriate"* to ensure a level of security *"adapted to the risk"*, taking into account the *"state of the art"*, costs, context and the likelihood/severity of risks. It explicitly mentions:

- The ability to ensure the **confidentiality, integrity, availability** and **resilience** of systems;
- The ability to **restore availability** within appropriate timeframes;
- A process for **regularly testing and evaluating** the effectiveness of measures.

The European Data Protection Board (EDPB) (*European Data Protection Board*) [44↗] and European Union Agency for Cybersecurity (ENISA) [45↗] confirm that Article 32 is based on the *"appropriate to the risk"* standard and that measures must be adapted to the context.

Implication for universities: it is legally and operationally defensible to operate **multiple security domains** (administrative, research, teaching) with differentiated freedoms, provided that each domain has:

1. a documented risk assessment;
2. defined and traceable responsibilities;
3. controls proportionate to the sensitivity of the data;
4. evidence of regular effectiveness testing.

4.2 NIS2 Directive: the institution as an essential entity

Where the institution's jurisdiction has transposed the NIS2 Directive [12↗], a public research-and-teaching institution is typically classified — on written confirmation by the national competent authority (the NIS2 supervisory authority) — as an **essential entity** on the basis of its status as a public institution (NIS2 Annex I). This classification is independent of the institution's research activities and applies to the institution as a whole.

Such a classification rests on three cumulative legal pegs that the national transposition typically reproduces: the definition of the **public-administration entity** through four cumulative criteria (public-interest mission, legal personality, public funding or State control, decision-making power affecting cross-border movements); the clause under which a public-administration entity is essential *regardless of size*; and the provision which excludes teaching establishments from the "research organisation" track that would otherwise apply the lighter important-entity regime.

This report recommends that the institution accept this classification, where it applies, as the binding operational basis of its NIS2 compliance. Acceptance of the outcome does not entail suspension of intellectual scrutiny over the classification protocol itself: as a public knowledge institution hosting a computer-science department whose research portfolio covers information-systems security, the institution retains and is invited by this report to exercise a duty to contribute technical and methodological input to the supervisory authorities' classification practice (see Section 4.7).

This classification has three direct consequences:

1. **Holistic perimeter.** NIS2 obligations apply to the institution in its entirety, with no possibility to narrow the scope to specific services, faculties or units — a structural difference from NIS1.

2. **Higher level of obligations.** Essential entities are subject to proactive (*ex-ante*) supervision rather than the reactive (*ex-post*) oversight applicable to important entities, with heavier sanctions (Article 34) and stricter incident reporting obligations (Article 23).

3. **Continuous compliance evidence.** The institution is required to submit a regular compliance and maturity report to the competent authorities, which presupposes governance, audit and incident-management evidence at the level of the entire institution.

Article 21 proportionality. A holistic perimeter does not require uniform controls. NIS2 Article 21(1) requires *appropriate and proportionate* technical, operational and organisational measures, taking into account the state of the art, costs of implementation, and the entity's exposure to risk. The multi-zone architecture proposed in Section 12 is precisely the mechanism through which Article 21 proportionality is implemented across a heterogeneous public-research perimeter: it operationalises NIS2 compliance, it does not narrow the scope.

4.3 National institutional landscape

The European-level framework set out above is operationalised at national level through a jurisdiction-specific institutional and procedural ecosystem. The present subsection anchors the five elements directly relevant to the institution — stated in role-based terms — so that the proposed architecture is opposable point by point to the national bodies that supervise it. (The worked instantiation for a given regime is given in the Regulatory Applicability annex.)

4.3.1 Supervisory authority and incident-response chain

Three categories of national body typically hold direct, non-overlapping responsibilities towards the institution:

The NIS2 supervisory authority. The competent authority designated under the national transposition of NIS2; the body that issues the institution's essential-entity classification and to which the annual compliance and maturity report is addressed.

The national / governmental CSIRT. The incident-response team for public-sector entities, namely the national/governmental CSIRT. As a public institution, the institution reports incidents primarily through this team.

The national single point of contact. The body responsible for cross-border NIS2 cooperation and major-incident escalation; it commonly hosts both the national/governmental CSIRT and the national information-security agency.

Two further categories of body may exist for ecosystem disambiguation: a separate CSIRT serving the private sector, communes and non-governmental entities (relevant when third-party private partners are involved), and a financial-sector supervisor (competent only for the financial sector and not for the institution outside specific financial projects).

4.3.2 Notification platform

Many jurisdictions operate a single national incident-notification and risk-management platform that consolidates notifications across NIS, NIS2, EECC, GDPR and CER directives, operated by the supervisory authority in partnership with the national cybersecurity bodies and the competent data-protection authority. The institution, as an essential entity, discharges its NIS2 incident-notification obligations through such a platform on the binding 24-hour / 72-hour / 30-day cadence (NIS2 Article 23) and submits its annual maturity report through the same channel.

4.3.3 National strategy hook

National cybersecurity strategies commonly identify the strengthening of cooperation with the *academic and research sphere* as a national priority. Such an objective is the direct national-level political hook for the present report's positioning: the institution's contribution to the regulator's protocols (Section 4.7) is consistent with it.

4.3.4 Concomitant CER framework

The national CER transposition law, transposing the Critical Entities Resilience (CER) Directive (EU) 2022/2557, typically provides that every entity designated as critical under the CER framework is automatically essential under NIS2. A given institution may or may not be designated as a CER critical entity; the cross-reference is provided for regulatory-neighbourhood completeness.

The technical baseline applicable to NIS2 essential entities is further specified by Commission Implementing Regulation (EU) 2024/2690 [43↗] of 17 October 2024, directly applicable across the European Union and detailing the ten obligation families listed in NIS2 Article 21(2).

4.3.5 Public-sector reference framework

The public-sector information-security baseline is typically governed by a national public-sector information-security policy, developed by the national information-security agency and applicable to State administrations. Such a baseline establishes the objectives of confidentiality, integrity, availability and risk-based security-measure adoption. The multi-zone architecture proposed in Section 12 is positioned as a compatible operational implementation that adapts that baseline to the heterogeneous public-research perimeter of the institution.

4.4 Operational obligations and proposition-mapping

The defensibility of the present report rests on the demonstration that every obligation imposed by the national NIS2 transposition on essential entities — mirroring NIS2 Article 21(2) — is already addressed by the architectural propositions developed in Section 15. Two mapping tables make this visible.

Table 2: NIS2 Article 21(2) ten-family obligations mapped to the report's propositions

Art. 21(2) family	**Reference**	**Propositions covering**
1. Risk-analysis and SI security policy	Art. 21(2)(1°)	P1 (risk-based approach), P14 (per-zone evidence)
2. Incident handling	Art. 21(2)(2°)	P12 (security communities), P14 (evidence)
3. Business continuity (backup, recovery, crisis)	Art. 21(2)(3°)	P9 (Science DMZ), P11 (secure alternatives)
4. Supply-chain security	Art. 21(2)(4°)	P6 (open-source by default), P7 (enclave charters)
5. SI acquisition, development, maintenance security	Art. 21(2)(5°)	P11 (secure alternatives), P6 (open-source)
6. Effectiveness measurement	Art. 21(2)(6°)	P14 (per-zone evidence + maturity dashboard)
7. Cyber-hygiene practices and training	Art. 21(2)(7°)	P5 (Digital Policy Commission), training in P10 / P12
8. Cryptography policies	Art. 21(2)(8°)	P11 (secure alternatives), implicit in P3 (BYOD MFA)
9. HR security, access control, asset management	Art. 21(2)(9°)	P3 (BYOD), P7 (charters), P8 (autonomy with minimums), P10 (federated identity)
10. MFA and secured communications	Art. 21(2)(10°)	P13 (Zero Trust + MFA), P10 (federated identity)

The technical baselines for each family are detailed in Commission Implementing Regulation (EU) 2024/2690 [43↗], directly applicable across the European Union.

Table 3: Essential-entity-specific operational obligations

Obligation	**Reference**	**Current status**	**Planned action**
Auto-registration with the supervisory authority	National NIS2 transposition	Pending	Initial declaration (transition plan, step 0)
Notification of measures to the supervisory authority	National NIS2 transposition	Architecture produces the evidence (P14)	Annual maturity report via the national notification platform
Ex-ante supervision	NIS2 essential-entity regime	Architecture is audit-ready	Internal-audit cycle feeding the maturity report
Incident notification 24h / 72h / 30 days	NIS2 Art. 23	Section 4.3 introduces the platform	Incident-response procedure integrated with the platform's cadence
Personal liability of management bodies	NIS2 Art. 20	Implicit in governance	Documented in the executive-training programme (Section 12.5.2)
Executive training of management bodies	NIS2 Art. 20(2)	Implicit in Digital Policy Commission role	Programme via Digital Policy Commission (Section 12.5.2)

4.5 European AI Act and access to AI cloud services

The European regulation on artificial intelligence (AI Act, 2024) [42↗] introduces differentiated obligations according to the risk levels of AI systems. For universities, the issue is twofold:

1. **AI research:** researchers must be able to freely access APIs and cloud services from global providers (OpenAI, Anthropic, Google, Meta, HuggingFace, AWS, Azure) to train, evaluate and compare models. Some of these services are not hosted in the EU and are not fully GDPR compliant;

2. **AI teaching:** advanced courses require access to these same platforms for hands-on exercises on foundation models.

The AI Act [42↗] provides two distinct provisions relevant to research:

- **Article 2(6):** exempts AI systems *specifically developed and put into service for the sole purpose* of scientific R&D. This covers bespoke research tools built by researchers, **not** the use of commercial AI services (ChatGPT, Claude, Gemini) as research instruments;
- **Article 2(8):** exempts research, testing and development activities on AI systems *prior to their being placed on the market.*

For researchers *using* commercial AI APIs, the relevant framework is the AI Act's *risk-based classification*: the applicable obligations depend on the concrete use case and the user's role under the Act; many research uses fall outside the high-risk categories. This risk classification — not a blanket research exemption — is the defensible legal basis for differentiated AI cloud access in the research zone (see Section 11).

4.6 Regulatory summary

Table 4: European regulatory framework and architectural implications

Regulation	Key requirement	Architectural implication
GDPR Art. 32	Measures appropriate to the risk, resilience, testing	Multi-zone architecture with per-zone assessment
NIS2 (essential entity)	Holistic perimeter, proactive supervision, mandatory audits, annual maturity report; Art. 21 proportionate measures	Article 21 proportionality via multi-zone segmentation; enclave registry, incident playbooks, formalised federated governance
NIS2 (operational cadence)	24h/72h/30-day incident notification via the national notification platform + annual maturity report to the supervisory authority	Incident-response procedure integrated with the national platform; institution-level maturity dashboard producing the annual report
AI Act	Risk-based classification; obligations by risk level	Research zone with managed, differentiated AI cloud access
GDPR (transfers)	Standard contractual clauses for transfers outside the EU	Legal framework for access to US clouds (research)

4.7 Compliance posture and knowledge-institution responsibility

The propositions developed in this report cluster into four labelled positions, each named to clarify the nature of the contribution under the corresponding regulatory framework. The labelling is intended to make the dossier opposable to the supervisory authorities point by point and to distinguish operational compliance from areas where the report proposes a substantive interpretation or contributes to the regulator's protocol-improvement processes.

Note on tone. Throughout the four positions, references to the classification process, to the regulator's protocols, and to areas of ongoing methodological debate use the language of constructive contribution, not of dispute. The relationship the report proposes between the institution and the supervisory authorities is collaborative: the binding character of the regulatory framework is acknowledged in every relevant section; the institutional duty of intellectual contribution is acknowledged in parallel, without prejudice to the former.

Position A — Compliance. The majority of the report's propositions (P1, P3, P5, P6, P7, P9, P10, P11, P12, P13, P15) are unambiguously compliant under the national NIS2 transposition, given the architecture and operational mapping developed in this report. These propositions require no further intellectual treatment beyond the operational implementation roadmap (see Section 14); they form the compliance baseline of the dossier.

Position B — Documented interpretation. Three areas in which the report's interpretation is documented with its supporting reasoning so that it can be examined on its merits.

B.1 — Cross-border decision-making power (public-administration criterion). This report supports that the institution satisfies the fourth criterion of the public-administration entity definition through diploma issuance, ECTS recognition, and qualification certification. The interpretation is reasonable but novel; this report recommends that interpretive guidance be requested from the national supervisory authority and the national single point of contact as part of the auto-registration dialogue (Section 4.4).

B.2 — Cloud AI access for research under *Schrems II* + AI Act. The cumulative regime articulated in Section 11.4 is the strictest contemporary interpretation of CJEU *Schrems II* [7↗] in combination with the AI Act [42↗]. This report indicates that the TIA template and the data-classification table could be made available, as contributing artefacts, to the EDPB / European Data Protection Supervisor (EDPS) doctrinal effort on research-context transfers, to the extent that institutional decisions and resources allow.

B.3 — NIS2 Art. 21 proportionality applied to a multi-mission perimeter. The seven-zone segmentation as NIS2 Article 21 implementation (Section 4.2) is the operational thesis of this dossier. Prior practice in the public sector has frequently not formalised such a multi-zone approach; this report proposes it as a model and indicates that the supporting evidence (annual maturity report structure, risk-analysis-method instances) could be shared with peer public-administration entities, subject to institutional decision.

Position C — Influence and reform. Four areas in which this report identifies a legitimate channel for the institution, as a knowledge institution, to inform the legislator and the regulator about the operational consequences of current rules.

C.1 — Exclusion of teaching establishments from the "research organisation" track. Where the national transposition closes the research-organisation route for universities, it places them under the heaviest regime (essential entity via public-administration) by default. This report indicates that the institution is well placed to contribute to a post-transposition review of whether this allocation is operationally optimal — without advocating for a downgrading of the present classification.

C.2 — "Essential regardless of size" rule. Where this rule applies it is binding, and this report supports its full operational acceptance. The report indicates that the institution could contribute, as a knowledge institution, to evidence-based discussion at EU level on whether tiered

obligations within the essential category would improve overall NIS2 effectiveness — without advocating for any individual derogation.

C.3 — Right of the regulated entity to request review of its own classification. The national transposition, read in conjunction with the applicable national administrative-review framework, does not preclude the regulated entity from submitting evidence-based observations on the classification methodology applied to its case. This report supports that the institution does not currently exercise this right with respect to the substance of the decision (the essential-entity status is accepted as binding). The report indicates that this possibility could be reserved should methodological refinements emerge — particularly around the interpretation of the cross-border decision-making criterion — that materially affect the classification of comparable institutions.

C.4 — AI Act research-support principle and simplified notification. AI Act Recital 25 and the innovation-support measures of Chapter VI (Articles 57–63) [42↗] call for research and innovation activities to be supported and not unduly restricted. This report supports the proposition that the relevant legislator formalise a simplified notification framework for transfers of pseudonymised personal data in research contexts, in addition to the AI Act Articles 2(6) and 2(8) exemptions for bespoke research tools and pre-market R&D. This report indicates that the institution could contribute to a national or EU consultation on this framework, consistent with the national cybersecurity strategy's academic-cooperation objective and with the cooperative declaration model articulated in Section 11.4.

Position D — Methodological contribution to the supervisory authority. As a public knowledge institution hosting a computer-science department whose research portfolio covers information-systems security, the institution holds an intellectual and moral responsibility that exceeds mere compliance: a responsibility to share rigorous technical and scientific input with the bodies that design and operate the national cybersecurity-regulation protocols (the national supervisory authority, the national single point of contact and governmental CSIRT, and the national information-security agency). The present report is itself the first concrete expression of this contribution; the domains listed below are offered without commitment of resources or specific deliverables, on a case-by-case basis subject to the formal request of the relevant authority.

D.1 — Stress-testing of classification criteria. This report indicates that the institution could provide, on request or unsolicited, a peer-reviewed analysis of the four-criteria interpretation of the public-administration-entity definition, in particular the cross-border decision-making criterion, with comparative analysis across EU public-research entities.

D.2 — Open-source methodology and tooling. This report indicates that the institution could share, on request, the TIA template (Section 11.4), the data-classification table and the maturity-report structure adopted by the present report, as reference artefacts that the regulator and peer entities may adapt — subject to institutional decisions and resource availability.

D.3 — Consultative engagement. This report indicates that the computer-science department's expertise could be made available to the national supervisory authority's, the single point of contact's and the information-security agency's consultative processes, including standardisation working groups, post-transposition reviews of the national NIS2 transposition, and EDPB / ENISA working drafts when academic input is solicited.

D.4 — Academic-regulator dialogue artefacts. The annual maturity report submitted to the national supervisory authority pursuant to the national transposition is, on the institution's

side, a compliance artefact. This report indicates that the institution could voluntarily complement it with a short methodological annex sharing observations and proposed protocol refinements arising from the year's operational experience — subject to institutional decisions and resource availability.

D.5 — Research-context interpretation of the GDPR accountability principle (*Schrems II* application). This report proposes a cooperative researcher-centred model for personal-data transfers in research contexts: PI data classification, institutional register maintained by the central IT service on PI request, periodic DPO audit, with no per-access gatekeeping. The model operationalises GDPR Articles 24(1) and 5(2) in a way that preserves international scientific collaboration as an academic right. This report indicates that the institution could share its register template and audit methodology with the national supervisory authority, the competent data-protection authority and EDPB working groups, as a contribution to research-context regulatory practice — without commitment of resources beyond the present proposal.

5 Specificities of universities regarding IS

> "The university is not one community but several [...]. Its edges are fuzzy [...]. A community should have a soul, a single animating principle; the multiversity has several."
>
> — Clark Kerr, *The Uses of the University* [46↗]

5.1 The university as an open space

Universities fundamentally differ from businesses in:

User diversity: students (transient, personal equipment), academic staff (demanding autonomy), administrative staff, visiting researchers, international external collaborators, alumni.

Equipment diversity: managed workstations, BYOD (*Bring Your Own Device*), research instruments (often running legacy operating systems), IoT sensors, High-Performance Computing (HPC) clusters, laboratory servers.

Culture of openness: academic freedom implies that researchers can choose their tools, test configurations, deploy prototypes and collaborate internationally without bureaucratic obstacles.

Scientific openness: the *Open Science* [47↗, 48↗, 49↗] and *Open Data* [50↗] movements push towards fewer restrictions on sharing and access to data and tools.

AI as an everyday tool: in 2025–2026, generative artificial intelligence has become an essential working tool for research and teaching, requiring access to global cloud services.

5.2 Differentiated needs by mission

The table 5 summarises the contrasting needs of the three university missions.

Table 5: Differentiated needs by university mission

Criterion	Administration	Teaching	Research
Traffic profiles	Predictable, web/email	Moderate, LMS/labs	Sustained multi-Gbps flows
Security model	Stateful firewall, proxy	Standard controls	ACL, IDS, monitoring
Latency tolerance	Moderate	Moderate	Very low (HPC)
Bandwidth	1–10 Gbps	1–10 Gbps	10–400 Gbps
Ext. connectivity	Filtered Internet	Filtered Internet	Direct to NRENs
AI cloud access	Not required	AI APIs for courses	**Unrestricted, including outside EU**
Data sensitivity	Strict GDPR, financial	Moderate	Variable (open to classified)
Population	Admin. staff	Students, instructors	Researchers, collaborators
Required autonomy	Low	Medium	**High (root access)**
BYOD	Limited	Dominant (students)	Frequent (researchers)

Note: in a research-and-teaching university, *"Research"* encompasses both research-only units and the research activities of research-and-teaching departments; *"Teaching"* encompasses

both teaching/training-only components and the teaching activities of research-and-teaching departments. Research-and-teaching departments thus span two zones.

5.3 Effects of uniform restriction policies

The approach of reducing the attack surface through uniform maximum restriction suffers from several contradictions:

1. **Single point of failure:** a centralised, undifferentiated infrastructure creates a *single point of failure* — if the central system is compromised, *everything* is compromised.
2. **Shadow IT:** excessive restrictions push users toward unmanaged solutions (personal clouds, servers under desks, personal VPNs), creating major security blind spots [28↗, 30↗].
3. **Loss of skills:** computer science and cybersecurity researchers can no longer train students in system realities if they do not have access to administrable environments.
4. **Brain drain:** top-level researchers leave institutions where restrictions prevent them from working effectively, in favour of more flexible universities.

5.4 Staff BYOD: a structural need

Staff BYOD (*Bring Your Own Device*) — and not only student BYOD — is an unavoidable reality:

- Faculty members often use a personal laptop as their primary work tool;
- Internationally mobile researchers must be able to connect from any device;
- Prohibiting BYOD amounts to pushing toward Shadow IT (connections via personal hotspots, work on unmanaged clouds).

The solution is a **dedicated BYOD subnet** offering:

1. Full Internet access;
2. **Progressive interoperability** with other networks — that is, a graduated model in which the scope of accessible institutional resources increases with the level of authentication and device posture verification:
   - Without authentication: Internet only (guest zone);
   - With MFA authentication: access to teaching/research zone resources matching the user's profile;
   - With compliant device (verified posture): extended access including administrative resources via secure VDI.

6 State of the art: university infrastructure architectures

> "The good fighters of old first put themselves beyond the possibility of defeat, and then waited for an opportunity of defeating the enemy."
>
> — Sun Tzu, *The Art of War* [51]

6.1 Protected high-throughput research-data paths: the Science DMZ pattern

Research traffic that the general stateful-filtering perimeter penalises needs a dedicated, protected high-throughput path. Several realisations meet this function — NREN-operated dedicated circuits and lightpaths (GEANT), experiment-operated overlays (CERN LHCOPN/LHCONE), and tuned Data-Transfer-Node fabrics — of which the best-documented and most-instrumented is the *Science DMZ* pattern, a network architecture developed by ESnet (*Energy Sciences Network*) of the U.S. Department of Energy specifically for the needs of high-performance scientific research [29, 52, 53]. The remainder of this section describes the Science DMZ as the canonical instantiation; the same function is realised elsewhere by the NREN- and experiment-operated paths just named.

6.1.1 Principles

The Science DMZ is a portion of the network, built at the campus perimeter, whose equipment, configuration, and security policies are *optimised for scientific applications* rather than for enterprise systems.

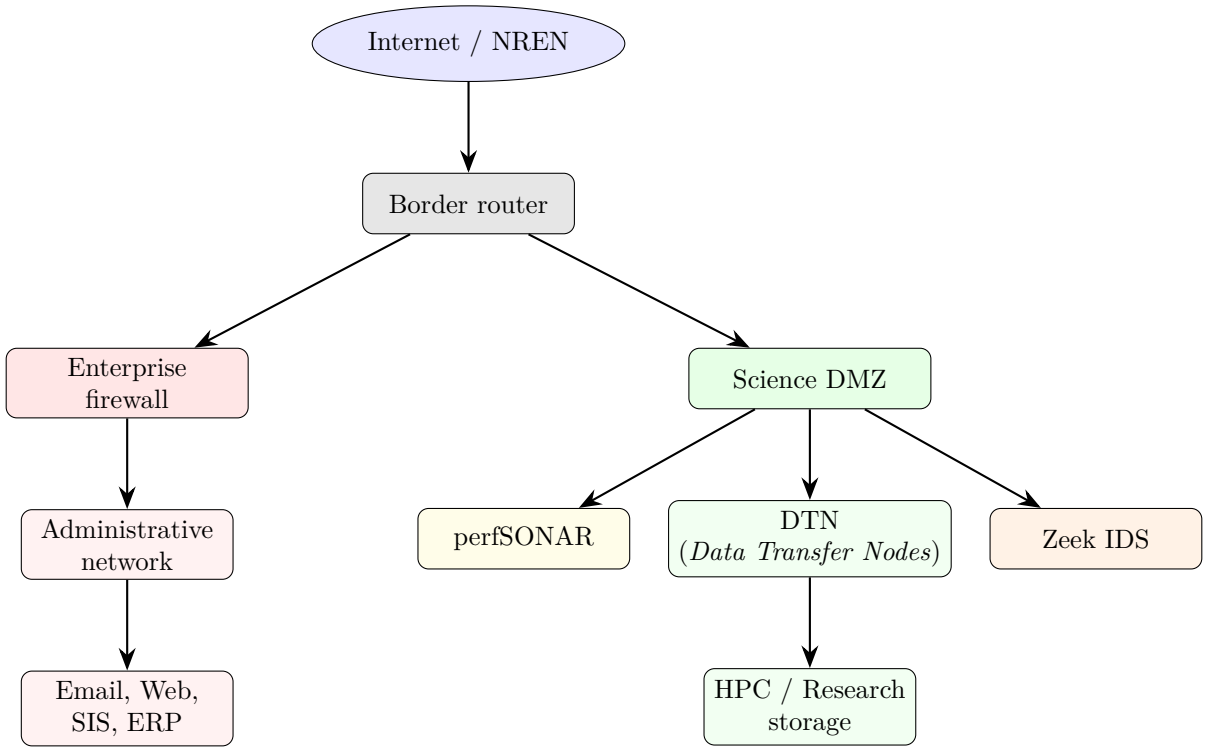


Figure 1: Science DMZ architecture: separation of research and administrative traffic

6.1.2 Key components

Data Transfer Nodes (DTN): servers dedicated to massive data transfers, using Globus [54] (HTTPS-based managed transfer), optimised for high-throughput flows.

Security through ACLs: while modern next-generation firewalls can technically achieve 100+ Gbps threat prevention throughput, they cost an order of magnitude more than the Science DMZ approach and introduce latency, jitter, and state-tracking overhead detrimental to sustained bulk transfers. Router-based access control lists (ACLs) can provide an appropriate control profile for the well-characterised, high-throughput traffic profiles typical of research data transfers, when combined with dedicated monitoring and strict host hardening [29↗].

perfSONAR: active network performance measurement platform [55↗], enabling detection and diagnosis of problems.

Dedicated monitoring: a specific IDS (Zeek, formerly Bro [56↗]) monitors Science DMZ traffic separately from the enterprise network.

This model is widely deployed across American research universities, adopted at over 100 university campuses with funding from the NSF *Campus Cyberinfrastructure* (CC*) program [57↗, 58↗]. In Europe and globally the same protected high-throughput function is met by NREN dedicated circuits and lightpaths (GEANT) and by experiment networks (CERN LHCOPN/LHCONE), rather than by a US-style campus enclave [52↗, 53↗].

Limitations and compensating controls. The Science DMZ model trades inline prevention for performance: Zeek provides detection but not inline blocking, and ACLs do not inspect application-layer content. These limitations are mitigated by (i) SOC monitoring of Zeek alerts, (ii) endpoint hardening on Data Transfer Node (DTN)s (minimal services, regular patching), (iii) the Trusted Activity Context framework proposed in this report, which confines each research activity to an isolated, monitored environment — ensuring that a compromise within one context cannot propagate laterally to other activities or to the infrastructure core.

6.1.3 Quantitative performance evidence

Table 6: Science DMZ case studies — measured results

University	Result	Ref.
U. of Florida	**x20** performance increase from the first phase; scaling up to 200 Gbps for LHC/CMS data	[59↗]
CU Boulder	*Core Split* architecture separating research and admin from the border router; resolution of firewall bottlenecks	[60↗]
Penn State	Increase from 50 Mbps to 250 Mbps (sending) and 600 Mbps (receiving) by bypassing a firewall that violated RFC 1323 (TCP Window Scaling) — **x5 to x12** gain	[61↗]
U. Michigan	Science DMZ with dedicated DTNs and perfSONAR; firewall repositioned near data sources rather than in the research path	[62↗]
Rutgers	Multi-campus fabric with Science DMZ + SDN + secure enclaves; research/-central IT partnership	[63↗]

Under classic TCP congestion control (Reno), the Mathis equation [64↗] predicts that even minimal packet loss severely degrades throughput on high-bandwidth links. While modern algorithms such as CUBIC — which carries the majority of research network traffic — are more loss-tolerant, they remain fundamentally constrained by packet loss. Any loss or jitter introduced by stateful inspection devices remains detrimental to sustained high-throughput transfers, particularly on long-RTT paths [65↗].

6.1.4 Enterprise IT vs Science DMZ comparison

Table 7: Enterprise model vs Science DMZ comparison

Characteristic	Enterprise Model	Science DMZ
Philosophy	Prevention through blocking	Detection and rapid response
Flow management	DPI of all packets	Lightweight ACLs + out-of-band IDS
Performance impact	High (jitter, latency)	Minimal for intended bulk-transfer paths
Tool management	Restrictive whitelist	Monitored autonomy
Shadow IT risk	High	Reduced (fewer incentives for workarounds)

6.2 VLAN network segmentation

VLAN segmentation is standard practice in most major universities. It consists of creating logically isolated network zones, each with its own security policies.

6.2.1 Typical VLAN categories

Table 8: VLAN categories in a typical university architecture

Zone	Security level	Content	Access
Administrative	High	Finance, HR, student IS, ERP	Restricted, IDS/IPS
Research	Flexible	HPC, Science DMZ, lab networks	High throughput, direct NREN access
Teaching	Moderate	Classrooms, LMS, teaching labs	Standard
Staff BYOD	Intermediate	Staff personal laptops	Internet + progressive interop.
Residential	Isolated	Student residences	NAT, limited, isolated
IoT / Building	Restricted	HVAC, lighting, access control	Isolated, no Internet
Guests / eduroam	Untrusted	Visitor Wi-Fi, conferences	Internet only

Important: VLANs provide *logical* separation but not security isolation on their own. They must be combined with inter-VLAN filtering (ACLs or firewall rules at Layer 3 boundaries), DTP disabled on all access ports, the native VLAN changed from default, and unused ports assigned to a dead VLAN. Without these hardening measures, VLAN hopping attacks remain feasible. The Trusted Activity Contexts proposed in this report add a further layer: even within a VLAN, each activity operates in its own isolated, policy-bound environment, limiting lateral movement *within* a zone as well as between zones.

Technical implementation: the network segmentation contract, zone catalogue, and Science DMZ patterns are developed in Chapter 8 of the standalone Technical Reference [6]. The wave-based migration approach to declaring zones and operationalising the standard interfaces is in Chapter 21 (Wave 3).

6.2.2 Multi-tier DMZ architecture

Universities typically maintain several DMZ tiers:

- **External DMZ:** web servers, Domain Name System (DNS), email relays — directly exposed to the Internet;
- **Application DMZ:** application servers requiring limited external access;
- **Science DMZ:** high-performance network path dedicated to research data transfers;
- **Management DMZ:** bastions (*jump boxes*), monitoring systems, out-of-band management.

6.3 Micro-segmentation and SDN

Beyond traditional VLAN segmentation, modern approaches use:

Micro-segmentation: isolation at the individual workload level, and no longer only at the subnet level. Technologies: VMware NSX, Cisco ACI, Illumio.

SDN (*Software-Defined Networking*): enables dynamic provisioning of network segments and automated response to security incidents. Examples of platforms (commercial and open-source): Cisco DNA Center, OpenDaylight, ONOS.

Dynamic 802.1X: port-level authentication with dynamic VLAN assignment based on the identity and posture of the device.

6.4 Adapted Zero Trust architecture

The Zero Trust architecture (Zero Trust) architecture (*"never trust, always verify"*) [66↗] eliminates the concept of a trusted internal network. Its application to universities requires specific adaptations:

Table 9: Progressive Zero Trust implementation in a university environment

Phase	Component	Actions
1	Identity	IAM, universal MFA, federation via InCommon/eduGAIN [67↗]
2	Device	EDR, posture verification, device certificates
3	Micro-segmentation	SDN, least-privilege network access
4	Continuous monitoring	SIEM, UEBA, dynamic risk scoring

The key adaptation for universities is to recognise that:

- The requirement for managed devices is not achievable for all users (dominant BYOD);
- Differentiated access levels are necessary (more access with managed device + MFA, limited access with unmanaged device);
- Research instruments and IoT require exemptions or special treatment;
- eduroam [26↗] and identity federations constitute the natural identity layer.

6.5 Medical Science DMZ: proof for sensitive data

The argument "everything must be locked down because of sensitive data" is challenged by the **Medical Science DMZ**, a design pattern developed by researchers from Harvard, the University of Chicago, Indiana University and Lawrence Berkeley National Laboratory [68↗]. This model handles biomedical data (HIPAA) without sacrificing performance:

- Security through **end-to-end encryption** and strict endpoint authentication — not through inspection of every packet;
- Sensitive data in **dedicated enclaves** with strict ACLs, logically separated from open research traffic.

If medical data subject to HIPAA can be processed in a segmented architecture, university research data can *a fortiori* be processed in such an architecture.

7 Examples of universities with decentralised architecture

> "If I have seen further, it is by standing on the shoulders of Giants."
>
> — Isaac Newton, letter to Robert Hooke, 1675/76 [69↗]

This section presents concrete examples of world-leading universities that successfully implement decentralised and federated architectures.

Relevant and Adequate Reference panel. The panel below covers institutions of varying size, governance models, and regulatory environments. Its composition reflects four selection criteria:

1. **Principles vs. implementations.** The architectural primitives discussed — segmentation, enclave charters, federated identity, Science DMZ, BYOD zoning — are governance and design choices that translate across scales of institution.
2. **Shared backbone services.** All institutions in the panel access the same NREN/GEANT backbone services. The adopting institution's own NREN is a peer member of the same federation (see Section 4.3), providing equivalent primitives at the national scale.
3. **Size-comparable institutions.** The panel includes EPFL (∼12 000 students, comparable to a mid-sized research university) [70↗], CERN (governance model translatable to research-and-teaching consortia) [71↗], and Paris-Saclay (multi-institution federation in a public-research perimeter regulated under an EU national equivalent of the framework) [72↗], alongside larger institutions.
4. **Track record.** Institutions of this kind commonly have substantial experience adapting external models to their specific public-research context.

7.1 Massachusetts Institute of Technology (MIT)

MIT operates one of the most historically decentralised IT models in higher education. IS&T (*Information Systems & Technology*) [73↗] is the central IT organisation, but MIT has always adopted a philosophy of *"distributed computing"* inherited from the **Project Athena** (1983–1991) [74↗].

Network: MITnet provides a 100 Gbps campus backbone connected to Internet2 and commercial ISPs [75↗].

Departmental autonomy: laboratories (CSAIL, Lincoln Laboratory, Media Lab, Koch Institute) operate their own IT staff, their own servers, and network segments. CSAIL's *The Infrastructure Group* (TIG) independently manages multiple data centers [76↗].

Segmentation: extensive use of VLANs. Departments can request their own VLANs; laboratories with sensitive data (ITAR, HIPAA) operate on isolated segments.

Security philosophy: the MITnet Rules of Use [77↗] reflect a tradition of host-based security rather than perimeter defence. Each system owner is responsible for hardening their own systems.

Legacy: MIT invented the **Kerberos** protocol during Athena [78↗], still used on campus alongside Shibboleth/SAML.

7.2 Stanford University

Stanford operates a **federated** IT model. University IT (UIT) [79↗] provides the core infrastructure, but each of the seven schools has its own IT organisation with significant autonomy.

Network: SUNet [80↗] is the campus backbone, one of the most advanced university networks, with a multi-tier architecture (backbone, distribution, access).

Multiple IT organisations:
- The School of Engineering has its own IT group (∼40 staff) [81↗] managing HPC clusters and laboratory networks;
- The School of Medicine operates Technology & Digital Solutions (TDS) [82↗], a parallel IT organisation with dedicated security staff, managing a HIPAA-compliant infrastructure;
- SLAC (*National Accelerator Laboratory*) has an entirely independent network and IT [83↗];
- The Stanford Research Computing Center (SRCC) [84↗] provides centralised HPC (Sherlock cluster) but individual laboratories also manage their own infrastructure.

Security: *shared responsibility* model. UIT manages the perimeter firewall and campus policies, but each school's IT is responsible for security within its domain.

7.3 University of Cambridge

Cambridge is one of the most **decentralised universities in the world**, due to its collegiate structure [85↗].

Network: the UDN (*University Data Network*, historically called CUDN) [86↗] is the multi-gigabit fibre backbone connecting colleges, departments, and buildings. Connected to JANET/Jisc (UK NREN).

Collegiate decentralization:
- Each of the **31 colleges** operates its own IT infrastructure: network segments, servers, email systems, Wi-Fi;
- Departments (Computer Science and Technology, Cavendish Laboratory, MRC Laboratory of Molecular Biology) have substantial independent IT operations.

Network delegation: the UDN provides connectivity but *delegates subnet management* to institutions [87↗]. Each institution manages its own Dynamic Host Configuration Protocol (DHCP), DNS, and firewall rules.

IP delegation: Cambridge owns a complete /16 block (131.111.0.0/16) and delegates /24 or larger blocks to institutions [88↗].

Security: the UDN operates as a largely open network within the backbone. Individual institutions are responsible for firewalling their own segments. UIS monitors the backbone for abnormal traffic and can isolate failing segments.

7.4 ETH Zurich

ETH Zurich operates a **hybrid centralised-federated** model [89↗]. Informatikdienste (ITS) provides the central IT infrastructure, but each of the 16 departments has its own IT Service Group (ISG) [90↗] and often dedicated IT staff.

Network: high-speed fibre backbone connecting the Zentrum and Hoenggerberg campuses, linked to SWITCH (Swiss NREN) at 100+ Gbps.

Autonomy: each department can operate its own servers, including computing clusters. The Computer Science department (D-INFK) manages its own substantial server infrastructure.

Segmentation: extensive VLANs with 802.1X network access control. Separate zones: administrative, teaching, research, DMZ.

Federated services: via SWITCH: SWITCHaai (federated identity), SWITCHdrive (cloud storage), SWITCHengines (OpenStack IaaS).

Key innovation — the Administrator Rights Agreement: Unlike a total ban, ETH Zurich has formalised root access through an *Agreement Regarding Administrator Rights* [21↗]:

- The user can request root rights if needed for their thesis or research;
- By signing, the user accepts responsibility for maintenance;
- The user commits not to disable basic security mechanisms (logs, antivirus, updates);
- It is a *transfer of responsibility* rather than a technical lockdown.

The baseline IT protection rules [17↗] require that non-compliant resources be placed in *isolated network zones* so that weaknesses are not exploitable from the outside.

7.5 Carnegie Mellon University (CMU)

CMU has a historically significant role in distributed computing, notably through the **Andrew Project** (1982–c. 1989) [91↗] which created the AFS distributed file system.

Autonomy: the School of Computer Science (SCS) operates its own IT infrastructure [92↗], including its own Kerberos realm (`CS.CMU.EDU`), its AFS cell, its computing clusters, and its network segments.

SEI: the Software Engineering Institute [93↗], a DoD-funded Federally Funded Research and Development Center (FFRDC), operates an entirely separate IT environment with DoD security requirements.

Legacy: AFS provides a global namespace (`/afs/cs.cmu.edu/`) [92↗] with Kerberos authentication, historically used at many institutions (CERN used it for over 20 years before beginning migration to EOS/CERNBox).

7.6 University of Michigan

Michigan operates a **federated model with central coordination** [94↗, 95↗]. ITS provides the shared infrastructure, but each of the 19 schools and colleges has its own IT organisation.

Network: UMNet provides the campus backbone across Ann Arbor, Dearborn and Flint. Michigan is also part of MiNet, a dedicated inter-university research network operated by Merit Network connecting U-M, Michigan State and Wayne State [96↗]. Michigan co-founded Merit Network [97↗] and was among the 34 founding universities of Internet2.

Federated governance:

- An *IT Council* [98↗] serves as an enterprise-wide advisory group to the VPIT-CIO, including IT leaders from each school;
- Michigan Medicine operates as a quasi-independent IT organisation (HITS) with its own CISO [99↗];
- CAEN (*Computer Aided Engineering Network*) [100↗] in the School of Engineering has its own clusters and infrastructure;
- Advanced Research Computing (ARC) [101↗] provides centralised HPC but laboratories can supplement with their own hardware.

Micro-segmentation: network divided into security zones with different trust levels. Sensitive data (CUI, HIPAA, FISMA) is placed on dedicated sensitive data environments [102↗].

Classification: *Safe Computing* [102↗] program defining levels (High, Moderate, Low, Public) associated with specific network and system requirements.

7.7 CERN

CERN operates one of the most sophisticated research network architectures in the world [71↗].

Campus network: tens of thousands of connected devices across the Meyrin (Switzerland) and Prevessin (France) sites, with a multi-100 Gbps backbone and over 50 000 km of optical fibre.

Experiment networks: each LHC experiment (ATLAS, CMS, ALICE, LHCb) operates its own dedicated network segments:

- Experiment control networks (isolated, high security);
- Data acquisition networks (ultra-high throughput, up to Tbps);
- Analysis networks (for physicists).

Strict separation: the **Technical Network** (accelerator control) is *strongly isolated by firewalls and strict ACLs* from the general network (GPN) for critical system security [103↗].

WLCG: tiered architecture (Tier-0 at CERN, 14 Tier-1 centers, ∼150 Tier-2 sites, university Tier-3 clusters) distributing worldwide computing via LHCONE [53↗, 104↗].

Security model: CERN balances perimeter controls (closed-by-default outer firewall) with extensive *monitoring and rapid response*, explicitly ensuring that security measures *"do not obstruct the operations of CERN's accelerators and experiments or limit academic freedom"* [105↗].

7.8 University of Oxford

Oxford explicitly describes itself as **federated** [18↗]. Departments have substantial autonomy and responsibility for implementing information security under an overarching strategy defined by central security functions. Unit heads are *accountable*, may implement the strategy as they see fit, and must define and document the roles, contacts and requirements of their department.

7.9 École Polytechnique Fédérale de Lausanne (EPFL)

EPFL has set up a **Research Computing Platform** (RCP) offering an à la carte infrastructure [70↗]: storage, GPU resources, research clusters and general server resources that researchers can provision according to their needs.

ETH Zurich's Data Stewardship model: At ETH Zurich, **Data Stewards** are deployed directly in departments [106↗] — experts bridging the gap between compliance and technical reality, ensuring security *by design* and not *by obstruction*.

7.10 University of Wisconsin-Madison

The university promotes federation as a *structured partnership* preserving local research and teaching capabilities while improving consistency and monitoring [20↗].

7.11 North Carolina State University

Described by EDUCAUSE [107↗] as a federated IT organisation with a central IT (OIT) and independent units in colleges, libraries, institutes and departments. Governance is explicitly aligned with the missions (education, research, administration, user experience).

7.12 Penn State

Penn State has unified IT professionals from many units while maintaining unit agency through participatory governance and SLAs [108↗].

7.13 French universities

7.13.1 Université Paris-Saclay

Paris-Saclay is a particularly interesting case because it is a **grouping of institutions** [109↗]: the university proper, CentraleSupélec, ENS Paris-Saclay, IHES, and numerous CNRS/CEA/INRIA laboratories. *Note: École Polytechnique, although geographically located on the Saclay plateau, is a member of Institut Polytechnique de Paris (IP Paris), a distinct entity from Université Paris-Saclay.*

- Each member institution maintains its own IT infrastructure and its own identity system;
- Federated identity uses the RENATER federation (FER) for inter-institutional authentication;
- The multi-institutional nature makes federation *structural and not optional*;
- Interoperability is ensured by standardised protocols (eduroam, Shibboleth, RENATER connectivity).

7.13.2 Sorbonne Université

Resulting from the UPMC / Paris-Sorbonne merger, with integration of associated research laboratories:

- The IT department provides central services, but faculty and laboratory IT teams persist;
- CNRS joint research units within Sorbonne — such as LIP6 [110↗] (computer science) and LPNHE [111↗] (nuclear physics) — manage their own servers, computing clusters, and internal network configurations.

7.13.3 CNRS–University model

CNRS laboratories (UMR — Joint Research Units), often embedded within universities, *naturally* create a federated model: CNRS and university IT coexist, each UMR typically having its own network segment within the host university's infrastructure.

7.14 Organizational models: charters and accountability

Rather than informal exceptions, high-performing universities use **institutional instruments**:

Enclave charters: modeled on Oxford [18↗], unit heads are accountable, define roles and contacts, and document their department's requirements.

Service catalogue: EDUCAUSE [112↗] provides a model including "Research", "Teaching" and "Information Security" as service categories.

Formalized exception path: ETH Zurich formalizes self-assessment, registration, temporary exemptions and isolation zones as mechanisms to support non-standard needs [17↗].

IT charter: in France, CNRS and universities such as UPPA [113↗] or Le Havre [114↗] use charters defining responsibilities rather than blocking usage.

Key persuasion point for central IT: charters and catalogs transform *"freedom"* into *accountable, auditable autonomy.* They produce artifacts useful as GDPR Article 32 evidence.

7.15 Comparative summary

Table 10: IT autonomy models in reference universities

University	Model	Segm.	Distinctive characteristic
MIT	Distributed	VLAN	Athena philosophy, host-based security
Stanford	Federated	Multi-tier	7 schools with autonomous IT, independent SLAC
Cambridge	Decentralised	Delegated	31 autonomous colleges, delegated IP
ETH Zurich	Hybrid	802.1X	Per-department ISG, federated SWITCH
CMU	Distributed	VLAN	Global AFS, autonomous SCS
Michigan	Coordinated fed.	Micro-seg.	IT Council, 19 schools
CERN	Multi-domain	Isolated (FW)	Per-experiment networks, global WLCG
Oxford	Federated	Departmental	Accountable unit heads, charters
EPFL	Hybrid	Enclaves	RCP, Data Stewards in labs
Wisconsin-Madison	Federated	Partnership	Federation preserving local capabilities
NC State	Federated	Missions	Mission-aligned governance
Penn State	Unified-federated	SLA	Participatory governance
Paris-Saclay	Structural fed.	Institutional	Multi-institution federation

8 Media-Covered Failures in Universities (2024–2025): Context and Lessons

> "The first principle is that you must not fool yourself — and you are the easiest person to fool."
>
> — Richard P. Feynman, *Cargo Cult Science*, 1974 [115↗]

Proposals for **network segmentation**, **federated governance** and differentiated access (research, BYOD, AI) are sometimes opposed on the grounds that "open" or "flexible" policies would expose universities to the kind of high-profile incidents that made headlines in 2024 and 2025. **This section summarises the most media-covered failures, analyses their root causes, and shows that these incidents do not support the claim that the solutions proposed in this report are too risky** — on the contrary, they underscore the need for *segmentation* and *risk-based governance* rather than for uniform restriction.

8.1 Scope and purpose

The aim here is not to minimise the harm caused by breaches or to assign blame to specific institutions. It is to provide a factual basis so that debate relies on **cause and architecture**, not on anecdote. When incidents are cited as proof that "permissive" policies fail, the appropriate response is to distinguish: (i) *third-party and supply-chain vulnerabilities*, (ii) *centralised, unsegmented perimeters* enabling lateral movement, and (iii) *credential compromise* — none of which are addressed by locking down research and teaching zones. Sector reports (Verizon DBIR, Sophos, EDUCAUSE) and normative frameworks (NIST) consistently point to **segmentation** and **isolation of activity contexts** as defences, not to blanket restriction.

8.2 Most media-covered incidents (2024–2025)

8.2.1 France

Université Paris-Saclay (August 2024): A ransomware attack claimed by RansomHouse affected central administrative services, email and data servers; the institution's website and digital services were severely disrupted. The attack reportedly involved theft of around 1 TB of data and compromise of employee credentials (infostealer activity). Recovery lasted months; the university did not pay the ransom and worked with the French national cybersecurity agency (ANSSI). **Relevant point:** the systems targeted were *central* administrative and email infrastructure — a large, undifferentiated perimeter. The incident illustrates the risk of a **single point of failure** and the value of isolating sensitive administrative data in a dedicated enclave, as recommended in this report [72↗, 116↗].

Université de Rennes (March 2025): The university reported a cyberattack affecting a *teaching subnet* (ISTIC — computing and electronics). The group FunkSec claimed theft of sensitive data and used double extortion. The university stated that the impact was limited to that subnet and that main networks remained operational. **Relevant point:** containment to a subnet is consistent with the benefit of **network segmentation**; the incident does not support the argument that flexible or segmented policies are inherently riskier [117↗].

Sorbonne Université: Also reported a cyberattack with data theft in 2024; less detailed public information is available [118↗].

8.2.2 United States and international (2021–2024)

- **Texas Tech University Health Sciences Center** (September 2024): Ransomware (Interlock); about 1.4 million individuals affected; healthcare and administrative data [119↗].

One of the largest university-related breaches of the year; the context is a *health sciences* and administrative perimeter, not research openness.

- **MOVEit supply-chain attacks** (2023–2024): The Cl0p group exploited a vulnerability in Progress MOVEit Transfer software. Many universities were affected (e.g. UCLA, Stanford School of Medicine, University of Missouri, Rutgers, University of Georgia, Yeshiva). **These breaches were caused by a *third-party software vulnerability*, not by institutional policies on openness or segmentation.** Affected institutions patched the product and improved vendor oversight; the lesson is supply-chain and vendor risk, not restriction of research or teaching zones [19↗, 120↗].
- **Howard University** (September 2021): Ransomware forced a campus shutdown and class cancellations for approximately ten days; the university stated that personal data did not appear to have been compromised [121↗]. **Western Sydney University** (2024): Multiple incidents; threat actors used *compromised IT accounts* to access the student management system and data warehouse [122↗]. This pattern — **credential compromise and lateral movement across systems** — is exactly what **network segmentation** is intended to limit [123↗].

8.2.3 2025: Oracle E-Business Suite and other vectors

In 2025, a major wave of incidents in higher education was linked to exploitation of *critical zero-day vulnerabilities in Oracle E-Business Suite* (CVSS 9.8), used by the Cl0p group for mass data extortion [124↗]. Affected institutions included the University of Phoenix (3.5 million records, per its SEC filing), Harvard (1.3 TB exfiltrated), Dartmouth (35 000+ individuals), University of Pennsylvania, and Baker University, among others [124↗]. Oracle EBS is widely used for *financial and administrative operations* (payroll, tuition, vendor payments). **Again, the root cause is a *third-party product vulnerability* and supply-chain risk, not the degree of openness of research or teaching networks.** Sector surveys (e.g. Sophos State of Ransomware in Education 2025) report that in higher education, *exploited vulnerabilities* and *unknown security gaps* are among the top identified causes — consistent with the need for hardening, patching, and segmentation of high-value perimeters, not with uniform lockdown [124↗, 125↗].

8.3 Root causes: what the failures actually show

Table 11: Recurring causes of media-covered university incidents (2024–2025)

Cause type	What it implies for policy
Third-party / supply-chain (MOVEit, Oracle EBS)	Vendor risk, patching, and isolation of critical apps — not restricting research/teaching zones.
Credential compromise & lateral movement (e.g. Paris-Saclay, Western Sydney)	Need for **segmentation** and least-privilege access so that one compromise does not expose the whole institution.
Centralised, undifferentiated perimeter (e.g. Paris-Saclay central services)	Aligns with this report's argument: a single large perimeter creates a **single point of failure**; administrative data should be in a dedicated, hardened enclave.
Phishing / human factor (a recurring vector in higher education [19↗])	MFA, awareness, and identity governance — not blanket restriction of academic networks.

The Verizon 2024 Data Breach Investigations Report and NIST guidance emphasise **segmentation and isolation** to limit lateral movement and contain incidents [19↗, 126↗]. **Media-covered failures in 2024–2025 do not demonstrate that segmented, risk-based architectures are too risky; they demonstrate that *lack* of segmentation and *undifferentiated* perimeters increase impact when a breach occurs.**

Key takeaway

The incidents most cited in the media (Paris-Saclay, MOVEit, Oracle EBS, Texas Tech, Rennes, etc.) are not evidence that the solutions proposed in this report — segmentation, federated governance, differentiated zones — "do not work" or are "too risky". Taken together, these incidents more strongly support the need for segmentation, supply-chain risk management, credential protection, and internal containment than for uniform restriction. The root causes — third-party and supply-chain risk, credential compromise, and centralised perimeters without internal boundaries — require *precisely the kind of architecture and governance* advocated here: strong protection of the administrative enclave, clear boundaries between zones, and accountable autonomy in research and teaching, with monitoring and incident response aligned to each zone's risk level.

8.4 Conclusion of this section

A fair reading of the most media-covered university failures in 2024 and 2025 supports **strengthening segmentation and federated governance**, not retreating into uniform restriction. Opponents of differentiated policies may invoke these incidents as proof of risk; this section provides the factual and analytical basis to show that **the causes are largely unrelated to "open" research or teaching policies** and that the recommended measures (multi-zone architecture, charters, evidence-based controls) are the appropriate response to the types of failures observed.

9 National Research and Education Networks (NREN)

> "The web is more a social creation than a technical one. I designed it for a social effect — to help people work together — and not as a technical toy."
>
> — Tim Berners-Lee, *Weaving the Web* [127↗]

Universities are not isolated: they belong to research and education network ecosystems that provide connectivity, federated services and shared security.

9.1 European ecosystem

GÉANT [52↗]: pan-European backbone network connecting around 40 NRENs across Europe, serving 50 million users in 10 000+ institutions. Backbone capacity: multiple wavelengths at 400 Gbps.

RENATER [128↗]: French NREN connecting all universities, research laboratories (CNRS, INRIA, CEA, INSERM) and French grandes écoles. Multi-100 Gbps backbone.

DFN [129↗]: German NREN with the X-WiN backbone and DFN-CERT for incident response.

SWITCH [130↗]: Swiss NREN with SWITCHaai (federated identity), SWITCHdrive and SWITCHengines (OpenStack IaaS).

JANET/Jisc: UK NREN.

9.2 Key federated services

Table 12: Federated services provided by NRENs

Service	Operator	Description
eduroam [26↗]	GÉANT	Federated Wi-Fi: a researcher connects at any worldwide institution with their local credentials
eduGAIN [67↗]	GÉANT	Global identity interfederation (80+ federations, inter-institutional SSO)
FER	RENATER	French identity federation (part of eduGAIN)
GÉANT TCS	GÉANT	Trusted certificate service for institutions
perfSONAR [55↗]	ESnet/GÉANT	Distributed network performance monitoring
Globus [54↗]	U. Chicago	High-performance research data transfer

9.3 NREN architecture: common pattern

All NRENs follow a similar architectural pattern:

1. **National backbone:** high-speed optical network connecting major cities;
2. **Regional aggregation:** regional networks or points of presence (PoP);
3. **Campus connection:** each university connected at 10–100 Gbps;
4. **Peering:** interconnection between NRENs (via GEANT in Europe) and with the commercial Internet;
5. **Federated services:** identity, eduroam, certificates, security (CSIRT).

Essential point: this model inherently relies on **federation** and **decentralization**. If NRENs operate on a federated model at the national and international level, it is natural and consistent for universities to adopt the same model internally.

9.4 NREN status: what is typically in place, what is missing

In many national ecosystems the public documentation of the NREN and of the institution's HPC facility does not, as of early 2026, evidence a deployed Science DMZ at the institution or at the national NREN level. A typical NREN advertises 10–100 Gbps point-to-point links on demand and a 100 Gbps uplink to GEANT [52↗], but publishes no dedicated DTN fabric, no public **perfSONAR** endpoint [55↗], and no Science DMZ reference design. HPC data-transfer documentation commonly lists `rsync`, `scp`, `sshfs` and SMB to central storage — a profile typical of an enterprise-IT path, not the friction-free, monitored research path described in [29↗, 131↗].

The substrate is present; the pattern is not. The *building blocks* required for a Science DMZ are frequently already operational: high-bandwidth GEANT connectivity through the national NREN, the NREN's CSIRT for incident response, and an institutional HPC facility with petabyte-scale research traffic to a national/EuroHPC supercomputer and to international partners. What is missing is the architectural *pattern*: a dedicated zone, DTNs, perfSONAR observability, and the governance charter that together turn raw bandwidth into research-usable, monitored, segregated capacity.

Is it a reasonable option? On the evidence available, yes — with two qualifications that the design must internalise:

- **Mutualised, not siloed.** Where the national research ecosystem is small (the institution together with a handful of national research institutes), it may be too small for several separate Science DMZs. The operationally rational form is then an NREN-anchored Science DMZ *co-designed* with the national NREN, federated across the research-active institutions, with a Medical Science DMZ enclave [68↗] for biomedical workloads subject to GDPR Article 9.
- **Benefits are not automatic.** Recent quantitative work shows that a Science DMZ outperforms enterprise paths only after deliberate tuning of hosts, protocol stacks and measurement; absent that tuning, latency on long-RTT paths can even degrade [65↗]. The investment must be paired with operational ownership (perfSONAR baselining, Zeek monitoring, DTN lifecycle), not treated as a one-shot procurement.

The operative question is therefore not "Should the institution adopt a Science DMZ on its own?" but: *Should the national ecosystem, through its NREN, deploy a federated research-network zone that the institution and the other research-active institutions can jointly consume?* This reframing is consistent with the federation principle just established and with the cost-feasibility structure developed in Section 13.

10 Normative and governance frameworks

> "Plans are worthless, but planning is everything."
>
> — Dwight D. Eisenhower, 1957 [132↗]

10.1 NIST Cybersecurity Framework 2.0

The NIST Cybersecurity Framework [133↗] (version 2.0, February 2024) provides a structured approach to cybersecurity risk management, widely adopted in higher education.

Table 13: NIST CSF 2.0 functions applied to universities

Function	Code	University application
Govern	GV	Digital Policy Commission with elected academic representation, risk appetite acknowledging research openness
Identify	ID	Asset inventory (BYOD challenge), data classification, risk assessment by unit
Protect	PR	IAM via InCommon/Shibboleth, MFA, training, technologies that do not impede research workflows
Detect	DE	SOC (shareable via REN-ISAC [134↗]), Zeek/Suricata monitoring, threat intelligence
Respond	RS	Response plans accounting for the academic calendar and research continuity
Recover	RC	Continuity plans for critical periods (exams, enrollment), research data recovery

Key point: the NIST CSF is a *risk*-based framework, not a *restriction*-based one. It does not prescribe uniformly reducing the attack surface through prohibitions — rather, it prescribes assessing risks and applying proportionate controls.

10.2 ISO 27001:2022

The ISO/IEC 27001:2022 [16↗] standard provides a framework for an Information Security Management System (ISMS).

10.2.1 University adaptations

- **Scope (Clause 4):** the Information Security Management System (ISMS) can cover central IT only or specific systems, reflecting the reality of federated governance;
- **Leadership (Clause 5):** management commitment must include the president/rector and the vice-president for teaching, not only the CIO;
- **Control A.8.22 (Network segregation):** directly relevant to the VLAN / Science DMZ segmentation described above;
- **Control A.8.23 (Web filtering):** particularly sensitive in an academic context because web filtering may conflict with academic freedom.

10.2.2 ISO 27001 certified universities

Several universities have obtained certification, typically for specific scopes:

- University of Leeds (UK) — IT services;
- University of Warwick (UK) — IT services;
- Eindhoven University of Technology (Netherlands);

- Various universities in Germany, Australia and Japan.

Observation: in most cases, certification covers *central IT services* and not the entire institution, which *reflects and validates* the federated governance model.

10.3 NIST SP 800-171 and secure enclaves

For universities receiving sensitive funding (notably US DoD), NIST SP 800-171 Rev. 3 [135↗] (May 2024) specifies 97 security requirements (consolidated from 110 in Rev. 2 [39↗]). The university response is *not* to lock everything down, but to create compliant **enclaves** for processing controlled data, while the rest of the institution operates at security levels appropriate to each zone.

This **secure enclave** model within an open architecture has accelerated the adoption of network segmentation and Zero Trust in research universities.

10.4 COBIT 2019 for IT governance

The COBIT 2019 [136↗] framework from ISACA is particularly relevant for universities because it explicitly distinguishes *governance* (strategic direction) from *management* (operational execution).

Table 14: IT decision domains adapted to universities (after Weill & Ross [137↗])

Domain	Who decides	Example
IT principles	Leadership + Digital Policy Commission	Cloud-first policy, open-source preference
IT architecture	Central IT (with faculty input)	Network standards, identity federation
IT infrastructure	Central IT	Data centers, backbone, baseline security
Application needs	Faculties/departments	Research software, specialised databases
IT investments	Joint committee	Budget allocation between research IT and administrative IT

10.5 A nationally provided risk-analysis methodology

Several jurisdictions provide an open-source, ISO/IEC 27005-aligned risk-analysis method and tool — often developed by a national cybersecurity competence centre — that enables organisations to conduct optimised, precise and repeatable risk assessments, leveraging the capitalisation of risk-analysis scenarios already produced in similar contexts, and integrated into the national incident-notification platform as the risk-analysis module for NIS2-related obligations.

For the adopting institution, such a method carries a specific operational relevance: being aligned with ISO/IEC 27005, it is directly usable for the institutional maturity-report structure and the per-zone risk-analysis evidence that Proposition 14 (Section 15) consolidates into a single annual score submitted to the national supervisory authority. Where no such national tool exists, any ISO/IEC 27005-conformant method serves the same purpose.

10.6 Risk-based approach vs. compliance-based approach

Table 15: Comparison of security approaches

Criterion	Compliance/restriction approach	Risk-based approach
Driver	Regulatory checklists	Threat and asset assessment
Key question	"Are we meeting the controls?"	"What are our critical assets and likely threats?"
Drawback	"Checkbox" mentality, uniform	Requires risk analysis skills
Benefit for univ.	Low	**High** — enables differentiation by zone
Associated frameworks	Internal control lists	NIST CSF, ISO 27001, FAIR risk quantification [138↗]

Proposition: the optimal approach combines both — regulatory compliance (GDPR, sector-specific regulations) as a *floor*, and risk assessment to prioritise investments *above* that floor according to institutional risk appetite.

11 Artificial intelligence and access to cloud services

> "We can only see a short distance ahead, but we can see plenty there that needs to be done."
>
> — Alan Turing, *Computing Machinery and Intelligence* [139↗]

11.1 AI as a structural need for research and teaching

In 2025-2026, generative artificial intelligence and foundation models have become everyday tools for:

- **Research**: training and fine-tuning models, accessing provider APIs (OpenAI GPT, Anthropic Claude, Google Gemini, Meta LLaMA, Mistral), using cloud platforms (AWS SageMaker, Google Vertex AI, Azure ML, HuggingFace Hub);
- **Teaching**: machine learning and NLP courses requiring API access, practicals on foundation models, comparative evaluation of AI systems;
- **Cybersecurity research**: AI-based threat analysis, anomaly detection, adversarial testing.

11.2 The GDPR challenge and non-EU cloud services

Use of major cloud-based AI services (OpenAI, Anthropic, Google Cloud AI) may involve international transfers of personal data and therefore requires case-by-case assessment of data flows, transfer safeguards, and technical and organisational measures appropriate to the risk. For research, this creates a **structural tension** between:

- The obligation to protect personal data (GDPR);
- The need for free access to the best global AI platforms to remain scientifically competitive.

11.3 Architectural solution: differentiated AI access zones

Table 16: AI access policy by network zone

Zone	Authorized AI access	Legal framework
Administrative	Validated institutional AI only (e.g.: Copilot with university tenant)	Strict GDPR, no personal data to non-EU services
Teaching	AI APIs for courses (with anonymized or synthetic data)	Instructor agreement, no real student data
Research	**Free access** to major cloud-based AI services	Researcher-centred accountability per Section 11.4; cumulative *Schrems II* regime applies to personal-data transfers [7↗]
BYOD	Via the zone corresponding to the authenticated profile	According to the destination zone

11.4 Safeguards for research AI access

Academic-community-centred design within the regulatory framework. The researcher-centred accountability model presented below operationalises GDPR Articles 24(1) and 5(2) and the AI Act's research-support principle (Recital 25) [42↗]. Six items detail the framework:

1. **Researcher accountability principle.** The Principal Investigator (PI) is responsible for the compliance of their project with applicable GDPR, *Schrems II* [7↗] and AI Act [42↗] provisions. The institution provides classification templates, registration facilities and training; the PI applies scientific and legal judgment case by case.

2. **Data classification.** Before any transfer to a non-EU AI cloud provider, the PI classifies the data:
   - *Non-personal or fully anonymised data*: free transfer (GDPR not applicable);
   - *Pseudonymised personal data*: transfer permitted under Standard Contractual Clauses (SCC) + supplementary measures (encryption with key separation, reinforced contractual clauses);
   - *Identifying personal data*: transfer requires explicit informed consent (or another Art. 6 lawful basis) + SCC + supplementary measures + documented TIA, or the data must remain within the EEA.
3. **Cooperative declaration via institutional register.** On first use of a non-EU AI cloud provider for personal data, the central IT service registers the access on PI request, recording: provider, data classification (provided by the PI), lawful basis (declared by the PI), and safeguards in place. The register is maintained as a standing institutional artefact available for periodic DPO audit. The model is **declarative and cooperative**, not gatekeeping: the PI requests access, the IT service registers, the DPO audits.
4. **EU-first routing preference.** European providers (e.g. Mistral, OVH, Scaleway) are preferred where functionality is equivalent. International collaboration with non-EU providers is permitted as an *academic right* under the declarative model above.
5. **Environment separation, traceability, training.** Research AI notebooks and environments operate within the research zone, isolated from the administrative zone; external API access is logged for audit; PIs receive training on GDPR, *Schrems II* [7↗], the AI Act [42↗], and the data-classification framework.
6. **AI Act application.** The risk-based classification of the AI Act [42↗] applies; many research uses fall outside high-risk categories. Bespoke research tools developed for scientific R&D are exempt under Article 2(6); research, testing and development before market placement is exempt under Article 2(8). The report endorses Recital 25 calling for research support and the avoidance of undue restriction.

Advocacy positioning. The cooperative declaration model proposed in item 3 operationalises the GDPR accountability principle in a research context where strict per-access gatekeeping would unduly restrict international scientific collaboration. This report indicates that the institution could share its register template and audit methodology with the national supervisory authority, the competent data-protection authority and EDPB working groups, as a contribution to research-context regulatory practice (see Section 4.7, Position D.5).

12 Proposed infrastructure and organisational solutions

> "In anything at all, perfection is finally attained not when there is no longer anything to add, but when there is no longer anything to take away."
>
> — Antoine de Saint-Exupéry, *Terre des Hommes*, 1939 [140↗]

Building on the state of the art and the previous examples, this section proposes a target architecture for a university wishing to reconcile security and academic freedom.

12.1 Conceptual architecture: five structural layers

Before detailing the operational zones, it is useful to present the **conceptual model** that underpins them. Following established resilience-engineering principles [34↗, 36↗], a university information system can be decomposed into five structural layers, each with distinct dependability requirements:

1. **Infrastructure core (dependability foundation).** The set of services on which *all other layers depend*: identity and access management (IAM), DNS, DHCP, Public Key Infrastructure (PKI), NTP, **immutable backup systems** (air-gapped or append-only repositories — the primary defence against ransomware), central storage, hypervisors, orchestration platforms, **Security Information and Event Management (SIEM)** for centralised security event aggregation and alerting (e.g. Wazuh, OpenSearch), network access control (Network Access Control (NAC)), campus backbone, Wi-Fi controllers, VPN concentrators, and administration bastions. This core constitutes the *dependability foundation* of the entire system: it must be strongly segmented, hardened, redundant, supervised, and isolated from experimental networks. Its compromise would affect every other layer; its resilience guarantees the survival of the institution [36↗, 133↗].

2. **Common services.** Shared platforms consumed by the entire university community: messaging, Learning Management System (LMS), user storage, collaborative tools, videoconferencing, printing, intranet portals, HPC scheduling interfaces. These services must be highly available, redundant, backed up, and organised in Trusted Activity Contexts aligned with data sensitivity — but they do not require the same isolation as the infrastructure core.

3. **Autonomous zones.** Perimeters managed locally by research laboratories, departments, experimental platforms, scientific clusters, fablabs, or temporary project infrastructures. Each zone enjoys *administrative autonomy* within a dedicated network segment, under a responsibility charter (ETH Zurich model [21↗]). The guiding principle is: *local autonomy, bounded global impact.*

4. **Exposed zones.** Public-facing services (web servers, open platforms, external collaborative portals, APIs, partner gateways) that must be *isolated from the internal SI* by DMZ-type architectures [15↗].

5. **User networks.** End-user connectivity: staff wired, student wired, eduroam Wi-Fi, guest Wi-Fi, BYOD, administrative workstations, computer labs. Open by nature, but segmented from critical zones.

The seven operational security zones detailed below map onto these five conceptual layers. The administrative zone and sensitive-data enclave sit within the infrastructure core and common-services layers; the research and teaching zones are autonomous zones; the Science DMZ and BYOD zone span the exposed and user-network layers respectively.

12.2 Trusted Activity Contexts

The transverse role of Trusted Activity Contexts

The five layers of Section 12.1 are *spatial*: they describe *where* components live and *how strongly* they are isolated from one another. The **Trusted Activity Context** (TAC) introduced in Section 3.6 is by contrast *transverse*: it describes *what coherent, validated environment* an activity operates in, regardless of which layer hosts that activity. A research project, a teaching session, or an administrative process can each be a TAC that consumes resources from several layers — identity and PKI from the infrastructure core, collaborative tools from the common services, autonomous compute from a research zone — with policy gating at every step and audit correlating the whole. The operational realisation of TACs — end-to-end activation sequence, policy contract, endpoint posture, conformance suite — is developed in the companion Technical Reference [6].

12.3 Segmented network architecture with BYOD zone and AI access

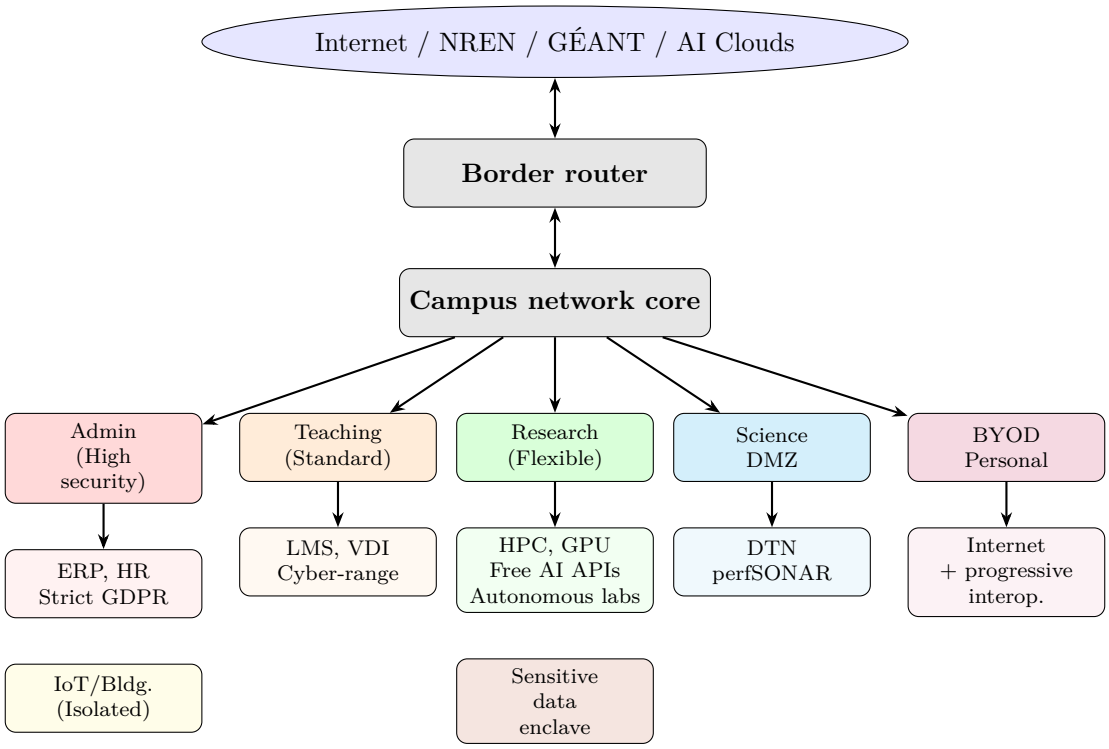


Figure 2: Segmented network architecture with BYOD zone and AI access. The Science DMZ realises the generic high-throughput research-data path; an NREN-operated dedicated circuit or GEANT lightpath is an equivalent realisation.

12.4 Seven security zones

1. **Administrative zone (high security):**
   - ERP, HR, finance, student information systems;
   - Stateful firewall, IDS/IPS, mandatory proxy (note: HTTPS inspection on the mandatory proxy must comply with the *Bărbulescu* [141↗] proportionality criteria regarding staff personal communications);
   - Strict GDPR compliance, database activity monitoring, encrypted storage at rest;
   - Restricted access, mandatory MFA;
   - *This is the zone that must be the most locked down — not the entire university.*

2. **Teaching zone (standard security):**
   - LMS (*Learning Management System*), classrooms, teaching laboratories;
   - VDI (*Virtual Desktop Infrastructure*) for specialised courses — technologies: VMware Horizon, Citrix, or Apache Guacamole as HTML5 access gateway over Proxmox VE (lightweight open-source alternative to commercial VDI);
   - Containerization (Docker, Kubernetes) for practical environments: JupyterHub on Kubernetes [24↗] allows providing each student with an isolated environment for data science, statistics, and computational courses across all faculties;
   - Cyber-ranges for security and networking courses, as recommended by NIST [25↗];
   - Access to AI APIs with anonymized data — available to all disciplines (AI-assisted legal research, computational linguistics, data analysis in social sciences, etc.);
   - Standard security controls, eduroam Wi-Fi;
   - Instructors across all faculties must be able to freely configure teaching environments.
3. **Research zone (flexible, high throughput):**
   - HPC clusters (Slurm job scheduler, parallel filesystem such as Lustre or BeeGFS, high-speed interconnect), GPU servers, laboratory infrastructure;
   - **Administrative autonomy** for laboratories and departments: each unit manages its own servers, software and configurations within its dedicated VLAN (central network operations retain control of VLAN boundaries and inter-VLAN routing);
   - Apptainer (formerly Singularity) [142↗] for HPC containers without root privileges;
   - **Free access to major cloud-based AI services** (see Section 11);
   - Monitoring-based security (Zeek + Suricata) rather than restriction-based, with log export to the central SIEM;
   - Direct NREN access for massive data transfers.
4. **High-throughput research-data path — Science DMZ instantiation (high-performance transfers):**
   - DTN with Globus for inter-institutional transfers, requiring Linux kernel TCP tuning (buffer sizes, IRQ affinity, jumbo frames) to achieve line-rate on 100 Gbps links;
   - ACL-based security (no stateful firewall, incompatible with 10–100 Gbps flows) on dedicated switching infrastructure;
   - perfSONAR for performance monitoring (nodes placed both inside and outside the Science DMZ to identify boundary bottlenecks);
   - Zeek + Suricata for dedicated surveillance (protocol analysis and signature-based detection in parallel).
     The Science DMZ is one instantiation of this role; where a campus enclave is not warranted, an NREN-operated dedicated circuit or GEANT lightpath realises the same high-throughput research-data path.
5. **Personal BYOD Zone:**
   - Full Internet access;
   - Progressive interoperability with other zones depending on the authenticated profile (see Section 5), implemented via FreeRADIUS and 802.1X dynamic VLAN assignment;
   - MFA + posture verification for extended access: for unmanaged devices, posture is established through device certificates or MDM enrolment; agentless checks (OS fingerprinting via DHCP, browser-based detection) provide a baseline but cannot verify patch level or antivirus status;
   - Network access control (PacketFence or equivalent) manages device onboarding, VLAN placement, and policy enforcement.
6. **IoT/Building Zone (isolated):**
   - HVAC, lighting, physical access control;

- Strictly isolated from the campus IP network (dedicated VLAN with no default gateway, or physically separate switching for access-control systems);
- Local NTP and firmware-update server within the zone (devices cannot reach the Internet but must still be patched and time-synchronised);
- Single-point gateway (application-layer proxy) for facilities-management access to building controllers.

7. **Sensitive data enclave:**
   - For projects requiring enhanced compliance (medical data, classified projects, etc.);
   - Micro-segmentation, enhanced logging, strictly controlled access;
   - Compliant with NIST SP 800-171 if necessary;
   - *Enclave within the open architecture* — the model proven by universities receiving DoD funding and by Harvard's Medical Science DMZ.

NIS2 holistic scope and Article 21 proportionality

All seven zones described above operate *within* the NIS2 perimeter applicable to the institution as an essential entity (Section 4.2). The variation in control profiles between zones is the direct expression of NIS2 Article 21(1), which requires measures *appropriate and proportionate* to each entity's exposure to risk. National transpositions typically make this proportionality principle binding and extend the calibration criteria to include the state of the art, applicable European and international standards, cost of implementation, entity size, and the likelihood and severity of incidents. The seven-zone segmentation is the operational mechanism through which the institution implements its NIS2 obligations across a heterogeneous public-research perimeter.

Segmentation does not narrow the regulatory scope; it calibrates the implementation. Every zone is subject to risk management, incident reporting, supply-chain controls and continuous evidence production — the calibration is in the intensity of controls, not in the inclusion within scope.

12.5 Federated IT Governance

Continuous-improvement mechanism. The Digital Policy Commission (Section 12.5.3), the collegial academic councils, the responsibility charters and the ICRADP (Section 16) collectively constitute the institution's **continuous-improvement mechanism**. The institutional artefact through which this mechanism becomes opposable is the annual compliance and maturity report submitted to the national supervisory authority pursuant to the national NIS2 transposition, which closes each annual governance cycle.

12.5.1 Proposed Structure

Table 17: Distribution of responsibilities in a federated model

Domain	Central IT	Research units / Departments / Laboratories
Backbone network	Operates and maintains	Uses
Identity (IAM)	Provides the infrastructure	Manages local accounts
Baseline security	Defines minimum standards, operates the SOC	Implements within its perimeter
Research servers	Provides optional hosting	**Freely administers** within its VLAN
Research software	—	**Freely installs**
ERP / HR / Finance	Operates and secures	—
HPC	Provides the central cluster	Can supplement with own hardware
Research cloud	Provides IaaS (OpenStack)	Provisions its own VMs
BYOD zone	Provides the network infrastructure	Uses
AI cloud	Maintains the institutional register (per PI request) and operates the periodic DPO audit	PI classifies data, requests access, uses the services under the cooperative declaration model (Section 11.4)
GDPR compliance	Coordinates, DPO	Responsible for its data

12.5.2 Executive training and management responsibility

The national NIS2 transposition imposes specific obligations on the management bodies of essential entities, distinct from researcher-level training and from the institutional security architecture:

- **Executive training** (NIS2 Art. 20(2) [12↗]): the institution's central executive leadership and the members of the institution's governing board must receive cybersecurity training enabling informed governance decisions on the matters covered by the NIS2 obligation framework. The training is a governance enablement obligation, not an operational compliance burden.
- **Personal liability of management bodies** (NIS2 Art. 20 [12↗]): under the national transposition, members of the management body can be held personally accountable for failures to discharge the cybersecurity-risk management obligations.

The Digital Policy Commission proposed in Section 12.5.3 is the natural delivery mechanism for the executive-training programme: its mixed academic-technical composition allows the training to be structured as a series of governance briefings tailored to the institution's specific public-research perimeter, rather than a generic compliance course. The training programme is documented in the maturity report submitted to the national supervisory authority, providing auditable evidence of compliance with NIS2 Art. 20(2).

Distinction. The training of researchers on GDPR, *Schrems II* and the AI Act (Section 11.4, item 5) is a separate and parallel programme; the present sub-subsection covers governance-body training only.

12.5.3 Digital Policy Commission

The governance of digital infrastructure and AI policy should be entrusted to a **Digital Policy Commission** whose key characteristics are:

- **Chair:** an elected academic — not a member of the IT operational hierarchy;
- **Composition:** a compact body of representatives from the departments and interdisciplinary centres across the university's faculties, ensuring that research, teaching, and

interdisciplinary perspectives are all represented;
- **Advisory members (non-voting):** the CIO, the CISO, the DPO, and a student representative;
- **Decision path:** the Commission formulates policy proposals that are submitted to the institution's collegial academic councils for endorsement before implementation.

This Commission holds *decision-making authority* over digital and AI policy proposals that affect academic missions. The CIO/CISO submit proposals and provide technical expertise; the Commission *decides* whether those measures are proportionate and compatible with academic needs.

This model rests on the principle of **university democracy**: the UNESCO *Recommendation concerning the Status of Higher-Education Teaching Personnel* (1997) [143↗] explicitly affirms the right of academic staff to *"elect a majority of representatives to academic bodies within the higher education institution."* The AAUP *Statement on Government of Colleges and Universities* (1966) [144↗] establishes that in matters affecting teaching and research, the faculty should exercise *"primary responsibility,"* with governing board review only *"in exceptional circumstances."* If elected academic bodies have decision-making authority over curricula, research priorities, and hiring, it is coherent that they also govern the digital infrastructure that conditions all of these activities.

In practice, governance models vary: Oxford's Information and Digital Committee [18↗] reports to Council with genuine decision-making authority over digital strategy; Michigan's IT Council [98↗] and Harvard FAS's IT Governance Committee [145↗] operate in a consultative capacity. The University of Kentucky's Senate has created an AI governance committee with policy-making authority derived from the elected Senate [146↗]. In California, elected faculty senates hold statutory *primacy* over technology-related academic matters [147↗]. This separation of strategic direction (governance) from operational execution (management) mirrors COBIT 2019's foundational distinction [136↗]. The Commission also defines the minimum standards that each zone must comply with.

Applied to a research-and-teaching university — typically organised into faculties, each with departments of teaching and research, and interdisciplinary centres with strong industrial and institutional partnerships — the proposed Commission would include representatives from these diverse entities. Its proposals would follow the institutional decision path: endorsement by the relevant collegial academic councils before operational implementation by the IT services.

12.5.4 Contextual role management and separation of privileges

In a university, a single individual routinely holds *multiple roles*: a doctoral student may also be a teaching assistant, a part-time system administrator for the laboratory, and a collaborator on an external project. The classical approach of assigning one account with the *union* of all privileges violates the **principle of least privilege** and makes audit trails opaque [38↗].

The foundational RBAC model [38↗] introduces the concept of **session-based role activation**: a user does not permanently carry all assigned roles but *activates a subset per session*, depending on the task at hand. Applied to a university context, this means:
- A researcher accessing the HPC cluster activates her *researcher* role with access to the research zone and AI cloud APIs;
- The same person, when entering grades, activates her *instructor* role with access to the LMS in the teaching zone;
- When performing system administration on her laboratory's servers, she activates her *local administrator* role, scoped to her unit's VLAN;
- At no point does she hold simultaneous access to administrative ERP data, which requires a separate role governed by a distinct Trusted Activity Context.

This approach yields several benefits aligned with the proposed architecture:
- **Least privilege:** each session carries only the permissions necessary for the current task;

- **Traceability:** audit logs record *which role* was active during each action, not merely which person;
- **Separation of duties:** conflicting roles (e.g. "data subject" and "data processor") can be declared mutually exclusive within a single session [38↗];
- **TAC alignment:** role activation maps naturally onto the Trusted Activity Context structure — each role grants access to a specific context within the zone architecture.

Examples of commonly deployed IAM platforms that support the access-control dimension of this model include: Keycloak (session-scoped role activation via OIDC/SAML), and Microsoft Entra ID (Privileged Identity Management for just-in-time role elevation). Shibboleth serves as the SAML federation bridge to eduGAIN interfederation service (eduGAIN) [67↗] and releases attributes per service provider, but does not itself manage session-scoped role selection. The full TAC vision — composing VLAN assignment, storage, applications, and access rights from a single role activation event — requires an orchestration layer (portal or Application Programming Interface (API) gateway) that coordinates these platforms; no single turnkey product achieves this today, but the individual building blocks are mature and deployable. The federated identity layer (eduGAIN for SAML-based Single Sign-On (SSO), eduroam for network authentication) provides the inter-institutional foundation. For modern applications and cloud APIs, OIDC/OAuth2 (natively supported by Keycloak) complements the SAML layer.

Note on Active Directory environments: where Windows AD is used, group membership is static per session. Implementing contextual role activation in AD-joined environments requires either Microsoft Entra ID Privileged Identity Management for role elevation, or dedicated access-brokering solutions. The TAC model applies most naturally to web-based and Linux-based research environments, and can be progressively extended to AD-managed workstations as the identity infrastructure matures. A more detailed (and deliberately tentative) endpoint integration matrix across Linux, macOS, and Windows is sketched in Chapter 2 of the standalone Technical Reference [6]; the broader endpoint contract and the iOS/Android coverage gap are addressed in Chapter 11.

12.5.5 Decision flow for autonomy requests

A predictable process replaces informal exceptions:

1. **Qualification:** does the request concern administration, teaching, research, or BYOD?
2. **Risk assessment:** sensitive data? External exposure required? Cloud access outside the EU?
3. **Zone assignment:** the request is directed to the appropriate zone with its native controls.
4. **Charter:** if local autonomy is necessary (root admin, servers, AI APIs), a charter formalizes the responsibilities, incident contacts, and the monitoring baseline.
5. **Validation:** the Digital Policy Commission validates cases involving external exposure or sensitive data, with endorsement by the relevant collegial academic council for institution-wide implications.

12.6 Cloud and Virtualization for Research

OpenStack private cloud: allows researchers to provision virtual machines on demand, with isolation per tenant. Examples: Jetstream2 (NSF, Indiana University), Nectar (Australia), EGI Federated Cloud (Europe), SWITCHengines (Switzerland).

Note: the recommendation is primarily to *consume* existing research cloud infrastructure provided by NRENs (SWITCHengines, EGI Federated Cloud, GEANT services) or to deploy lighter-weight alternatives (OpenNebula, CloudStack) for local needs. Operating a full OpenStack deployment requires significant dedicated operations capacity and is best suited to consortium-level or NREN-hosted deployments rather than individual university installations.

Kubernetes: container orchestration for:

- JupyterHub: interactive computing environments for students and researchers;
- Kubeflow: ML/AI pipelines;
- BinderHub: reproducible environments from Git repositories.

VDI for teaching: Apache Guacamole (open-source, clientless HTML5 access), VMware Horizon, or Citrix to provide standardised desktops accessible from any student device (BYOD).

12.7 Shared Security Organizations

Rather than managing everything alone, a university can rely on:

- **REN-ISAC** (US / North America) [134↗]: threat intelligence sharing, DNS RPZ feeds, incident notifications (700+ member institutions);
- **Trusted CI** [148↗]: center of excellence in cybersecurity for research (funded by the NSF);
- **GEANT Security**: security services for European institutions;
- **the national / governmental CSIRT**: the public-sector incident-response team; the institution's primary first-line CSIRT as a public institution;
- **the national NREN's CSIRT**: the CSIRT of the national NREN, commonly a *Trusted Introducer* member, complementary to the national/governmental CSIRT for incidents arising on or affecting the academic network perimeter;
- **a private-sector CSIRT**, where one exists, serving the private sector and non-governmental entities; relevant when third-party private partners of the institution are involved (not the institution's first-line CSIRT);
- **FIRST** [149↗]: global forum of incident response teams (CSIRT), including DFN-CERT, SWITCH-CERT and national NREN and governmental CSIRTs;
- **JRES** [150↗]: biennial French conferences on academic networks, a major source of experience feedback.

13 Justification and Feasibility

A university entering the third millennium will be, above all, a **digital university**. The quality, security, and flexibility of its digital infrastructure condition every academic activity: research, teaching, administration, and international collaboration. For an institution that sets excellence as a strategic objective, it is both coherent and necessary that this standard of excellence extend to the digital infrastructure that underpins all academic missions.

The investment required is not a cost to be minimised but a **strategic enabler**: just as a university invests in libraries, laboratories, and lecture halls, it must invest in a digital infrastructure worthy of its ambitions. The progressive approach proposed in this dossier (governance first, then pilot on selected entities, then gradual extension) is designed to be implementable within the institution's multi-year planning and funding cycle, spreading effort over several cycles and aligning each step with demonstrated results.

13.1 Cost analysis: centralised approach

- **Direct costs:** oversized centralised infrastructure having to handle all use cases, expensive application firewall licenses processing all traffic including research;
- **Indirect costs:**
  - Loss of researcher productivity (time spent circumventing restrictions or waiting for authorizations);
  - Inability to teach certain advanced courses;
  - Brain drain to more flexible universities;
  - Shadow IT creating unmanaged risks;
  - Loss of competitiveness for grant applications requiring high-performance research infrastructure.

13.2 Cost analysis: federated approach

- **Enhanced security:** Trusted Activity Contexts limit the propagation of incidents — a compromise in a research context cannot reach the administrative context;
- **Proportionate controls:** maximum investment where the risk is highest (sensitive administrative data), adapted investment elsewhere;
- **Research productivity:** researchers work without hindrance in their zone, while being protected;
- **Pedagogical excellence:** advanced courses have realistic environments;
- **Attractiveness:** the university attracts high-level researchers thanks to a modern and flexible infrastructure;
- **AI access:** research and teaching at world-class level;
- **Functional BYOD:** staff productivity with personal devices;
- **Facilitated compliance:** secure enclaves allow meeting the strictest requirements without penalizing the rest of the institution;
- **GDPR/NIS2 evidence:** each zone produces its own evidence of compliance and effectiveness.

13.3 Feasibility and cost structure of the proposed approach

The question of **cost and feasibility** is addressed explicitly, in line with GDPR Article 32, which requires that measures be *appropriate to the risk* taking into account *state of the art*, **costs** and context [11↗].

- **Proportionate investment:** by concentrating the strictest controls on the *administrative enclave* only, the university avoids over-investing in perimeter security for low-sensitivity research and teaching traffic; the "high security" perimeter becomes *smaller and cheaper to harden and monitor*.
- **Reuse of existing ecosystems:** many components are *low-cost or cost-free*: NREN/GEANT connectivity and security services, REN-ISAC and GEANT Security (threat intelligence, CSIRT), open-source tools (perfSONAR, Zeek, Apache Guacamole, JupyterHub, Globus). Science DMZ patterns are documented and adopted by 100+ universities [57↗, 58↗] without requiring proprietary enterprise licenses for research zones.
- **Progressive implementation:** starting with governance (Digital Policy Commission, charters, service catalogue), followed by a pilot deployment on the entities with the strongest domain expertise (a computer-science department, a cybersecurity-focused interdisciplinary research centre, and the institution's HPC team), then gradual extension to other faculties, departments and centres as results are validated (see Section 14).
- **Comparative cost factors:** indirect costs associated with centralised approaches (productivity loss, talent mobility, Shadow IT, competitiveness in calls for proposals) and incident-related costs (remediation, fines, reputation impact in case of a major breach) provide a benchmark against which the proposed investment can be assessed. The analysis of media-covered university incidents (Section 8) identifies the absence of internal boundaries as a recurring cause.

A detailed transition plan with phases, risk register and KPIs (Section 14) allows the institution to *control scope and budget* at each step and to prioritise quick wins (governance, charters, pilot) before broader rollout.

14 Transition Plan

An indicative scoping of a minimum-viable TAC pilot — with the caveat that timelines and resourcing remain to be confirmed by the IT department — is developed in the standalone Technical Reference [6], Chapter 23 ("Wave 5 — TAC pilot"). The full wave-based migration playbook spanning ten waves is developed in Part III of the same document.

14.1 Progressive Transition

Table 18: Progressive transition plan

Step	Actions
0. Initial declarations	Auto-registration with the national supervisory authority (national NIS2 transposition) Initial setup of the institutional account on the national notification platform (incident-notification + risk-analysis modules) Definition of the maturity-report template (an ISO/IEC 27005-aligned risk-analysis method, such as a nationally provided open-source tool) and identification of per-zone evidence sources
1. Governance	Establishment of the Digital Policy Commission (elected chair + faculty/centre representatives) Definition of target zones and charter templates Adoption of the differentiated responsibility charter (ETH Zurich model) Service catalogue and formalised exception path Executive-training programme for the top governing board (NIS2 Art. 20(2), see Section 12.5.2)
2. Pilot	Pilot deployment of the segmented architecture and Trusted Activity Contexts on the entities with the strongest domain expertise (a computer-science department, a cybersecurity-focused interdisciplinary research centre, and the institution's HPC team) Installation of DTN + perfSONAR + Zeek PoC micro-segmentation (SDN overlay) Pilot BYOD zone with progressive interoperability Before/after metrology for factual data
3. Progressive extension	Gradual rollout to other departments, faculties and interdisciplinary centres Establishment of local ISGs (IT correspondents trained by the IT services) Progressive Zero Trust deployment (MFA → posture → micro-segmentation) AI zone with worldwide cloud access for research Audit and continuous improvement cycle
4. Annual cycle	Annual maturity-report submission to the national supervisory authority via the national notification platform (per the national NIS2 transposition) Internal-audit cycle covering all enclaves, feeding the maturity report DPO audit cycle covering the cooperative declaration register for non-EU AI cloud access (Section 11.4) Executive-training refresh for the top governing board (NIS2 Art. 20(2), Section 12.5.2)

The governance step is predominantly organisational and can be carried out with existing staff. The pilot confines initial deployment to the entities with the strongest domain expertise — a computer-science department, a cybersecurity-focused research centre, and the institution's HPC team — whose expertise in computer science, cybersecurity, and high-performance infrastructure

makes them natural candidates for validating the architecture. Progressive extension then follows validated results, allowing the institution to control scope at each step.

14.2 Risk Register

Table 19: Transition programme risk register

Risk	Prob.	Impact	Mitigation
Central IT perceives enclaves as loss of control	High	High	Show the security gain on the admin enclave; charters and precedents (Oxford, ETH)
Departments treat autonomy as absence of responsibility	Medium	High	Charters with accountability, mandatory contacts, baseline monitoring, periodic reviews
Exceptions creating a "hidden flatness" of the network	Medium	High	Default-deny at internal boundaries; documented exceptions with expiration; ETH isolation zones
Teaching labs (offensive security courses) impacting production	Low	High	Isolated cyber-ranges; rapid reset; strict egress policies
Insufficient GDPR compliance for AI access outside the EU	Medium	High	Researcher-centred accountability per Section 11.4: PI data classification + IT-service register + cumulative *Schrems II* regime for personal-data transfers + EU-first preference + periodic DPO audit [7↗]

14.3 Monitoring KPIs

Table 20: Key performance indicators

KPI	Measure
Reduction of admin enclave exposure	Services reachable from non-admin zones
Teaching lab rebuild time	Reimage/reset cycle; incidents resolved by reset
Research enclave onboarding rate	Chartered enclaves; request→approval delay
Lateral movement containment	Post-mortems: did the compromise cross zone boundaries?
DTN throughput and diagnostic time	Transfer performance, perfSONAR deviations
Art. 32 evidence production	Planned and completed control tests, audits, exercises

15 Propositions

Implementation strategy and cost control. The propositions below are ordered so that *governance and quick wins* come first (risk-based approach, federated committee, charters): these require little or no additional infrastructure and deliver immediate clarity of responsibilities. *Pilot deployment* (one department, one zone) then validates the model at contained cost before any institution-wide rollout. The heavy use of shared services (NREN, GEANT, REN-ISAC, open-source tooling) and the absence of a single "critical path" vendor reduce both implementation risk and total cost of ownership. The cost-benefit and feasibility discussion in Section 13 and the phased transition in Section 14 should be read as an integral part of these propositions.

1. **Adopt a risk-based approach** (NIST CSF 2.0, GDPR Art. 32) rather than an approach mainly driven by uniform restrictions. Each zone receives controls proportionate to its risk level.
2. **Segment the network into 7 zones**: administrative (high security), teaching, research (flexible), Science DMZ, personal BYOD, IoT, sensitive data enclave. These zones constitute the operational architecture through which the institution implements the proportionate measures required by the national NIS2 transposition; per-zone compliance evidence aggregates into the institutional annual maturity report submitted to the national supervisory authority.
3. **Create a personal BYOD zone** with Internet access and progressive interoperability with other zones depending on authentication.
4. **Guarantee access to AI cloud services** from the research zone under a *researcher-centred accountability model*. The Principal Investigator classifies data and selects providers proportionately; personal-data transfers outside the EEA follow the cumulative *Schrems II* regime (SCC + supplementary measures) [7↗]. International collaboration with non-EU providers is permitted on a *cooperative declaration* basis: the central IT service registers the access on PI request, the register is available for periodic DPO audit; EU-first is a routing preference, not a restriction (operational detail in Section 11.4; advocacy positioning in Section 4.7, Position D.5).
5. **Establish a Digital Policy Commission** chaired by an elected academic, with representatives from departments and interdisciplinary centres, responsibility charters, and a service catalogue.
6. **Adopt open-source and open-science tools as default institutional choices**, reducing vendor lock-in, increasing auditability and transparency, and aligning with the European Commission's open-source strategy for public administrations.
7. **Formalize autonomy** through enclave charters (ETH Zurich / Oxford model) and Data Stewards in laboratories (EPFL model).
8. **Grant administrative autonomy to research-only units, research-and-teaching departments, and their laboratories** within their dedicated VLANs, with minimum security standards defined centrally but freedom of local implementation. Administrative autonomy is exercised within the institutional minimum standards required by the national NIS2 transposition (mirroring NIS2 Article 21(2)) and opposable to all zones; enclave charters formalise these standards and their verification by internal audit feeds the maturity report submitted to the national supervisory authority. **Autonomy is contextual, not exempt.**
9. **Deploy a Science DMZ** for high-performance research data transfers, following the ESnet pattern adopted at over 100 university campuses with NSF *Campus Cyberinfrastructure* (CC*) funding [57↗, 58↗].

10. **Implement federated identity** via eduroam and the national NREN-operated identity federation (linked to eduGAIN), enabling inter-institutional SSO and researcher mobility.

11. **Offer secure alternatives** rather than banning: OpenStack private cloud, VDI for teaching, Kubernetes for research environments, rather than blocking cloud access or software installation.

12. **Participate in security communities** (FIRST globally, GEANT Security in Europe, and the equivalent regional body — e.g. REN-ISAC in the US, JRES in France) to share threat intelligence and best practices.

13. **Implement Zero Trust progressively**: start with identity (universal MFA), then device posture, then micro-segmentation, adapting requirements to the academic context.

14. **Demonstrate NIS2 essential-entity compliance** by adopting an architecture producing per-zone evidence of risk management, incident containment and Article 21 proportionate measures, supporting the institution's annual compliance and maturity report to the national supervisory authority. Per-zone evidence consolidates into an institution-level maturity dashboard, based on an ISO/IEC 27005-aligned risk-analysis method (such as a nationally provided open-source tool), producing the single annual score submitted to the supervisory authority pursuant to the national NIS2 transposition.

15. **Draw inspiration from reference universities**: Oxford, ETH Zurich, Michigan, Rutgers, Cambridge, MIT, Stanford, CERN, Penn State, NC State, and Wisconsin-Madison demonstrate that security and academic freedom are compatible.

The propositions above, taken together, constitute a **continuous-improvement mechanism**: each proposition contributes to the per-zone evidence base and to the federated governance dispositive whose institutional artefact is the annual compliance and maturity report to the national supervisory authority pursuant to the national NIS2 transposition. The continuous-improvement framing is aligned with cybersecurity governance best practice (NIST CSF 2.0 GV function [133↗], ISO/IEC 27001:2022 clause 10) and with the maturity-cycle expectations of NIS2 essential entities.

16 Independent Commission for Reasonable Adjustments to Digital Policies

> "Where, after all, do universal human rights begin? In small places, close to home [...] Unless these rights have meaning there, they have little meaning anywhere."
>
> — Eleanor Roosevelt, *In Your Hands*, 1958 [151↗]

Independent of the IT security policy adopted by the institution, a mechanism allowing any employee to obtain **reasonable adjustments** for personal, medical or professional reasons is a structural requirement. This mechanism is to be guaranteed by an **independent commission** operating outside the operational chain of command of the IT services.

16.1 Legal and Normative Foundations

16.1.1 European Equal Treatment and Disability Law

The concept of *reasonable adjustment* (*reasonable accommodation*) is a pillar of European anti-discrimination law:

- **Directive 2000/78/EC** [152↗] establishing a general framework for equal treatment in matters of employment and occupation requires employers to take *"appropriate measures"* to enable a person with a disability to access, exercise, and advance in employment (Article 5). The CJEU has interpreted 'disability' to include some long-term limitations, including certain chronic or long-lasting illnesses, but not sickness as such and not purely temporary conditions [153↗, 154↗].
- The **United Nations Convention on the Rights of Persons with Disabilities** (CRPD) [155↗], ratified by the EU and its member states (and, more broadly, by the relevant jurisdiction), defines "discrimination on the basis of disability" to include the *denial* of reasonable accommodation (Article 2, Definitions) and establishes the substantive duty of equality and non-discrimination, including reasonable accommodation, in Article 5.
- **the national transposition of Directive 2000/78/EC into labour law** integrates the obligation of reasonable adjustments into national law.

16.1.2 Extension Beyond Disability: the Concept of Reasonable Adjustment of Digital Policies

Note: the extension of the reasonable adjustment concept beyond disability is proposed here as *institutional governance best practice* inspired by the legal model, not as a legal obligation under Directive 2000/78/EC or the CRPD — which specifically concern disability. The governance rationale is that frameworks such as COBIT 2019 (EDM05), NIST CSF 2.0 (GV function) and ISO 27001 (Clause 4.2) all require integrating stakeholder needs into IT governance, providing an independent institutional basis for this mechanism.

While the original legal framework primarily concerns disability, **good management practice** and **IT governance frameworks** recognise that uniform digital policies can create disproportionate obstacles for various reasons:

Medical reasons: an employee suffering from musculoskeletal or visual disorders may need specific equipment or software not included in the standard catalogue; a researcher undergoing treatment requiring adapted telework may need a particular VPN access.

Personal reasons: a single parent providing support for a child with a disability may need remote access flexibility incompatible with a restrictive BYOD policy; an employee acting as a family caregiver may need specific communication tools.

Professional reasons: a cybersecurity researcher needs access to malware analysis environments; an artificial intelligence instructor must access non-European cloud APIs; a data science researcher requires local administrative privileges (root/admin access) on their workstation.

The **NIST Cybersecurity Framework 2.0** [133↗], in its *Govern* (GV) function, insists on integrating *"stakeholder needs"* into the cybersecurity strategy. The **COBIT 2019** [136↗] framework emphasizes that IT governance must serve *"stakeholder needs"* and not constrain them without justification. **ISO 27001:2022** [16↗], in its Clause 4.2, explicitly requires understanding the *"needs and expectations of interested parties"* as a prerequisite for the ISMS.

16.1.3 Infringement of Fundamental Freedoms and Digital Conscientious Objection

Beyond medical, personal, and professional reasons, a fourth category of grounds for adjustment must be recognised: the situation of an employee whose **fundamental freedoms** are infringed disproportionately by a digital policy, or who feels, in conscience, that this policy constitutes a violation of rights they consider inalienable. This ground, which we call **digital conscientious objection**, is based on a converging body of European and international fundamental rights. No court has yet applied Article 9 to digital workplace policies; however, the *Bayatyan* criteria — a serious and insurmountable conflict between an obligation and a sincerely held conviction — provide an arguable framework, particularly where restrictions compel actions that conflict with deeply held professional or ethical convictions.

The fundamental freedoms at stake. Restrictive university digital policies simultaneously engage several fundamental rights. In EU-bound jurisdictions these are grounded in the **Charter of Fundamental Rights of the EU** [156↗] and the **European Convention on Human Rights** [157↗]; in other jurisdictions the adopter's equivalent constitutional or human-rights instruments apply, with the international consensus (below) as the jurisdiction-neutral anchor:

Academic freedom (EU Charter, Art. 13): *"The arts and scientific research shall be free of constraint. Academic freedom shall be respected."* This right is self-standing within the Charter. The ECtHR linked it to Article 10 in the judgment *Sorguç v. Turkey* [158↗], which recognises the freedom of academics to *"freely express their opinion about the institution or system in which they work and to distribute knowledge and truth without restriction"*. The judgment *Mustafa Erdoğan v. Turkey* [159↗], in which a concurring opinion (Judges Sajó, Vučinić and Kuriš) proposes that *"academic discourse should enjoy the highest level of protection"*.

Freedom of expression and information (EU Charter, Art. 11; ECHR, Art. 10): includes *"the freedom to receive or impart information or ideas without interference by public authorities and regardless of frontiers"*. The ECtHR characterised the Internet as *"one of the principal means by which individuals exercise their right to freedom to receive and impart information"* (*Yildirim v. Turkey* [160↗]). Systematic filtering and blocking were held incompatible with Article 11 of the Charter by the CJEU in *Scarlet Extended v. SABAM* [161↗].

Freedom of thought and conscience (EU Charter, Art. 10; ECHR, Art. 9): the Grand Chamber of the ECtHR recognised in the judgment *Bayatyan v. Armenia* [162↗] that conscientious objection is an autonomous right protected by Article 9. While the case concerned military service, the *Bayatyan* criteria — a serious and insurmountable conflict between an obligation and a sincerely held conviction — may provide an arguable

framework for other contexts. The judgment *Eweida v. United Kingdom* [163] extended the protection of Article 9 in the professional context.

Respect for private life and communications (EU Charter, Art. 7 and 8; ECHR, Art. 8): the Grand Chamber judgment *Bărbulescu v. Romania* [141] established a **six-criteria proportionality test** for digital surveillance in the workplace and laid down the principle that *"restrictions cannot reduce to zero private social life in the workplace"*.

Dignity at work (EU Charter, Art. 1 and 31): Article 31 guarantees every worker *"working conditions which respect their health, safety, and **dignity**"*. Dignity is explicitly listed as a component of fair working conditions.

The international consensus on digital rights.

- Resolution A/HRC/RES/20/8 of the **UN Human Rights Council** [164] (2012) affirms for the first time that *"the same rights that people have offline must also be protected online"*.
- Resolution A/HRC/RES/32/13 [165] (2016) **condemns** measures aimed at intentionally preventing or disrupting access to information online.
- Resolution A/HRC/RES/47/16 [166] (2021), adopted by 43 votes to 0, condemns Internet shutdowns and online censorship.
- The **UNESCO Recommendation on Science and Scientific Researchers** [167] (2017, 195 countries) affirms that researchers must *"work in a spirit of intellectual freedom"* and have *"free access to libraries and other sources of information"*.
- The **Magna Charta Universitatum** [2] (Bologna, 1988, over 1 000 signatories from 94 countries, revised in 2020) states that *"research and teaching must be intellectually and morally independent of all political authority and economic power"*.

The proportionality requirement. Article 52(1) of the EU Charter requires that **any limitation** of a fundamental right:

1. be *provided for by law*;
2. *respect the essential content* of the right;
3. be *proportionate*, necessary, and *genuinely* meet an objective of general interest.

The CJEU has invalidated disproportionate digital restrictions in three major judgments: *Digital Rights Ireland* [168] (invalidation of the data retention directive), *Schrems I* [169] and *Schrems II* [7] (invalidation of EU-US transfer agreements for disproportionate surveillance). These judgments establish that an **indiscriminate and disproportionate digital restriction is illegal** under EU law, even when it pursues a legitimate security objective.

Technostress and moral injury as documented harms. The scientific literature documents two forms of harm caused by restrictive digital policies:

- **Technostress** [170, 171, 172, 173, 174] is an empirically established occupational risk (systematic review of 105 studies), characterised by anxiety, fatigue, and loss of effectiveness. The absence of autonomy in technology use is a positive predictor of technostress [173] — a finding that, while not directly studied in the specific context of restrictive IT policies, provides a plausible mechanism linking rigid digital environments to occupational stress. Technostress reduces job satisfaction and organisational commitment [175].

- **Moral injury** (*moral injury*), defined as the trauma resulting from *"acts that transgress deeply held moral beliefs and expectations"* [176], was systematically reviewed in the *British Journal of Psychiatry* [177], which called for extension of the concept to civilian occupational contexts. While no study has directly measured moral injury resulting from IT policies, the structural conditions identified in the occupational literature — compulsion

to act against professional values, perceived futility of action, and absence of institutional recourse — can be present when restrictive digital policies force academics to choose between professional obligations and policy compliance. A qualitative study documented the moral injury of university staff confronted with institutional policies experienced as a betrayal of their professional values during the COVID-19 crisis [178↗]. The concept of *"chronic moral injury"* [179↗] applies to situations where a professional aspiring to excellence must operate within an institution whose practices hinder the exercise of their competencies.

Note on proportionality: the severity of moral stakes in IT policy contexts is clearly lower than in military or pandemic contexts where the original concept was developed. The argument here is not one of equivalence but of *structural analogy*: the mechanism (institutional compulsion against professional values, absence of recourse) may operate in attenuated form when digital policies systematically prevent academics from fulfilling their professional obligations.

Summary: the eligibility of requests based on fundamental freedoms. The legal argument is structured as follows:

1. Restrictive university digital policies **engage** simultaneously academic freedom (Art. 13), freedom of expression and information (Art. 11), freedom of conscience (Art. 10), the right to private life and communications (Art. 7-8) and dignity at work (Art. 1, 31) of the EU Charter;
2. Any restriction of these rights must pass the **proportionality test** of Article 52(1), which implies a case-by-case assessment — not an automatic refusal;
3. **Indiscriminate and disproportionate** restrictions are illegal (*Digital Rights Ireland*, *Scarlet Extended*);
4. Disproportionate restrictions can cause **documented harm** (technostress, moral injury);
5. An employee who experiences that a digital policy *disproportionately infringes on their fundamental freedoms* — whether through deep conviction (conscientious objection, Art. 9/10), through infringement of their academic freedom (Art. 13), or through harm to their dignity and health (Art. 31) — has a **defensible legal basis** to request a reasonable adjustment;
6. For requests grounded in disability or other protected characteristics (Directive 2000/78/EC), the burden shifts to the institution to demonstrate that the refusal is proportionate. For other grounds (personal, professional), the requester must provide a documented justification, after which the institution must demonstrate that refusal is proportionate to an identified security risk — not merely administratively inconvenient.

Important: this ground does not open an unlimited right to bypass any security rule. It requires an *individualized proportionality assessment* by an independent body, in accordance with the consistent case law of the CJEU and the ECtHR. The adjustment granted may be an alternative technical solution (different network zone, dedicated enclave, specific VPN) that reconciles the individual's need with the legitimate security objectives.

16.2 Why an *independent* commission?

16.2.1 The problem of internal conflict of interest

When adjustment requests are handled by the IT department itself — the one that designs and enforces the policy — a **structural conflict of interest** arises:

- The IT department has an operational interest in minimizing exceptions, which increase its workload and support surface;

- The requester is in a position of technical subordination vis-à-vis the department that evaluates their request;
- The absence of external oversight favors arbitrary decisions or unmotivated refusals;
- The literature on organisational governance shows that self-assessment mechanisms without external oversight tend toward *"status quo bias"* [180↗].

As De Haes and Van Grembergen [181↗] emphasize, effective IT governance relies on *"structures, processes and relational mechanisms"* that separate strategic decision-making from operational execution. Entrusting the arbitration of adjustments to the department that enforces the policy violates this fundamental principle.

16.2.2 The university Ombudsman model

Many universities have an **Ombudsman** (*independent mediator*) tasked with handling conflicts between individuals and the institution in an impartial manner. The International Ombudsman Association (IOA) [182↗] defines four fundamental standards: **independence**, **neutrality**, **confidentiality** and **informality**. These principles apply directly to a digital policy adjustment commission.

16.3 The precedent of an existing reasonable-adjustments committee

Many institutions already operate a **reasonable-adjustments committee** (or equivalent) that supports students and staff with disabilities, learning difficulties, chronic illnesses, or other specific needs. Such a committee typically:

- Reviews adjustment requests and recommends practical adjustments in collaboration with the relevant institutional actors;
- Covers a wide range of measures: additional time for examinations, alternative submission formats, adaptation of teaching materials, individualised assessment modalities;
- Operates on the principle that the **general framework should adapt to the individual** when a legitimate need is documented.

If the institution already operates a mechanism for adjusting academic practices to individual needs — including the design and assessment of courses — it is coherent to extend an analogous principle to digital policies, which are a tool in service of the university's missions.

16.4 Proposal: Independent Commission for Reasonable Adjustments of Digital Policies (ICRADP)

16.4.1 Mission

The ICRADP's mission is to ensure that **every employee** — whether in a research-only unit, a research-and-teaching department, a teaching/training component, or an administrative service — can obtain a reasonable adjustment to any university digital policy when that policy creates a disproportionate obstacle to the exercise of their functions or infringes on their fundamental rights, for reasons of:

- **Medical**: disability, chronic illness, temporary health condition;
- **Personal**: family situation, caregiver obligations, documented individual circumstances;
- **Professional**: specific needs related to research, teaching, or the exercise of a particular function;
- **Infringement of fundamental freedoms**: disproportionate infringement of academic freedom, freedom of expression and information, freedom of conscience, dignity at work, or documented harm (technostress, moral injury) caused by the digital policy (see Section 16, §*Infringement of fundamental freedoms*).

16.4.2 Fundamental principles

1. **Independence:** the commission reports to the central executive leadership and not to the IT department or any operational service. Its members may not receive instructions from any department regarding the handling of requests.

2. **Pluralist composition:**
   - An independent chair (tenured teaching-researcher without a management function);
   - A representative of the teaching staff elected by peers;
   - A representative of administrative and technical staff;
   - The Data Protection Officer (DPO), as a legal expert;
   - An external expert in digital ergonomics or labour law (advisory member);
   - The CISO is *heard* but is **not** a voting member, to preserve independence.

3. **Universal right of referral:** any employee may refer a matter to the commission directly, without going through their hierarchy or the IT department.

4. **Processing deadline:** the commission rules within a maximum period of 15 working days. In case of a documented medical or professional emergency, a provisional adjustment may be granted within 48 hours.

5. **Reasoned decisions:** any refusal of adjustment must be justified in writing, demonstrating that the requested adjustment would constitute a *"disproportionate burden"* within the meaning of Directive 2000/78/EC or would create a *documented and quantified* security risk (and not merely invoked).

6. **Right of appeal:** the requester may appeal to the central executive leadership in case of refusal.

7. **Transparency:** the commission publishes an anonymized annual report indicating the number of requests, the types of adjustments granted and refused, and the processing times.

8. **Security safeguards:**
   - A security impact assessment is required before any binding decision — the CISO provides a written analysis of the risks associated with the requested adjustment;
   - Certain categories of adjustment are excluded *a priori*: exemptions from MFA, access to the sensitive data enclave without standard controls, and any adjustment that would create an unmonitored network path to the infrastructure core;
   - The commission must include at least one member with demonstrated competence in information security or digital risk.

16.4.3 Examples of reasonable adjustments

Table 21: Examples of reasonable adjustments to digital policies

Reason	Obstacle	Possible adjustment
Medical (visual impairment)	Unauthorized accessibility software	Installation authorization with IT support
Medical (RSI)	Standard keyboard/mouse imposed	Authorization of ergonomic BYOD equipment
Personal (caregiver)	Restricted remote access	Extended VPN with enhanced MFA
Professional (AI research)	Cloud AI APIs blocked	Access from dedicated research zone
Professional (security teaching)	Pentest tools prohibited	Isolated cyber-range with charter
Professional (root admin)	Admin rights denied	Granting of admin rights (ETH model)
Academic freedom (Art. 13)	Web filtering blocking scientific sources	Unfiltered access from research zone
Freedom of information (Art. 11)	Blocking of major cloud-based AI services	Access via research zone with traceability
Conscience / dignity (EU Charter Art. 10, 31)	Monitoring perceived as an affront to dignity	Reduction of monitoring to the strict minimum, BYOD zone
Documented technostress	Restrictions causing anxiety and loss of efficiency	Individualized easing with follow-up

16.5 Justification from the literature and international best practices

Several converging arguments support the creation of such a commission:

1. **International law requires it for disability:** the CRPD [155↗] and Directive 2000/78/EC [152↗] mandate reasonable adjustments. Yet digital policies *are* working conditions — their rigidity may constitute indirect discrimination within the meaning of the directive.

2. **The risk-based approach recommends it:** if security must be *proportionate to risk* (GDPR Art. 32 [11↗]), then the refusal of adjustment must be proportionate to the actual risk — which requires an independent assessment, not an automatic refusal by the IT department.

3. **The best universities practice it:**
   - Oxford, MIT and Stanford have governance structures in which academic representatives participate in IT policy decisions, providing institutional channels for addressing disproportionate restrictions;
   - ETH Zurich [17↗] has institutionalized exception pathways (self-assessment, registration, temporary exemptions, isolation zones);
   - The Harvard Faculty of Arts and Sciences has an *IT Governance Committee* of academics that arbitrates conflicts between IT policy and academic needs [145↗].

4. **Organizational psychology confirms it:** Deci and Ryan [183↗] show that perceived autonomy is a fundamental psychological need. Rigid digital policies without recourse diminish the sense of autonomy and competence, reducing intrinsic motivation and increasing turnover — a major risk for a university that depends on the attractiveness of its talent.

5. **IT governance prescribes it:** COBIT 2019 [136↗] identifies the process *"Ensure Stakeholder Engagement"* (EDM05) as a governance objective. The absence of a recourse mechanism for employees violates this principle.

16.6 Integration with the proposed architecture

The ICRADP is not in contradiction with the segmented architecture proposed in this dossier — it is its **indispensable human complement**. The multi-zone architecture structurally reduces the need for individual adjustments (most needs are covered by the appropriate zone), but it cannot cover all cases. The ICRADP ensures that:

- Individual cases not covered by the zone division are handled fairly and promptly;
- The IT department is not overloaded by ad hoc exception requests — the commission centralizes and formalizes the process;
- The university demonstrates its compliance with labour law and anti-discrimination law;
- The digital policy remains a *tool in service of people*, and not a rigid system imposed on individuals without recourse.

17 Conclusion

> "One resists the invasion of armies; one does not resist the invasion of ideas."
>
> — Victor Hugo, *Histoire d'un Crime* [184↗]

The international state of the art shows a clear trend: the most high-performing and most secure universities in the world generally do *not* rely primarily on a uniform restriction policy. They tend to adopt **segmented and federated architectures** that:

- Strongly protect sensitive data in dedicated zones;
- Offer great flexibility to researchers and instructors in adapted zones;
- Use monitoring and detection rather than prohibitions as the first line of defence on research networks;
- Rely on identity federation and mutual security communities.

The fundamental principle of **dependability** — segmentation combined with Trusted Activity Contexts — confirms this approach: it is by multiplying barriers, zones, and validated activity environments, and not by reducing everything to a single perimeter, that the best resilience is achieved.

In the context of 2026, three additional dimensions make this change even more urgent:

- **Artificial intelligence** increasingly requires access to global cloud services to remain competitive in research and teaching;
- **Staff BYOD** is a widespread reality that benefits from being integrated into the architecture rather than resisted;
- The **European regulatory framework** (GDPR, NIS2, AI Act) requires measures *proportionate to risk* and a capacity for *evidence* — exactly what a multi-zone architecture with federated governance produces.

A security policy that significantly hinders researchers from researching and instructors from teaching risks weakening the university rather than protecting it. Security should serve as an *enabler* (*enabling security*), not as an obstacle. Proven solutions exist and are already deployed in many leading universities worldwide. Adopting them would strengthen both security and the university's core missions.

The **feasibility and cost** of the proposed measures have been addressed explicitly: implementation is *phased* (governance → pilot → rollout), relies on existing NREN/GEANT ecosystems and open-source or shared tools where possible, and concentrates investment on the administrative enclave rather than on the whole perimeter. This makes the approach both *implementable* within typical university budgets and *proportionate* to risk, as required by GDPR Article 32 and good governance practice.

Ultimately, a university requires administration, but is not a corporation; university governance must optimise for freedom for ideas and persons, physical or digital. The digital infrastructure should reflect this fundamental distinction.

Part III

Questions and Evidence-Based Answers

How to read this module

This module anticipates the objections most frequently raised against the policy-layer proposals of the dossier and answers each on the evidence. Three box types structure every exchange:

Question a good-faith technical or governance objection, reformulated at its strongest before it is answered.

Insidious framing an objection that smuggles in a premise, a motive, or a rhetorical trap; the answer addresses the framing, not only the surface claim.

Answer an evidence-based response following the concession-then-rebuttal pattern: partial merit is conceded honestly, then the objection is answered across independent evidence layers.

Evidence methodology. Every substantive answer is built from up to five independent layers, presented strongest-first and cross-corroborated:

1. **Legal** — binding instruments of the adopter's jurisdiction; in EU/CoE editions these are the EU Charter, European Court of Human Rights (ECtHR) and Court of Justice of the European Union (CJEU) case law, General Data Protection Regulation (GDPR), NIS2 Directive (NIS2) and the European AI Act (AI Act), used here as the worked example;
2. **Standards** — normative frameworks (NIST CSF 2.0, NIST SP 800 series, ISO/IEC 27001, Control Objectives for Information and Related Technologies (COBIT) 2019);
3. **Sector** — consensus of professional bodies and surveys (EDUCAUSE, GEANT pan-European research network (GEANT), Verizon DBIR, Sophos);
4. **Empirical** — quantified measurements and incident root-cause analysis;
5. **Institutional** — named universities and research organisations with publicly documented practice.

A thesis is treated as robust only when at least three layers sustain it independently; where a layer is contestable, the answer says so. The institutional precedents named below (MIT, Stanford, Oxford, ETH Zürich, CERN, Michigan, and others) are cited as *evidence*, not as models any particular institution must replicate.

1 Questions on network segmentation

> "For every complex problem there is an answer that is neat, simple, and wrong."
>
> — H. L. Mencken, *Prejudices: Second Series*, 1920

Q1.1 — "Segmentation increases complexity and therefore the attack surface"

Network segmentation multiplies the number of zones, inter-zone boundaries, and firewall rules. More boundaries mean more configuration points, more potential misconfigurations, and therefore a *larger* attack surface. A single, well-managed perimeter is simpler and therefore safer.

Answer to Q1.1

Partial merit acknowledged: segmentation does increase *configuration complexity*. This is a genuine engineering concern, not a straw-man.

However, the question conflates two distinct concepts:

1. *Configuration complexity* (the number of rules to manage) and
2. *Attack surface* (the set of points an attacker can exploit).

Segmentation *increases* the former but *decreases* the latter. NIST SP 800-53 Rev. 5 [15↗] explicitly recommends "protecting internal boundaries and isolating components to reduce the attack surface and limit damage." The NIST Cybersecurity Framework 2.0 [133↗] and ISO 27001:2022 control A.8.22 [16↗] both mandate network segregation precisely because it *reduces* the blast radius of any single compromise.

Empirical evidence: documented university ransomware failures of 2024–2025 demonstrate that *centralised, unsegmented perimeters amplify damage*. Where an institution runs a single large administrative perimeter, an attack can disrupt the entire institution for an extended period; conversely, a segmented architecture is designed to confine a breach to a single subnet, limiting the blast radius that a flat network exposes [117↗]. The Verizon 2024 DBIR [19↗] documents the prevalence of lateral movement in such breaches — the propagation path that segmentation, per the NIST and ISO controls cited above, is designed to interrupt.

Managing the configuration complexity: the dossier's phased transition addresses this directly — governance and charters first, a pilot on selected entities next, then gradual extension. Software-Defined Networking (SDN) tools and infrastructure-as-code automate rule management and reduce human error. The complexity argument is an argument for *proper tooling and gradual rollout*, not for avoiding segmentation.

Q1.2 — "A single perimeter is easier to monitor and defend"

With all traffic passing through a single firewall, the security team has full visibility. Segmentation creates blind spots between zones.

Answer to Q1.2

This argument assumes that *centralised inspection* equals *comprehensive visibility*. The opposite is frequently true in practice:

- A single perimeter firewall handling research traffic at 10–100 Gbps cannot perform deep packet inspection without creating bottlenecks — a documented case measured a **five- to twelve-fold throughput degradation** when research traffic traversed an enterprise firewall [61↗].

- When performance degrades, researchers route around the firewall (Shadow IT), creating *actual* blind spots far worse than managed inter-zone boundaries.
- In a segmented architecture, each zone has *its own* monitoring (a Zeek Intrusion Detection System (IDS) on the Science Demilitarised Zone (Science DMZ), IDS/Intrusion Prevention System (IPS) on the administrative zone, per-zone logging baselines). Total observability is *greater*, not lesser.

CERN explicitly operates zone-specific monitoring alongside backbone monitoring [105↗]. The University of Michigan deploys per-zone security classifications and dedicated sensitive-data environments [102↗]. These institutions have demonstrably *better* visibility than a single-perimeter model, not worse.

Q1.3 — "You just want less security to make researchers' lives easier"

The real motivation behind this document is not improved security but reduced control. Researchers want to do whatever they want without oversight. This is a *comfort* argument dressed up in security language.

Answer to Q1.3

The validity of a proposal is best assessed on its evidence and logic, independently of the motives attributed to its authors — attacking the imputed motive rather than the argument is an *ad hominem*. The proposals must be evaluated on their *substance*.

On the substance: the dossier proposes *more* security for sensitive data, not less. The administrative enclave is *smaller, easier to harden and easier to monitor*. The security function gains:

- A reduced and well-defined perimeter for the most sensitive assets;
- Charters replacing informal exceptions with accountable, auditable autonomy;
- Zone-specific monitoring replacing a single, overwhelmed checkpoint;
- Evidence production for GDPR Article 32 and NIS2 compliance.

The "comfort" framing is refuted by the proposal's own evidence: the design is endorsed by NIST [15↗, 133↗], ISO 27001 [16↗], and EDUCAUSE [185↗], and is practiced by MIT, Stanford, Oxford, ETH Zürich, CERN, and the 100-plus universities operating a Science DMZ [57↗, 58↗]. If "wanting less security" were the true motive, these institutions and frameworks would not converge on the same model.

Constructive engagement with evidence-based proposals, as recommended by the COBIT 2019 process EDM05 (*Ensured Stakeholder Engagement*), is more productive than debating motives [136↗].

Q1.4 — "The analogy with firebreaks is misleading — a forest is not a network"

The argument for segmentation leans on a forestry analogy (firebreaks). But networks are not forests: a misconfigured inter-zone rule *is* a vulnerability, unlike a physical firebreak.

Answer to Q1.4

Partial merit: all analogies have limits, and pushing any metaphor too far weakens the argument. The firebreak analogy illustrates one principle only: *compartmentalisation limits propagation*. It is not a complete model of network security.

However, the principle itself does not depend on the analogy. It is established by:

- NIST SP 800-207 (Zero Trust architecture (Zero Trust) Architecture) [66↗]: "assume breach, limit blast radius";
- NIST SP 800-53 Rev. 5 [15↗]: "isolate components to reduce attack surface";
- The Verizon 2024 DBIR [19↗]: lateral movement is a dominant breach-progression mechanism, which network segmentation is designed to interrupt.

The risk of misconfigured rules is real but is an *implementation risk*, not an argument against the principle. The phased transition (pilot first, then rollout) and use of SDN automation directly mitigate this risk.

Technical implementation: the segmentation contract, zone catalogue, and migration approach are developed in the standalone Technical Reference [6].

Q1.5 — "You claim Zero Trust but exclude SASE/ZTNA and never map to NIST SP 800-207"

You claim a Zero-Trust posture, yet you exclude SASE and ZTNA — the two products the market equates with Zero Trust — and never demonstrate Zero-Trust maturity against the actual standard, NIST SP 800-207.

Answer to Q1.5

Excluding SASE/ZTNA from the structural foundation is a sovereignty choice, not a rejection of Zero Trust — and the architecture maps directly to NIST SP 800-207 [66↗]. SASE and ZTNA are commercial *packagings* of Zero-Trust ideas in which a supplier operates the data plane and terminates TLS; that is precisely the data- and technical-sovereignty loss the dossier argues against. Zero Trust is a set of principles, not a product, and the reference architecture realises them structurally:

1. **Resources, secured everywhere** (Tenets 1–2): every layer is a protected resource and communication is secured regardless of network location.
2. **Identity-based, per-session access** (Tenets 3, 6): access is mediated by federated identity (Single Sign-On (SSO)-capable identity providers, eduGAIN) and authorised per session, strictly enforced before access.
3. **Dynamic policy** (Tenet 4): the policy plane decides on identity, role, posture and environment; zones default-deny.
4. **Posture and monitoring** (Tenet 5): endpoint posture signals and the observability layer continuously measure asset integrity.
5. **Telemetry to improve posture** (Tenet 7): an event pipeline collects decision and access telemetry used to refine policy.

The architecture therefore adopts Zero Trust *by SP 800-207 tenet*, while declining the SASE/ZTNA *deployment model* whose supplier-operated data plane is incompatible with the institution's sovereignty objectives. SASE may still be adopted tactically where sovereignty is not at stake; it is not the structural foundation.

2 Questions on governance models

> "The price of freedom is eternal vigilance."
>
> — Attributed to Thomas Jefferson

Q2.1 — "Federated governance creates accountability gaps — who is responsible when a breach occurs?"

If departments manage their own zones, the security function cannot be held responsible for their failures. Accountability becomes diffuse and no one is truly in charge.

Answer to Q2.1

This is a genuine concern and the dossier addresses it explicitly through **enclave charters** modelled on Oxford [18↗] and ETH Zürich [17↗]:

1. Each zone has an *identified owner* (unit head or delegate);
2. The charter specifies incident contacts, logging baselines, and minimum security standards;
3. The central security function defines the *standards* and operates the Security Operations Centre (SOC); departments *implement* within their perimeter;
4. This is not *less* accountability but *more granular* accountability — a model where one officer is nominally responsible for everything but cannot actually control departmental behaviour creates the *real* accountability gap.

At Oxford, unit heads are explicitly *accountable* for information security in their area [18↗]. At Michigan, an IT Council coordinates across nineteen schools with clear responsibility lines [98↗]. At ETH Zürich, the Administrator Rights Agreement [21↗] is a binding *transfer* of responsibility, not an abdication.

Key point: the question is not "centralised vs. distributed accountability" but "formal accountability vs. informal unaccountability." The situation in which users run shadow IT with zero accountability is the real governance failure.

Live-incident containment authority: accountability includes the power to act during an active breach. The enclave charter pre-grants the central security function a scoped, auditable, time-bounded *emergency containment authority* — the right to force network isolation or quarantine of a zone on defined incident criteria, logged and reviewed post-hoc by the digital-policy commission — overriding zone autonomy in real time. This is not an erosion of the federated model but its safeguard: NIS2 Art. 21 (technical and operational risk-management measures) and Art. 23 (incident-reporting duty) already vest a central duty to contain; NIST CSF 2.0 Respond and ISO/IEC 27035 standardise the containment workflow; and the Oxford and ETH Zürich unit-head models already subordinate the unit to a central isolation decision [17↗, 18↗]. The authority is operationalised in the Wave 7 audit-and-incident-response runbooks of the Technical Reference, not merely asserted here.

Q2.2 — "Departments will treat autonomy as the absence of responsibility"

Giving departments autonomy over their IT will lead to neglect: unpatched servers, exposed databases, abandoned research machines connected to the network.

Answer to Q2.2

This risk is real and is identified in the dossier's risk register (rated Medium probability / High impact).

Mitigations are built into the proposal:

- **Charters with accountability:** mandatory incident contacts, logging baseline, periodic reviews;
- **Baseline monitoring by the SOC:** the central security team monitors all zones for anomalies, including research zones;
- **Default-deny at internal boundaries:** a neglected zone cannot propagate to other zones;
- **ETH Zürich isolation model:** non-compliant resources are placed in isolated network zones [17↗] so that weaknesses are not exploitable from outside;
- **Periodic audits:** a digital-policy governance body reviews zone compliance.

Counter-question: under the current monolithic model, are departmental "servers under desks" patched, monitored, and accountable? The answer is typically *no* — they exist as shadow IT with *zero* oversight. Formalised autonomy with charters is strictly *better* than informal unmanaged autonomy.

Q2.3 — "This proposal undermines the security function's authority"

By proposing that academic representatives sit on a digital-policy commission, and that an independent commission can override IT policy decisions, the proposal effectively strips the security function of the authority needed to protect the institution.

Answer to Q2.3

This question rests on a distinction that governance frameworks draw explicitly. The proposal does not remove the security function's authority — it *positions it correctly* within a governance structure. There is a fundamental distinction between:
Governance: strategic direction and risk appetite (the digital-policy commission);
Management: operational execution (the security function and IT department).
This distinction is foundational in COBIT 2019 [136↗] and in the work of Weill and Ross [137↗] on IT governance. De Haes and Van Grembergen [181↗] explicitly warn against conflating governance with management: the security function *executes* security policy; the governance body *defines* the risk appetite and resolves conflicts between security and the institutional mission.

No security officer at MIT, Stanford, Oxford, Michigan, or ETH Zürich has *unilateral* authority over all IT decisions [18↗, 98↗]. In all these institutions, governance bodies with academic representation define policy, and the security function implements it. This is not a diminishment — it is professional governance.

The real question: should a single operational officer have the authority to make decisions affecting academic freedom, research competitiveness, and the fundamental rights of employees *without external oversight*? Every governance framework says no.

Q2.4 — "Academics should not interfere with security — they lack expertise"

Security is a technical discipline. Putting academics on a digital-policy commission is like putting passengers in the cockpit.

Answer to Q2.4

A more precise analogy might be surgeons having input on hospital operating-theatre design — academics are *the people whose work the infrastructure exists to serve*, not passive passengers. No hospital would exclude surgeons from that process and defer entirely to the facilities manager.

The expertise argument conflates two levels:

- *Technical implementation* (firewall rules, IDS configuration): this is the security function's domain — no one disputes this;
- *Policy direction* (what should be restricted, what autonomy is needed, what risk appetite is acceptable): this is a *governance* question requiring input from all stakeholders.

NIST CSF 2.0 Govern (GV) function [133↗] explicitly integrates "stakeholder needs" into cybersecurity strategy. ISO 27001 Clause 4.2 [16↗] requires understanding "the needs and expectations of interested parties." EDUCAUSE [186↗] recommends governance structures including academic representation. Excluding the primary users of the infrastructure from governance decisions violates every major IT governance framework.

Furthermore, in a university context, many academics *are* technical experts: computer-science researchers, cybersecurity specialists, network engineers. Dismissing their expertise because they are "academics" is a category error.

3 Questions on research zone autonomy and local administrative privileges

> "Discovery consists in seeing what everybody else has seen and thinking what nobody has thought."
>
> — Attributed to Erwin Schrödinger

Q3.1 — "Giving researchers root access creates unacceptable risk"

Root access means researchers can disable security tools, install vulnerable software, and create backdoors. One compromised research machine can become a launchpad for attacks against the entire institution.

Answer to Q3.1

Partial merit: root access is indeed a powerful privilege that can be misused. This is why the dossier does not propose *unrestricted* root access but *accountable* root access within dedicated zones.

The ETH Zürich model [21↗]:

1. The user requests root rights for a documented purpose (thesis, research project);
2. By signing the agreement, the user accepts *personal responsibility* for maintenance;
3. The user commits not to disable basic security mechanisms (logs, updates);
4. Non-compliant machines are placed in isolated network zones [17↗];
5. It is a *transfer of responsibility*, not an abdication of control.

Why this is safer than the alternative: when root access is denied, researchers jailbreak managed machines, use hidden VMs, connect lab equipment via personal hotspots, or deploy entirely unmanaged servers under desks. These shadow systems have *no* logging, *no* patching, *no* accountability, and *no* isolation. Formal root access with charters, accountability, and network isolation is strictly safer than informal root access with no controls.

The "launchpad" fear: in a segmented architecture, a compromised research machine cannot reach the administrative enclave — this is the entire point of segmentation. At CERN, experiment networks are isolated from the general network by strict firewalls and Access Control List (ACL)s [103↗], yet physicists retain extensive local control.

Q3.2 — "Researcher autonomy = researcher liability — this unfairly burdens academics"

By transferring responsibility via charters, the institution offloads security risk onto academics who are not trained for it. This is unfair and possibly illegal under employment law.

Answer to Q3.2

This concern has merit when pushed to extremes — researchers should not be expected to be full-time system administrators. The dossier addresses this through multiple mechanisms:

- Central IT still provides the backbone, Identity and Access Management (IAM), SOC, and baseline monitoring — researchers are not "on their own";
- ETH Zürich deploys *Data Stewards* [106↗] and departmental IT staff (ISGs) [90↗] who bridge the gap between central IT and researchers;
- The charter defines *proportionate* responsibilities: a researcher who installs a notebook server has lighter obligations than one running a public-facing web service;

- The progressive transition includes training of local IT correspondents by the IT services.

On the legal point: the charter model is an established, documented practice at institutions such as ETH Zürich and Oxford [18↗, 21↗]. The responsibility is *contractual and proportionate*, not a blanket transfer of institutional liability.

Counter-question: under the current model, when a researcher deploys shadow IT that is breached, who is liable? The answer is unclear — which is precisely the governance failure that charters resolve.

Q3.3 — "The Science DMZ bypasses security controls — this is a security hole by design"

The Science DMZ explicitly removes the enterprise firewall from the research data path. This means research traffic is not inspected. This is an indefensible gap in security posture.

Answer to Q3.3

The premise is factually incorrect. The Science DMZ does *not* remove security — it replaces one type of security (a stateful firewall, designed for enterprise traffic) with another appropriate for research traffic:

ACLs on routers: whitelist-based filtering at line speed;

Zeek (formerly Bro) IDS: a dedicated intrusion-detection system monitoring all Science DMZ traffic [187↗];

perfSONAR: active performance monitoring that detects anomalies [55↗];

Data Transfer Node (DTN) hardening: Data Transfer Nodes are purpose-built, minimal-service machines with a reduced attack surface.

This model was developed by ESnet [29↗], the U.S. Department of Energy's network serving nuclear laboratories. It is deployed at **over 100 universities** through NSF funding [57↗, 58↗]. If bypassing the enterprise firewall were a "security hole by design," neither the DoE nor the NSF — both security-conscious organisations — would have funded and promoted it.

The deeper point: a stateful firewall that, in a documented case, mishandled TCP window scaling on high-volume long-distance flows and degraded research throughput by **five- to twelve-fold** [61↗] does not *provide* security. It provides the *appearance* of security while driving researchers to bypass it via shadow IT. A Science DMZ with ACLs, IDS, and monitoring provides *actual* security appropriate to the traffic profile.

Q3.4 — "If the Science DMZ were so good, our network operator would already have deployed it"

The model is presented as state of the art and adopted by 100-plus universities. Yet neither our national research network nor our HPC team publishes any Science DMZ today. The absence is itself an argument: if it were the right answer for us, our National Research and Education Network (NREN) or our High-Performance Computing (HPC) team would already have built it.

Answer to Q3.4

The factual premise may be correct; the inference is not — this is an appeal to absence. That an institution or its NREN has not yet deployed a pattern is not evidence that the pattern is unsuitable; it is, in most cases, evidence about *capacity and funding routes.*

Three observations frame the diagnostic generically:

1. **The substrate is often already present.** High-bandwidth NREN access (e.g. via GEANT [52↗]), a national Computer Security Incident Response Team (CSIRT) for incident response, and an HPC facility moving large volumes of data internationally are frequently in place. What is missing is the architectural *pattern*, not the bandwidth. Current research transfer over generic enterprise paths (`rsync`, `scp`) is an enterprise-IT profile, not a research-tuned one [29↗, 131↗].
2. **Non-deployment tracks capacity, not merit.** A small research ecosystem with a limited pool of research-network engineers, and the absence of a dedicated funding programme equivalent to the NSF CC* line that explicitly funded Science DMZs at over 100 U.S. campuses [57↗, 58↗], explains non-deployment without implying technical inadequacy.
3. **Convergent practice elsewhere is overwhelming.** ESnet, NSF, GEANT, and the Medical Science DMZ pattern — documented in implemented deployments at major U.S. biomedical-research institutions [68↗] — converge on the design. "We have not done X yet" is a weak argument against X when every comparable research ecosystem has.

The realistic form is mutualised. The proposal is not a siloed institution-only Science DMZ but a federated research-network zone — with a Medical Science DMZ enclave for biomedical workloads — *co-designed* across the research-active institutions and the NREN. Mutualisation is the form in which the operational and economic case closes at small scale.

One honest caveat. A 2024 quantitative study confirms that Science DMZ benefits are not automatic: without deliberate tuning of hosts, protocol stacks and measurement, latency on long-RTT paths can even degrade [65↗]. This argues for operational ownership and tuning, not for inaction.

4 Questions on BYOD and AI cloud services

> "The best way to predict the future is to invent it."
>
> — Alan Kay, Xerox PARC, 1971

Q4.1 — "BYOD is inherently insecure — personal devices cannot be trusted"

Personal devices are not managed, may be infected, may lack encryption, and may be shared with family members. Allowing them on the network is an unnecessary risk.

Answer to Q4.1

Bring Your Own Device (BYOD) is not a policy choice — it is a reality. Faculty members use personal laptops. Researchers use personal phones. Visiting scholars arrive with their own devices. The question is not whether BYOD exists but whether it is *managed or unmanaged*.

The dossier proposes *progressive interoperability*:

1. **Without authentication:** Internet only (guest zone);
2. **With Multi-Factor Authentication (MFA) authentication:** access to teaching and research resources matching the user's profile;
3. **With a compliant device (verified posture):** extended access including administrative resources via a secure Virtual Desktop Infrastructure (VDI).

This is precisely the Zero Trust approach recommended by NIST SP 800-207 [66↗]: access decisions based on identity and device posture, not on whether the device is "managed" or "personal."

Education Roaming (eduroam) [26↗] — the global academic federated Wi-Fi system — has operated successfully for two decades on exactly this principle: authenticate users, not devices.

The alternative — banning BYOD — pushes devices onto personal hotspots and creates genuinely unmanaged, invisible connections. This is *less* secure than a dedicated BYOD subnet with progressive access.

Q4.2 — "Giving researchers free access to non-EU AI cloud services creates GDPR liability"

Commercial AI cloud services are not fully GDPR-compliant. If researchers send personal data to these services, the institution faces regulatory sanctions.

Answer to Q4.2

This is a legitimate concern and the dossier does not propose unfettered access without safeguards. It proposes a *differentiated framework*:

1. **Data classification:** personal data is *never* sent to a third-country service without a lawful basis and a valid transfer mechanism — an adequacy route where one exists (e.g. the EU–US Data Privacy Framework for certified providers), or standard contractual clauses (Standard Contractual Clauses (SCC)s) supplemented, per *Schrems II*, by a documented Transfer Impact Assessment (Transfer Impact Assessment (TIA)) and supplementary technical measures (encryption, pseudonymisation, key custody), as operationalised in the regulatory mapping;

2. **Environment separation:** research AI environments are isolated from the administrative zone, preventing accidental mixing of personal data with research API calls;
3. **AI Act risk-based compliance:** for researchers *using* commercial AI services, the applicable framework is the AI Act's risk-based classification — *not* a blanket research exemption; the Art. 2(6)/2(8) exemptions cover bespoke, pre-market research tools, not commercial-API use [42↗];
4. **Traceability:** logging of external API access for auditing;
5. **Training:** researcher awareness of GDPR implications.

The alternative is worse: when access is blocked, researchers use personal accounts on personal devices outside the institutional network, sending the same data with *zero* institutional safeguards, *zero* SCCs, and *zero* traceability. The institution's GDPR exposure is *higher*, not lower, when it refuses to provide a managed pathway.

Competitive reality: leading research universities increasingly provide researchers with *managed* access to global AI platforms rather than prohibiting them outright. An institution that blocks such access risks putting its researchers at a competitive disadvantage relative to peers who provide a governed pathway.

Q4.3 — "The AI access proposal is about convenience, not necessity"

Researchers managed perfectly well before generative AI. AI cloud access is a luxury, not a structural need for research. The institution should not compromise its security posture for fashionable tools.

Answer to Q4.3

This perspective may underestimate the pace of change in research methodologies. Behavioural research on decision-making [180↗] documents *status-quo bias*: the tendency to prefer the current state of affairs simply because it is familiar, regardless of evolving evidence.

On the facts: foundation models and generative AI are *not* optional luxuries for research in computer science, NLP, machine learning, data science, computational biology, digital humanities, and increasingly the social sciences. Major conferences (NeurIPS, ICML, ACL, CVPR) feature a large and growing share of work relying on cloud AI platforms, and funding agencies explicitly fund AI-based research.

Dismissing AI as "fashionable tools" is analogous to dismissing the Internet in 1995 or statistical software in 1985. The question is not *whether* universities will use AI cloud services but *whether they will do so through managed, secure channels or through ungoverned shadow IT*.

Structural need: AI research *requires* access to APIs (for model comparison, fine-tuning, evaluation), cloud accelerators (for training), and open-source model repositories. These are not interchangeable with local-only tools. Teaching advanced AI courses without API access is like teaching chemistry without a laboratory. The differentiating factor is not the tool but the *governed workflow*: managed access with classification and logging improves outcomes, while a blanket ban displaces the same activity into the ungoverned shadow.

5 Questions on institutional comparisons and transferability

"In theory, there is no difference between theory and practice. In practice, there is."

— Attributed to Yogi Berra

Q5.1 — "You are comparing us to MIT and Stanford — this is absurd"

MIT has a multi-billion endowment; Stanford has thousands of IT staff. We are a small institution. These comparisons are meaningless and the models cannot transfer.

Answer to Q5.1

The comparison is not about replicating budgets but about adopting scale-independent architectural principles. The question assumes that the only relevant difference is scale, and that smaller institutions cannot adopt principles from larger ones — a *false equivalence* between "adopting a principle" and "replicating a budget".

The dossier does not propose replicating any institution's budget. It proposes adopting *architectural principles* (segmentation, federation, charters) that are *scale-independent*:

- **Virtual Local Area Network (VLAN) segmentation** requires no additional *hardware* budget — it is a configuration decision on existing switches; the cost is design and operational labour, not procurement;
- **Charters** are documents, not infrastructure purchases;
- **The Science DMZ** uses open-source tools (perfSONAR, Zeek) and NREN services already available through GEANT [52↗, 55↗];
- **Federated governance** is an organisational choice, not a technology procurement.

The evidence base deliberately spans institutions of different sizes: not only MIT and Stanford, but also smaller European universities, ETH Zürich, Michigan, NC State, Penn State and Wisconsin-Madison [20↗, 98↗, 107↗, 108↗]. The architectural principles are consistent across all sizes.

The scale argument actually favours federation: a small institution has *fewer* resources for a monolithic central team to manage everything. Federation distributes the workload to where domain expertise exists.

The deeper point: these are not larger institutions' choices to borrow, but a minimal necessary set. The functions the architecture discharges — authenticating users, protecting sensitive and personal data, segmenting, auditing — are required of *any* institution offering a digital infrastructure. Several are legally compelled with no size threshold: a data-protection duty applies to any institution processing personal data, irrespective of size, under the institution's applicable data-protection regime (in the EU, the GDPR [11↗], which applies irrespective of size). The choice a small institution faces is therefore not "afford the leading universities' model or not", but "discharge these already-owed obligations coherently and sovereignly, or implicitly and dependently". Only the instantiation scales with size; the obligations do not [6].

Q5.2 — "Cherry-picking successful models ignores failed federations"

The dossier only cites universities where federation works. What about universities that tried federation and failed, reverting to centralisation?

Answer to Q5.2

This is a fair challenge. Any honest analysis must consider counter-examples.

However:

1. The evidence base spans **a broad set of reference universities** across the US, UK, Switzerland and continental Europe, plus CERN, plus the wider NREN ecosystem. This is not cherry-picking — it is the *dominant pattern* in high-performing universities worldwide.
2. The EDUCAUSE Top 10 IT Issues [185↗] and EDUCAUSE IT-governance resources [186↗] consistently recommend federated governance for higher education. This is sector consensus, not anecdote.
3. Counter-examples of "failed federation" typically involve institutions that *federated without accountability mechanisms* (no charters, no SOC oversight, no minimum standards). The charter-based model addresses this risk directly.

The burden of evidence is symmetrical: if the questioner claims that federation fails, they should cite specific examples and show that the failures were caused by *federation itself* rather than by the absence of the governance mechanisms proposed here.

Q5.3 — "Those universities were built federated — we cannot retrofit federation onto a centralised institution"

MIT, Cambridge, and Stanford were *born* decentralised. Their federation is historical, not deliberate. You cannot impose federation on an institution that has been centralised for years.

Answer to Q5.3

Factually incorrect for several documented universities:

- **NC State** explicitly *redesigned* its IT governance for digital transformation, as documented in EDUCAUSE Review [107↗];
- **Penn State** *unified* IT professionals from centralised units while introducing participatory governance and SLAs [108↗];
- **Wisconsin-Madison** adopted federation as a deliberate "modernisation and federation" strategy [20↗];
- **University of Michigan** evolved from a more centralised model to formal federation with the creation of an IT Council [98↗].

Federation is not a "natural state" — it is a *governance choice* that can be adopted, with appropriate transition planning. The progressive transition plan (governance first, then pilot on selected entities, then gradual extension) is designed precisely for institutions moving *from* centralisation *to* federation.

Q5.4 — "The reversibility claim rests on soft, single-vendor conformance tests"

The lock-in answer rests on exit tests and a reversibility playbook; if those tests are anchored on single-vendor specifications, the guarantee is soft.

Answer to Q5.4

The exit tests are cross-implementation by design, not single-vendor. Each replaceable layer is tested against an *alternative* implementation: System for Cross-domain Identity Management (SCIM) user/group export to an alternative identity provider, policy bundles re-imported into an alternative engine, container images to an alternative OCI registry, switch

configuration to an alternative-vendor device, the analytical store re-pointed, and object-store operations against an independent S3-compatible implementation. Reversibility is therefore tested behaviour, not a vendor promise — developed in full in the standalone Technical Reference [6].

6 Questions on the independent adjustments commission

> "Injustice anywhere is a threat to justice everywhere."
>
> — Martin Luther King Jr., *Letter from Birmingham Jail*, 1963

Q6.1 — "An independent adjustments commission creates bureaucratic overhead and slows down IT decisions"

Adding an independent commission that can override IT policy decisions introduces delays and bureaucracy into what should be agile operational decisions.

Answer to Q6.1

The Independent Commission for Reasonable Adjustments of Digital Policies (ICRADP) does not "override" operational decisions. It provides an *adjustment* mechanism for *individual* cases where a *general* policy creates a disproportionate obstacle for a specific person. This is analogous to a court system: the existence of courts does not slow down legislation; it corrects general rules that produce unjust outcomes in specific cases.

On timing:

- The commission rules within a short, published deadline — faster than many IT change-management processes;
- In documented emergencies (medical, professional), a provisional adjustment can be granted within a sharply shorter window;
- The commission handles *exceptions*, not routine operations. The segmented architecture, by providing appropriate zones for most needs, *reduces* the number of adjustment requests.

Cost of the alternative: without a formal mechanism, adjustment requests are handled through *informal negotiations* with the IT department — a process that is slower, less predictable, less fair, and produces no auditable record. The ICRADP *streamlines* exception handling by centralising and formalising it.

Q6.2 — "The commission is a Trojan horse to override IT security decisions"

Under the guise of "reasonable adjustments," every dissatisfied user will appeal to the commission to bypass security controls. The commission will become a mechanism for institutional circumvention of IT policy.

Answer to Q6.2

This concern is understandable; the following structural safeguards are designed precisely to prevent abuse:

1. *Documented justification:* requests must specify medical, personal, professional, or fundamental-rights grounds;
2. *Proportionality assessment:* the commission evaluates whether the adjustment creates a disproportionate security risk (not merely an inconvenience for IT);
3. *Reasoned refusals:* the commission can and will refuse requests that do not meet the criteria;
4. *Annual transparency report:* statistics on granted/refused requests, preventing either systematic overriding or systematic refusal;
5. *The security function is heard:* the security perspective is formally considered in every decision.

Precedent: reasonable-adjustment committees that support students and staff operate on similar principles across many institutions and have not devolved into mechanisms for "bypassing" academic standards. Courts, ombudsmen, and appeal mechanisms exist in every well-governed institution without destroying the authority of the decision-makers they review.

The deeper issue: an IT department that cannot withstand *reasoned, independent review* of its policies is an IT department whose policies may not be defensible. Accountability mechanisms strengthen governance; they do not undermine it.

Q6.3 — "Citing fundamental rights for IT policy is emotional manipulation"

Invoking the EU Charter of Fundamental Rights, the ECHR, and human-rights case law for a discussion about firewall rules is disproportionate and emotionally manipulative. This conflates totalitarian censorship with ordinary IT administration.

Answer to Q6.3

The legal framework cited is binding, not rhetorical. Here is how it applies concretely:

- In EU jurisdictions, Article 13 of the EU Charter protects academic freedom as a *fundamental right* and applies to *universities* — that is not a stretch; it is the literal scope of the provision. Comparable jurisdictions protect academic freedom under their own constitutional or statutory instruments.
- The ECtHR in *Sorguç v. Turkey* [158↗] and *Erdoğan v. Turkey* [159↗] applied freedom-of-expression protections specifically to *academic* contexts.
- The CJEU in *Scarlet Extended v. SABAM* [161↗] ruled that *systematic filtering* of Internet traffic is incompatible with Article 11 of the Charter.
- The Grand Chamber in *Bărbulescu v. Romania* [141↗] established a **six-criteria proportionality test** for digital surveillance *in the workplace* — the exact context of university IT policies.

These are not abstract philosophical references. They are *binding law* in the EU and Council of Europe member states; where the adopter is so bound, an IT policy that systematically restricts digital access and monitors communications *must* satisfy the proportionality requirements of these instruments. Elsewhere, they stand as a strongly persuasive proportionality benchmark alongside the adopter's own fundamental-rights instruments.

Scale of the claim: the dossier does not compare university IT policies to totalitarian censorship. It argues that digital policies *engage* fundamental rights and must therefore pass a proportionality test. This is a measured, legally grounded claim — not emotional manipulation.

Q6.4 — "Technostress and moral injury are not real occupational hazards — this is pseudoscience"

Technostress is a buzzword. Moral injury applies to soldiers, not to academics who cannot install software. Citing these concepts to argue against IT policies is scientifically dubious.

Answer to Q6.4

The scientific evidence is extensive and peer-reviewed:

Technostress: La Torre et al. [174↗] published a systematic review of **105 studies** in the *International Archives of Occupational and Environmental Health* (Springer), establishing technostress as a documented occupational risk with measurable effects on well-being

and productivity. Tarafdar et al. [171↗] demonstrated its impact on role stress and performance in the *Journal of Management Information Systems*. Ragu-Nathan et al. [175↗] validated the construct empirically in *Information Systems Research*. These are top-tier peer-reviewed journals, not "buzzword" sources.

Moral injury: Litz et al. [176↗] introduced the construct in the *Clinical Psychology Review*. Williamson et al. [177↗] published a systematic review and meta-analysis in the *British Journal of Psychiatry*, extending the concept to *occupational* contexts. Hanna et al. [178↗] specifically studied moral injury in *university staff*. The concept is not limited to military contexts — it is a well-established framework in occupational psychology.

Dismissing peer-reviewed systematic reviews as "pseudoscience" without engaging the evidence is itself an unscientific position. One may disagree with the *policy implications* drawn from this literature, but denying the documented phenomena requires counter-evidence, not dismissal. These findings describe documented risks; the dossier pairs them with the mitigation it proposes (proportionate policy and an adjustments mechanism), not with a claim that restriction is always harmful.

7 Questions prompted by recent incidents

> "Data is not information, information is not knowledge, knowledge is not understanding, understanding is not wisdom."
>
> — Russell L. Ackoff, *From Data to Wisdom*, 1989

Q7.1 — "Recent university breaches prove we need MORE restriction, not less"

The headlines are clear: universities are under siege from ransomware and supply-chain compromises. This is not the time to relax security by giving departments autonomy.

Answer to Q7.1

This is a frequently heard interpretation that warrants careful factual examination. Sector incident analysis points consistently to a small set of root causes:

- **Third-party software vulnerabilities (supply chain):** neither "more restriction" on research zones nor "less department autonomy" would have prevented them. The mitigation is vendor risk management, patching, and *isolation of critical applications* — which is what segmentation achieves.
- **Centralised administrative perimeters:** ransomware that exploits a single undifferentiated perimeter is amplified by the *absence* of segmentation, where email, data servers, and administrative services share one perimeter.
- **Credential compromise and lateral movement:** segmentation is the standard defence against lateral movement [19↗].
- **Contained incidents:** where an incident *is* confined to a subnet, that is a demonstration that segmentation *works* [117↗].

None of these incident classes were caused by "openness," "federation," or "research-zone autonomy." They were caused by third-party vulnerabilities, credential compromise without segmentation, and centralised perimeters that became single points of failure. The Sophos State of Ransomware in Education 2025 [125↗] identifies "exploited vulnerabilities" and "unknown security gaps" as top causes — consistent with patching and segmentation, not with restriction. The proposed mechanisms (segmentation, enclaves, charters, zone-specific monitoring) *directly address* every one of these root causes; the "more restriction" response does not.

Q7.2 — "The incident analysis is biased — it selectively interprets failures to support its thesis"

Any incident can be interpreted multiple ways. Claiming that a centralised-perimeter breach proves the need for *less* centralisation is tendentious when it could equally prove the need for *stronger* centralisation.

Answer to Q7.2

This is a fair methodological challenge. Let us examine it rigorously.

The claim that a centralised-perimeter breach proves "stronger centralisation" would need to show that (i) the breach was caused by a *decentralised* part of the infrastructure, and (ii) a more centralised architecture would have prevented the specific attack vector.

The available evidence on the canonical cases shows the opposite: such attacks target *central administrative services* (email, data servers), and the damage is amplified because these

services sit in a single, undifferentiated perimeter. Centralising *more* services into that perimeter would have *increased* the blast radius.

The interpretation aligns with independent sector analysis:

- Verizon DBIR 2024 [19↗]: lateral movement as a dominant breach-progression mechanism, which segmentation is designed to interrupt (per the NIST/ISO controls above);
- NIST SP 800-215 [126↗]: a guide to securing enterprise networks through segmentation;
- Sophos State of Ransomware in Education 2025 [125↗]: "exploited vulnerabilities" and "unknown security gaps" as top causes — consistent with patching and segmentation, not with restriction.

The analysis is not "selective interpretation" — it is alignment with the independent analysis of Verizon, Sophos, and NIST. The burden is on the questioner to show how "stronger centralisation" addresses the documented root causes.

8 Questions on regulatory interpretation

> "The law is reason, free from passion."
>
> — Aristotle, *Politics*

Q8.1 — "NIS2 may actually require MORE centralisation, not federation"

The NIS2 Directive requires incident notification, risk management, and governance. These requirements are easier to demonstrate with a single, centralised IT authority. Federation makes compliance harder.

Answer to Q8.1

NIS2 is requirements-based, not architecture-prescriptive. The Directive specifies *what* must be achieved (risk management, incident containment, governance) but does *not* prescribe *how* the infrastructure must be organised.

A federated architecture with a central SOC for detection and notification, per-zone risk assessments and incident playbooks, charters documenting responsibilities and contacts, and a digital-policy commission for strategic oversight, meets every NIS2 requirement while *also* providing the compartmentalisation that *improves* incident containment — a core NIS2 objective.

One locatable clock owner. Where the adopter is an essential or important entity under the applicable supranational and national legal framework, the central SOC owns the incident-reporting clock — in the EU, the NIS2 Article 23 timeline of a 24-hour early warning, a 72-hour notification and a one-month final report [12↗] — while the zone charters oblige each zone to report inward to the SOC within a sub-deadline. The single-owner pattern is generic: it applies to whatever incident-reporting regime governs the adopter, so federation does not fragment the reporting obligation but gives it a single, accountable owner.

ISO 27001 precedent: universities that achieve ISO 27001 certification commonly scope the certification to *central IT services* rather than the entire institution. Clause 4.3 of the standard [16↗] expressly permits such a bounded Information Security Management System (ISMS) scope, and certifiers accept this *de facto* federation as a valid scope definition.

The evidence argument: a multi-zone architecture with per-zone logging, incident playbooks and regular testing *produces more auditable evidence* than a single monolithic perimeter.

Q8.2 — "The GDPR 'risk-based' argument is too convenient — it could justify anything"

Saying that GDPR Article 32 requires measures "appropriate to the risk" does not mean an institution can decide to accept more risk. A supervisory authority could still sanction insufficient security even if the institution claims it assessed the risk.

Answer to Q8.2

Correct — the risk-based approach is not a carte blanche. GDPR Article 32 requires measures appropriate to the risk, taking into account the "state of the art, costs, context, and the likelihood/severity of risks" [11↗]. The institution must demonstrate that its choices are *justified*, not merely *convenient*.

However, this argument applies equally to the monolithic approach:

- A monolithic approach that *over-restricts* research and teaching while *under-protecting* the administrative enclave (because the same firewall handles both) may also fail the "appropriate to the risk" test — for different reasons;
- The "state of the art" element explicitly requires considering what comparable institutions do. The state of the art in higher education *is* segmented, federated architecture; an institution that ignores it may be *more* exposed to regulatory challenge, not less;
- The European Data Protection Board (EDPB) [44↗] and European Union Agency for Cybersecurity (ENISA) [45↗] confirm the risk-based interpretation and that measures must be *adapted to context* — not uniformly maximal.

The dossier does not argue for "less security." It argues for *differentiated* security: maximum where the risk is highest (administrative data), proportionate where the risk is lower (research). This is precisely what GDPR Article 32 contemplates.

Q8.3 — "The proposal never states a GDPR lawful basis or a DPIA trigger"

The proposal introduces new processing of personal data — per-zone monitoring, the audit pipeline (which logs subject and decision identifiers), AI-API access logging, and federated identity — yet it never states the GDPR Article 6 lawful basis, nor identifies an Article 35 DPIA trigger. Under the Article 5(2) accountability principle, a controller must be able to demonstrate its lawful basis; as written, a Data Protection Officer (DPO) could refuse the proposal on the ground that none is stated.

Answer to Q8.3

The concern is well founded, and the lawful basis is stated here explicitly. The proposal does introduce new processing, and under GDPR Article 5(2) the controller must be able to demonstrate its lawful basis [11↗].

Lawful basis. The controller identifies a lawful basis under the institution's applicable data-protection regime: a public-mission body typically relies on the public-interest task, a private body on legitimate interests or consent. In the EU instantiation, for a public university the monitoring, audit and identity processing rests on GDPR Article 6(1)(e) — processing necessary for a task carried out in the public interest (the institution's research and teaching mission and its statutory security obligations, including those under NIS2) — and, where appropriate, Article 6(1)(f) legitimate interests (network and information security, expressly recognised in Recital 49), subject to the balancing test against data subjects' rights and freedoms. Any processing of special categories of data is conditioned on a corresponding Article 9 ground.

DPIA. Because the monitoring and audit pipeline use new technologies and entail systematic processing likely to result in high risk, they are expected to warrant a DPIA under Article 35(1) [11↗]. The proposal feeds that assessment rather than replacing it: the per-scenario audit records supply the systematic description, the necessity-and-proportionality analysis and the risk treatment an Article 35 DPIA requires. The per-processing lawful basis is finalised in the DPIA and the Record of Processing Activities (Article 30), owned by the institution's DPO.

This strengthens, rather than weakens, the proposal. A monolithic perimeter that monitors all traffic uniformly faces the *same* Article 6 and Article 35 obligations with *less* ability to scope and minimise. The segmented, context-bounded design keeps monitoring proportionate — per-zone scope, minimised audit fields, access-controlled logs — which is exactly what the necessity-and-proportionality test of Article 35 rewards.

Q8.4 — "Barbulescu is wielded outward but never applied to the proposal's own monitoring"

Q6.3 invokes the Bărbulescu six-criteria proportionality test against restrictive monitoring, but the proposal's own per-zone monitoring, SOC oversight and audit pipeline (logging subject and decision identifiers) are themselves surveillance — which the proposal never runs through the same six criteria. A reviewer could call this an asymmetry.

Answer to Q8.4

Fair point — the same test must, and does, apply to the proposal's own monitoring. The architecture's monitoring is surveillance in the Bărbulescu [141↗] sense and is assessed here against its six criteria:

1. **Prior notification:** monitoring is disclosed in advance through the zone charters and the institution's transparency notices.
2. **Extent and intrusion:** the audit pipeline records *metadata* (subject and decision identifiers, verdicts, timestamps), not communication *content*; monitoring is scoped per zone, not blanket, and retained for a bounded period.
3. **Legitimate justification:** the aim is network and information security and the institution's NIS2/GDPR duties — not performance or behavioural surveillance; access to any content would require the weightier justification Bărbulescu demands.
4. **Least intrusive means:** context-bounded, metadata-level monitoring is *less* intrusive than the blanket content inspection a monolithic perimeter tends toward.
5. **Consequences and use:** logs feed security operations and incident response under access controls; they are not a routine input to disciplinary or performance decisions.
6. **Safeguards:** SOC access controls, retention limits, DPO oversight and the DPIA (Q8.3) provide the safeguards Bărbulescu requires — especially the bar on routine content access.

Far from exempting itself, the proposal's segmented, metadata-level design is what *lets* it satisfy the Bărbulescu criteria more readily than the uniform monitoring it replaces.

Q8.5 — "Federated procurement leaves NIS2 supply-chain security (Art. 21(2)(d)) without an owner"

The incident answers address supply-chain risk only *after the fact*. NIS2 Article 21(2)(d) imposes a *forward*, standing duty to manage security in the supply chain and supplier relationships. Where zones and faculties procure their own tools, a security officer could refuse the proposal on the ground that no one owns supply-chain assurance *across* autonomous zones.

Answer to Q8.5

The obligation is real, forward-looking, and distinct from incident response — and it has a named owner here. The supply-chain-security duty of the applicable supranational and national legal framework (in the EU, NIS2 Article 21(2)(d) [12↗]) requires ongoing management of supplier and supply-chain security, not merely post-incident remediation.

The architecture already carries the control. The lifecycle wave, a supply-chain-attestation instantiation (signed provenance and SBOMs), and a procurement-clause workstream established in the foundations wave [6] produce software provenance and contractual security clauses applied to *every* acquisition, regardless of which zone procures it.

One accountable owner, mirroring the Article 23 clock. Just as the central SOC owns the NIS2 reporting clock (Q8.1), a central security-governance owner maintains the

supplier-assurance baseline — the approved-supplier register, the mandatory procurement clauses, and the attestation requirements — while each zone charter binds local procurement to that baseline. Federation therefore does not fragment supply-chain assurance: it gives it a single, locatable owner with per-zone obligations reporting inward.

Q8.6 — "Data-subject rights are unfulfillable across federated zones and a distributed audit store"

Q8.3 and Q8.4 establish the lawful basis, DPIA and proportionality of monitoring, but never explain how the institution actually fulfils a data subject's Article 15 access, Article 16 rectification or Article 17 erasure request when identity is federated and the audit log is distributed across autonomous zones. A DPO could refuse on the ground that rights become unfulfillable in a distributed design.

Answer to Q8.6

The concern is well founded, and the same single-accountable-owner logic that locates the Article 23 clock (Q8.1) locates rights fulfilment. Distribution raises a genuine operability question; the design answers it with one front door, one map, and per-zone duties.

Central intake (one front door). A data-subject request is received and tracked at a single DPO-owned intake point, so the data subject never has to address individual zones.

Per-zone retrieval duty. Each zone charter carries a binding obligation to locate, return, rectify or erase the records it holds within a sub-deadline, reporting inward to the DPO — exactly as zones report inward to the SOC for incident notification.

Bounded retention and a locator. The audit pipeline records minimised *metadata* for a bounded period (Q8.4), so scheduled expiry makes Article 17 erasure tractable rather than a distributed deletion hunt; and the Article 30 Record of Processing Activities [11↗], owned by the DPO, maps which zones and systems hold which categories of data, so any Article 15/16/17 request is routed deterministically across the federation.

The evidence store is itself a control. The audit trail that underwrites these rights is not assumed trustworthy: it is append-only and tamper-evident (per-record signing or hash-chaining), with separation of duties between operators and readers and a four-eyes rule on retention expiry, as specified in the Technical Reference's observability chapter. The record proving accountability therefore cannot be silently altered or selectively deleted (GDPR Art. 32 / Art. 5(1)(f); ISO/IEC 27001 A.8.15).

9 Questions on costs and feasibility

> "There is nothing more expensive than a missed opportunity."
>
> — Attributed to H. Jackson Brown Jr.

Q9.1 — "The cost analysis lacks concrete numbers — how much will this actually cost?"

The dossier discusses costs qualitatively but does not provide a detailed budget. Without concrete figures, the cost-benefit analysis is speculative.

Answer to Q9.1

This is a fair request and one that can only be fully addressed through a detailed implementation study specific to the institution's current infrastructure, contracts, and staffing.

What the dossier does provide:

- **The governance step** (commission, charters, digital-policy commission): predominantly *organisational* — no new infrastructure, implementable with existing staff;
- **The pilot step** (selected entities with domain expertise): standard open-source tools and NREN services already available through GEANT [52↗];
- **The extension step:** gradual rollout aligned with validated results;
- **Cost of inaction:** the global all-industry average data-breach cost reached $4.88M in 2024 [188↗] (the education sector sits below this average); talent drain, Shadow IT, and lost competitiveness in funding calls are additional indirect costs.

The absence of a line-item budget in a *policy proposal* is normal — the budget is produced during the implementation study that follows the governance step. The purpose is to demonstrate that the approach is *architecturally sound and scalable from a teaching-led to a research-intensive institution*, not to substitute for a procurement exercise.

The standalone Technical Reference [6] provides indicative operational envelopes per layer, three reference pace options for the migration (5/7/10-year horizons), and explicit discussion of the financial-sovereignty dimension of every architectural choice.

Q9.2 — "The transition plan is too optimistic"

Institutional change at universities is notoriously slow. The proposed progressive transition may face delays due to institutional inertia.

Answer to Q9.2

The progressive structure is designed to absorb delays:

- NC State completed a governance redesign within a comparable scope [107↗];
- NSF CC* grants that fund Science DMZ deployments typically run two to three years for full deployment at a single campus [58↗];
- The governance step is primarily *commission, charters, and documents* — it does not require infrastructure procurement, the usual bottleneck.

The transition is incremental, not deadline-driven. The progressive structure ensures that delays in one step do not create systemic risk — the institution benefits incrementally from each completed step.

The alternative timeline is worse: the current state (monolithic restriction, Shadow IT,

regulatory uncertainty) does not improve with time. Every month of delay is a month of talent drain, Shadow IT risk, and missed compliance opportunities.

Q9.3 — "The economic case is asserted, not shown — the board cannot decide without figures"

This dossier asks the governing bodies to adopt the policy; the detailed, situation-specific costing would properly be commissioned from the CIO once they decide to proceed. But a board still needs an order of magnitude to take that decision — and as written the dossier gives no figures, so a CIO could note that the economic case has not been framed.

Answer to Q9.3

The detailed, situation-specific cost analysis is the CIO's to produce once the governing bodies request it; the dossier's task is to give the board a defensible order of magnitude and a cost shape, not to pre-empt that analysis.

1. **Cost shape.** The governance step (commission, charters, digital-policy commission) is *cost-neutral* — existing staff, no procurement. Cost-bearing items sit in later, optional waves (segmentation, Science DMZ, observability storage), each gated by the validated results of the prior step.
2. **A scalable benchmark.** Rather than invent a figure, the order of magnitude can be read from sector benchmarks: industry guidance places information-security spend at roughly 8–15% of the IT budget depending on threat exposure [189↗], whereas higher education currently allocates only about 3.6% [190↗]. A board can therefore size the likely envelope from its enrolment and current IT budget, and ask the CIO to refine it.
3. **Cost of inaction.** The status quo is not free: the global all-industry average data-breach cost reached $4.88M in 2024 [188↗] (the education sector below it), with talent drain and Shadow-IT exposure growing with delay.

This frames precisely the decision the dossier asks of the governing bodies — to commission a costed implementation study — with enough quantified context (a scalable percentage and a quantified downside) to make that decision defensible, while leaving the precise TCO to the CIO.

Q9.4 — "Even if it is affordable, a small IT team cannot operate a heavyweight open-source stack"

The cost objection has a sharper, operational form: the reference stack names heavyweight platforms whose day-to-day operation demands specialist staff a small or teaching-led institution does not have. Affordability of acquisition is not the same as feasibility of operation.

Answer to Q9.4

The reference stack is the research-intensive instantiation, not a mandatory floor; the architecture is defined by its functional layers and the sovereignty grid, and each layer degrades to a managed or mutualised realisation as scale decreases.

1. **Operate by responsibility, not by platform.** A down-scaled profile draws compute and storage from a national research cloud, an NREN service, or a managed provider under a data-processing agreement [6]: the institution retains sovereignty over *where* and *under what terms* data sits without operating the underlying platforms itself.
2. **Roles are not headcount.** The role inventory describes responsibilities that, in a small institution, several of which are discharged by the same person; it is not summed

into a minimum specialist team.

3. **Optional layers stay optional.** Components justified only at scale — the Science DMZ, dedicated observability storage — can be deferred entirely without weakening the rest of the architecture.

The operational burden therefore scales with the chosen instantiation, not with the architecture: a small institution adopts the same principles at a managed-service realisation it can actually run.

© SUITO

10 Questions on methodology, process and credibility

> "The important thing is not to stop questioning. Curiosity has its own reason for existing."
>
> — Albert Einstein, *LIFE Magazine*, 1955

Q10.1 — "This document is biased — it was written to support a predetermined conclusion"

The dossier reads as an advocacy document, not an objective analysis. It selects evidence that supports federation and ignores evidence that supports centralisation.

Answer to Q10.1

Every policy document has a thesis. The distinction between a biased document and a well-argued one is whether the argument is supported by evidence and whether counter-arguments are addressed.

The evidence base:

- An extensive, fully referenced bibliography with verified sources;
- multiple reference university case studies across several countries;
- Major normative frameworks (NIST, ISO, COBIT, EU regulations);
- Sector organisations (EDUCAUSE, GEANT);
- Independent sector reports (Verizon DBIR, Sophos);
- A body of court decisions and legal instruments.

Counter-arguments are addressed: the incident analysis (Q7.1, Q7.2) directly engages with the strongest evidence that could be used *against* the thesis and demonstrates that it actually supports it. The risk register honestly catalogues the risks of the proposed approach. This very module demonstrates willingness to engage with criticism.

It is worth noting that maintaining the status quo is also a policy position that benefits from the same evidence-based scrutiny. The status quo is itself a position that should be defended with evidence — not treated as the neutral default.

Q10.2 — "This is an attack on the IT department / on the security function personally"

The dossier criticises the current approach so extensively that it amounts to a vote of no confidence in the IT department's competence.

Answer to Q10.2

The dossier critiques an *approach*, not *people*. The monolithic restriction approach is common in many institutions and is often adopted in good faith by competent professionals responding to genuine threats. The argument is that a *different* approach is more effective for a *university context* — not that the IT department is incompetent.

The proposals benefit the IT department:

- *Reduced perimeter:* the IT department focuses on the administrative enclave rather than trying to manage everything;
- *End of ad hoc exceptions:* charters and the ICRADP replace informal, time-consuming negotiations;
- *Clear accountability:* departments take formal responsibility for their zones instead of

blaming central IT when things go wrong;
- *Better regulatory posture:* an evidence-producing architecture strengthens the security function's position in audits.

Policy evolution is a normal institutional process. Every institution periodically re-evaluates its approaches; this dossier is a contribution to that ongoing dialogue, not an indictment.

Q10.3 — "The document was partially written with AI tools — therefore it cannot be trusted"

The dossier acknowledges using AI tools in its composition. This undermines its credibility as a serious academic contribution.

Answer to Q10.3

This is a *genetic fallacy*: evaluating an argument by its origin rather than its content. The validity of the dossier depends on:

1. The accuracy of its factual claims (verifiable through its extensive base of cited sources);
2. The soundness of its reasoning (evaluable on its logical merits);
3. The robustness of its recommendations (assessable against established frameworks).

None of these are affected by whether the text was drafted with AI assistance, a typewriter, or a quill pen. The AI Act itself recognises this: it regulates AI *systems deployed in the real world*, not AI used as a writing tool [42↗]. LLMs produce nothing without human direction; the differentiating factor is the disciplined, review-bound workflow around the tool, not the tool itself.

Transparency: the explicit disclosure of AI-assisted composition is an act of intellectual honesty, not a weakness. Demanding disclosure and then using the disclosure to discredit the work is a rhetorical trap.

Scientific standard: the relevant question for any document is whether the claims are accurate, the sources verifiable, and the reasoning sound. These criteria apply regardless of the drafting tools used.

© SUITOAAA

11 Summary: quick-reference table

Table 22: Quick-reference summary of questions and key points

Ref.	Question (summary)	Key points
Q1.1	Segmentation increases complexity	Complexity ≠ attack surface; NIST mandates segmentation; phased rollout + SDN mitigate
Q1.2	Single perimeter = better visibility	Single firewall creates bottlenecks; per-zone monitoring gives greater total observability
Q1.3	"You just want less security"	*Ad hominem*; proposals endorsed by NIST, ISO, EDUCAUSE, and a broad set of reference universities
Q1.4	Firebreak analogy is misleading	Analogy has limits; principle stands on NIST/Verizon evidence independently
Q1.5	Zero Trust claimed but SASE/ZTNA excluded	Maps to all seven SP 800-207 tenets; SASE/ZTNA declined as a sovereignty choice, not Zero Trust
Q2.1	Federation creates accountability gaps	Charters + SOC + zone owners create *more* granular accountability
Q2.2	Departments will be irresponsible	Risk acknowledged; mitigated by charters, SOC, default-deny, isolation, audits
Q2.3	Undermines the security function's authority	COBIT/Weill-Ross: governance ≠ management; no major university gives one officer unilateral authority
Q2.4	Academics lack security expertise	Distinction between technical implementation and policy direction; every framework requires stakeholder input
Q3.1	Root access is unacceptable risk	ETH model: accountable root access + isolation is safer than shadow root access
Q3.2	Autonomy unfairly burdens researchers	Central IT still provides backbone/SOC; Data Stewards + local ISGs bridge the gap
Q3.3	Science DMZ bypasses security	Replaces firewall with ACLs + Zeek IDS; endorsed by DoE/NSF; 100+ deployments
Q3.4	Not deployed locally, so unsuitable	Appeal to absence; substrate often present; non-deployment reflects funding routes, not merit; mutualised form proposed
Q4.1	BYOD is inherently insecure	BYOD exists regardless; progressive interoperability + Zero Trust is safer than unmanaged
Q4.2	Commercial AI creates GDPR liability	Differentiated framework: adequacy or SCCs+TIA with supplementary measures, data classification, AI Act risk-based classification, traceability

Continued on next page

Ref.	Question (summary)	Key points
Q4.3	AI access is convenience, not necessity	Status-quo bias; AI is structural for research/teaching; blocking creates shadow AI
Q5.1	We are not MIT/Stanford	False equivalence; principles are scale-independent; evidence spans institutions of all sizes
Q5.2	Cherry-picked success stories	Broad set of reference universities + sector consensus (EDUCAUSE); counter-examples welcome
Q5.3	Cannot retrofit federation	NC State, Penn State, Wisconsin-Madison, Michigan deliberately transitioned to federation
Q5.4	Reversibility rests on single-vendor tests	Exit tests are cross-implementation by design; tested behaviour, not vendor promise
Q6.1	Adjustments commission creates bureaucracy	Short published deadlines; handles exceptions, not routine; formalises existing informal process
Q6.2	Commission could be misused	Structural safeguards: documented justification, proportionality, security function heard, transparency
Q6.3	Citing rights is disproportionate	Binding EU/ECHR law, not philosophy; CJEU/ECtHR case law directly applies
Q6.4	Technostress is pseudoscience	105-study systematic review (La Torre 2019); peer-reviewed in top journals
Q7.1	Recent breaches prove need for restriction	Root causes are supply chain, credentials, lack of segmentation — not openness
Q7.2	Incident analysis is biased	Interpretation aligns with Verizon DBIR, NIST, Sophos independently
Q8.1	NIS2 requires centralisation	NIS2 is requirements-based, not architecture-prescriptive; federation meets all requirements with one clock owner
Q8.2	Risk-based argument is too convenient	Applies symmetrically; state of the art is segmented architecture; EDPB/ENISA confirm
Q8.3	No GDPR lawful basis / DPIA trigger stated	Art. 6(1)(e)/(f) basis stated; Art. 35 DPIA expected; segmentation aids data minimisation
Q8.4	Bărbulescu not applied to own monitoring	Metadata-only, per-zone, disclosed monitoring satisfies the six criteria
Q8.5	NIS2 supply-chain (Art. 21(2)(d)) unowned	Attestation + procurement clauses; central assurance owner, per-zone duties
Q8.6	Data-subject rights unfulfillable when federated	Central DPO intake + per-zone retrieval duty + bounded retention + Art. 30 RoPA locator

Continued on next page

Ref.	Question (summary)	Key points
Q9.1	No concrete budget numbers	Normal for policy documents; budget produced after governance step; open-source/NREN tools minimise cost
Q9.2	Timeline is too optimistic	Phased structure absorbs delays; status quo worsens with time
Q9.3	Economic case is asserted, not shown	Cost shape + scalable benchmark (8–15% vs 3.6%) + cost of inaction frame the board decision
Q9.4	Small team cannot operate the stack	Reference stack is the high-scale instantiation; layers degrade to managed/mutualised realisations
Q10.1	Document is biased	Extensively referenced, counter-arguments addressed, risk register honest
Q10.2	Attack on the IT department	Critiques approach, not people; proposals benefit IT department
Q10.3	AI-assisted = untrustworthy	Genetic fallacy; validity depends on accuracy/reasoning, not drafting tools

12 Summary and outlook

> "The test of a first-rate intelligence is the ability to hold two opposed ideas in mind at the same time and still retain the ability to function."
>
> — F. Scott Fitzgerald, *The Crack-Up*, 1936

The systematic treatment of the frequently raised questions above supports four conclusions:

1. **No question invalidates the core thesis.** Every genuine concern (complexity, accountability, costs, feasibility) is met by a specific mechanism (phased rollout, charters, SOC oversight, open-source tooling). Some questions have partial merit and highlight implementation risks that must be managed; the risk register acknowledges these.

2. **Several questions rest on premises that, on examination, require correction or additional context.** These are addressed through clarification rather than rebuttal, and the underlying concerns are taken seriously in each case.

3. **The evidence base is robust:** an extensive, fully referenced base, multiple documented university case studies, and alignment with NIST, ISO, COBIT, the EU regulatory framework, EDUCAUSE, and independent sector reports. Engaging constructively with this evidence is the most productive path toward sound IT governance decisions.

4. **The strongest argument is convergence:** MIT, Stanford, Cambridge, Oxford, ETH Zürich, CERN, Michigan, Wisconsin-Madison, NC State, Penn State — and the 100-plus universities operating a Science DMZ — converge on segmented, federated architectures, while NIST, ISO, EDUCAUSE, GEANT, and the EU regulatory framework all support risk-based, proportionate security. When both practice and theory converge this strongly, an institution choosing a fundamentally different path should articulate the evidence supporting that alternative.

The proposals are grounded in extensive evidence, aligned with major governance frameworks, and internationally validated. Their implementation will require careful management, but they offer a robust foundation for constructive dialogue. Further questions are welcome.

© SUITOAAD

Part IV

Regulatory Applicability

1 Regulatory applicability: the invariant obligation spine

Status and scope of this module

This module records an interpretive engineering mapping between a small set of functional obligations that every modern data-and-cyber regulatory regime imposes on a university, and the SUIT control set that an institution can invoke to discharge them. It is *not* legal advice. The named instruments, authorities and deadlines are the worked instantiation of each regime as of mid-2026; an adopting institution must have its mapping reviewed by qualified counsel and by its own data-protection and information-security officers before relying on it for a compliance argument. National transpositions, sectoral overlays and funder-imposed clauses may add provisions this module does not record.

The architecture and the playbook of the SUIT suite are not designed against a regulatory checklist; they are designed against the engineering question of how a university can be sovereign at the architectural level, and they are then *read* against the regulations the institution faces. This module performs that reading at the level of the regime, not the article. Its claim is deliberately narrow and therefore transferable: across every regime we examined — and, we argue, across every regime an adopter will meet — the same short list of **functional obligations** recurs. The instruments that carry them, the competent authorities that enforce them and the exact deadlines differ by jurisdiction; the *functions* do not. That invariant list is the proof an adopter can carry from one jurisdiction to the next.

1.1 The functional-obligation spine (F1–F6)

We name the spine in role terms so that it survives translation across regimes. Each obligation is a *function the regulator requires the institution to perform*, independent of the statute that happens to require it in a given country.

F1 — Personal-data protection / security of processing.
Classify personal data and apply appropriate technical and organisational measures to protect its confidentiality, integrity and availability. This is the omnibus data-protection duty (General Data Protection Regulation (GDPR) Art. 32 in the baseline; an equivalent exists in every regime examined).

F2 — Cybersecurity risk governance.
Run a documented, risk-based information-security programme — risk analysis, accountable owner, cyber-hygiene, network and information-system security measures — attaching to the *function performed* rather than to headcount.

F3 — Incident and breach notification.
Detect security and personal-data incidents and notify the competent authority (and, where the risk is high, affected individuals) within a regime-specific deadline.

F4 — Cross-border / international data transfers.
Establish a lawful route to move personal data outside the home jurisdiction for cloud, identity, research-collaboration and AI services.

F5 — Electronic identification, trust services and AI / technology governance.
Provide trustworthy electronic identification, signatures and seals, and govern the controlled technologies the institution deploys (AI systems; export-controlled or otherwise restricted technology) under the applicable risk-based regime.

F6 — Accountability, auditable logging and conformity.
Retain auditable logs and records and be able to *demonstrate* that F1–F5 are in place — the cross-cutting evidentiary duty that makes the other five reviewable.

Why the spine is size-invariant. The spine is a **minimal necessary set**: it is the smallest collection of functions below which an institution is not compliant in *any* of the regimes examined, and it does not grow with the size of the institution. The anchor for the claim is the data-protection regime's *absence of a de-minimis threshold* for the security, accountability and breach duties: under the baseline GDPR, the only size-conditioned relief is the Art. 30(5) records-of-processing derogation below 250 persons, which is itself conditional and does not touch security, accountability or breach duties [11↗]. The cybersecurity regime attaches the same way: NIS2 scope is a function of the *service performed*, not of headcount [12↗]. A small institution therefore performs the same six functions as a large one; only the *instantiation* — the number of systems, the size of the team, the volume of logs — scales. This is the transferable core: an adopter that can show it discharges F1–F6 has shown the regulator-facing minimum, whatever its size and wherever it sits.

1.2 The obligation → mechanism matrix

The spine becomes operational when each function is mapped to the SUIT control set that contributes to discharging it. The matrix below is the size- and jurisdiction-invariant core: it is read identically in every regime, and only the *instrument* column (the local statute, authority and deadline) is substituted per jurisdiction in Section 2. The control-set references are role-based — they name architectural *capabilities*, not products — so the matrix transfers without editing.

Table 23: Obligation → mechanism matrix — the invariant core. Each functional obligation maps to the SUIT control capabilities that contribute to discharging it; only the regulatory instrument is substituted per jurisdiction.

Functional obligation	SUIT control mechanism (invariant)	What the regulator can be shown
F1 Personal-data protection / security of processing	Identity, policy, network and cryptographic-services capabilities as the technical chain enforcing access control and confidentiality; storage-placement constraints; the sovereignty-grid data dimension	A documented technical-measures chain proportionate to risk, keyed to the data classification
F2 Cybersecurity risk governance	The ISO/IEC 27005-aligned risk-analysis method; the policy and governance capabilities; network segmentation and cyber-hygiene baselines; the conformance suite as evidence of effectiveness	A risk-based, owner-accountable security programme with current risk analysis and tested controls
F3 Incident and breach notification	Observability capability (logging, monitoring, detection); the audit pipeline for timeline reconstruction; the documented incident-response procedure with a notification path	Detection-to-notification within the regime deadline, with an evidenced timeline
F4 Cross-border / international data transfers	Storage-placement and key-custody controls; the sovereignty-grid data dimension recording the disclosure-regime exposure; transfer safeguards (encryption, pseudonymisation) as supplementary measures	A lawful-transfer route with a documented transfer-risk assessment and supplementary technical measures
F5 Electronic identification, trust services and AI / technology governance	Identity and cryptographic-services capabilities (qualified signatures/seals); the technology-control and segregation patterns for restricted technology; AI-system inventory and human-oversight hooks	Trustworthy e-identification and a governed inventory of controlled technologies with oversight evidence
F6 Accountability, auditable logging and conformity	The auditable-logging and records capability; the conformance suite producing assessment artefacts; the sovereignty grid as the design-decision record	A standing evidence base demonstrating that F1–F5 are in place and reviewable on request

How to use the matrix. The left column is fixed: it is the spine of Section 1.1. The middle column is fixed: it is the SUIT capability set, named in role terms. Only the binding *instrument* changes per regime — which statute imposes F1, which authority enforces F3, what the F3 deadline is. The regime typology that follows fills exactly that variable part, regime by regime; the mapping method of Section 3 lets an adopter in an unlisted regime fill it for itself.

2 Regime typology

Regimes differ in **depth**, not in the spine they impose. A **deep** regime (here the EU and the US) carries the spine through a dense, multi-instrument stack with hard deadlines and conformity machinery; it earns a full F1–F6 table plus a worked applicability demonstration. A **light** regime (here the United Kingdom, Brazil and South Africa) carries the same spine through a more compact instrument set; it earns a concise but real F1–F6 table. The five profiles below span Europe, North America, South America and Africa. Each is one worked instantiation an adopter substitutes with its own.

2.1 European Union / EEA — deep regime (baseline anchor)

The EU/EEA is the SUIT baseline anchor: a deep, directly-applicable stack in which the spine is carried by named Regulations and a Directive, each with its own competent authority and operative deadline. The data-protection authority is each Member State's national DPA, made consistent by the European Data Protection Board; the cybersecurity authority is the national NIS2 competent authority and CSIRT, coordinated by ENISA; trust services run through the national eIDAS supervisory body; AI through national market-surveillance authorities and the European AI Office; and transfer adequacy is decided by the European Commission.

Table 24: EU/EEA — F1–F6 instantiation of the invariant spine.

Obligation	Instrument and authority	Deadline / mechanism
F1 Data protection / security of processing	GDPR Art. 32 [11↗]; national DPA, EDPB for consistency	Directly applicable since 25 May 2018; standing duty, no size threshold
F2 Cybersecurity risk governance	NIS2 Directive (EU) 2022/2555 with Implementing Regulation (EU) 2024/2690 [12↗, 43↗, 45↗]; national NIS2 competent authority / CSIRT, ENISA	Transposed by 17 Oct 2024; ten Art. 21(2) measure families (MFA, cryptography, access control, supply-chain); function-based scope
F3 Incident and breach notification	GDPR Arts. 33–34 [11↗, 44↗]; NIS2 Art. 23 reporting [12↗]; national DPA and NIS2 authority	GDPR: notify DPA without undue delay, ≤72 h; NIS2 tiered: early warning ≤24 h, full notice ≤72 h, final report ≤1 month
F4 Cross-border transfers	GDPR Chapter V: adequacy (Art. 45), SCCs (Art. 46, Decision 2021/914), EU–US DPF adequacy [11↗, 191↗, 192↗]; European Commission (adequacy), DPAs/EDPB (safeguards)	Transfer mechanism: adequacy where it exists, else SCCs + a post-*Schrems II* transfer-impact assessment and supplementary measures
F5 eID, trust and AI governance	eIDAS 2 — Reg. (EU) 910/2014 as amended by 2024/1183 [193↗]; AI Act Reg. (EU) 2024/1689 [42↗]; AI Act via national market-surveillance authorities and the European AI Office	eIDAS 2 in force 20 May 2024, EUDI Wallet by end-2026; AI Act phased: prohibited practices Feb 2025, GPAI Aug 2025, high-risk Aug 2026 (research/R&D exemptions)
F6 Accountability, logging, conformity	GDPR Arts. 5(2), 24, 30 [11↗]; NIS2 Art. 21 logging / Art. 23 reporting [12↗, 43↗]; national single-window platforms [8]	Standing: records of processing on DPA request; NIS2 logging / maturity reporting through the national reporting platform

Worked applicability demonstration (EU). Take a mid-sized research-intensive university operating only in one Member State, with no defence research and a single national campus. Does the spine apply, and at what depth? *F1* applies in full and unconditionally: the GDPR security duty has no de-minimis threshold, so the institution must run the technical-measures chain keyed to its data classification regardless of size [11↗]. *F2* applies because NIS2 scope is function-based: a university that operates its own network, identity and research-computing services performs the services that bring an entity into scope as an essential or important entity, irrespective of headcount [12↗]. *F3* therefore bites at two deadlines simultaneously — the GDPR 72-hour breach clock to the DPA and the NIS2 tiered clock (24 h / 72 h / 1 month) to the cyber authority — so the observability and incident-response capability must satisfy the *shorter* of the applicable clocks. *F4* engages the moment the institution uses a non-EEA cloud or collaborates with a third-country partner: it needs an adequacy route or SCCs plus a transfer-impact assessment [191↗, 192↗]. *F5* engages partially: eIDAS 2 governs any qualified signing/sealing of diplomas and contracts [193↗], and the AI Act engages *only* for deployed (not pure-research) AI systems, with the high-risk obligations arriving Aug 2026 [42↗]. *F6* is standing throughout: the auditable log and records capability is what lets the institution *show* the DPA and the cyber authority that F1–F5 are in place. The demonstration shows the method: walk the six functions, mark each as full / partial / conditional, and record *which* clock or mechanism

governs — the architecture's contribution is identical in each case; only the trigger and deadline are read from the instrument column.

2.2 United States — deep regime (sectoral and fragmented)

The US carries the same spine through a *sectoral and fragmented* stack: no omnibus statute, but federal sector statutes (FERPA for student records, HIPAA for health data, GLBA / FTC Safeguards for financial-aid data), federal-contracting baselines (NIST SP 800-171, CMMC, FISMA), export-control regimes (EAR, ITAR) and a growing state-privacy layer (CCPA/CPRA). Enforcement is distributed across the Department of Education, HHS Office for Civil Rights, the FTC, the DoD, Commerce/BIS, State/DDTC and state Attorneys General.

Table 25: United States — F1–F6 instantiation of the invariant spine.

Obligation	Instrument and authority	Deadline / mechanism
F1 Data protection / privacy	FERPA (20 U.S.C. §1232g; 34 C.F.R. Part 99) [194↗]; HIPAA Privacy Rule for covered health components; CCPA/CPRA as the state-law layer [195↗]; ED/SPPO, HHS OCR, state AGs	FERPA: no fixed breach deadline, administrative enforcement via funding withdrawal; CCPA/CPRA largely exempts universities except via vendors / for-profit affiliates
F2 Risk governance / written security programme	FTC Safeguards Rule (16 C.F.R. Part 314) [196↗]; HIPAA Security Rule risk analysis [197↗]; NIST CSF 2.0 (voluntary baseline) [133↗]; FTC, HHS OCR	Safeguards full-compliance 9 Jun 2023 (written programme, qualified individual, risk assessment); HIPAA risk analysis a continuing duty; Title-IV pulls in essentially all universities
F3 Incident / breach notification	HIPAA Breach Notification Rule (45 C.F.R. §§164.400–414) [198↗]; FTC Safeguards notification [196↗]; state breach statutes [195↗]; HHS OCR, FTC, state AGs	HIPAA: notify individuals and HHS ≤60 days (500+ contemporaneous); FTC: notify ≤30 days for events affecting 500+ consumers (since 13 May 2024); state timelines layer on top
F4 Cross-border transfers	Handled functionally through export control rather than a transfer-adequacy regime — see F5; CCPA/CPRA vendor flow-down for consumer data [195↗]	No EU-style adequacy list; the operative cross-border control for research data is the deemed-export regime (F5)
F5 Trust / AI / technology governance (export control)	EAR (15 C.F.R. 730–774, fundamental-research exclusion §734.8) [199↗]; ITAR (22 C.F.R. 120–130) [200↗]; Commerce/BIS, State/DDTC	Licensing + deemed-export: releasing controlled technology/technical data to foreign nationals (even on US soil) is an export; operationalised via technology-control plans and segregated environments
F6 Conformity assessment / certification	CMMC Program (32 C.F.R. Part 170) with DFARS implementation [201↗]; NIST SP 800-171 Rev. 3 as the assessed control set [15↗, 39↗, 135↗]; DoD (CMMC PMO, DIBCAC), C3PAOs	CMMC final rule effective 16 Dec 2024; DFARS clause effective 10 Nov 2025, phased over 3 years; Level 2 (CUI) requires a C3PAO assessment; artefacts retained six years

Worked applicability demonstration (US). Take the same mid-sized research university, now with a Title-IV financial-aid office, a small health clinic and one DoD-funded research project. The spine applies, but it is *assembled* from sector statutes rather than read off one instrument. *F1* is anchored by FERPA over student records [194↗]; CCPA/CPRA mostly does *not* reach the

institution directly but reaches its vendors [195↗]. *F2* is triggered the moment the institution participates in Title-IV: the FTC Safeguards Rule classifies it as a financial institution and requires the written security programme with a qualified individual [196↗]; the clinic adds the HIPAA Security Rule risk analysis [197↗]. *F3* gives the institution *two* breach clocks — HIPAA's 60-day outer limit and the FTC's 30-day / 500-consumer trigger — plus any state clock; as in the EU case, the architecture must meet the *shortest* applicable deadline [198↗]. *F4* is unusual: there is no adequacy regime, so the cross-border control that bites is the *deemed-export* concept — releasing the DoD-project's controlled technical data to a foreign-national researcher, even on campus, is an export needing a license or a technology-control plan [199↗, 200↗]. *F5* therefore *is* the cross-border control here, which is why F4 and F5 fold together in the US column. *F6* is where the US regime is most distinctive: CMMC converts the NIST SP 800-171 controls into a *contractually enforceable, third-party-assessed* certification that the DoD-funded project cannot be awarded without [135↗, 201↗]. The demonstration shows the same six functions resolving to a different instrument geometry — the spine is invariant, the assembly is sectoral.

2.3 United Kingdom — light regime (post-Brexit, diverging)

The UK carries the spine through retained-and-amended EU-derived instruments now diverging via domestic reform. The data-protection authority is the ICO (becoming the Information Commission under the Data (Use and Access) Act 2025); cyber resilience runs through the NIS Regulations 2018 with sector competent authorities and the NCSC; accessibility runs on domestic statute.

Table 26: United Kingdom — F1–F6 instantiation (light regime).

Obligation	Instrument and authority	Deadline / mechanism
F1 Data protection / security of processing	UK GDPR with the Data Protection Act 2018, amended by the Data (Use and Access) Act 2025 [202↗, 203↗, 204↗]; ICO / Information Commission	Standing security-of-processing duty (Art. 32); DUAA 2025 key provisions in force 5 Feb 2026
F2 Cyber-security risk governance	NIS Regulations 2018 (SI 2018/506); forthcoming Cyber Security and Resilience Bill [205↗, 206↗, 207↗]; sector competent authorities, ICO (RDSPs), NCSC	Risk-management duty; NCSC Cyber Assessment Framework; CSR Bill expands scope (e.g. managed service providers), not yet in force
F3 Incident / breach notification	UK GDPR Art. 33 [202↗]; NIS Regs reg. 11 [205↗]; ICO; sector competent authority / NCSC	GDPR breach to ICO $\leq$72 h; significant NIS incident to the competent authority $\leq$72 h
F4 Cross-border transfers	UK GDPR Chapter V; ICO IDTA and the UK Addendum to the EU SCCs [202↗, 204↗, 208↗]; ICO, Secretary of State (adequacy)	Adequacy where it exists, else IDTA / Addendum + a transfer-risk assessment; DUAA 2025 "not-materially-lower" data-protection test
F5 eID / trust services	UK eIDAS (retained Reg. 910/2014 as amended; SI 2016/696) [209↗]; ICO as supervisory body	Conformity / qualified-status mechanism: ICO grants/revokes qualified status with breach reporting and audits
F6 Accountability / accessibility conformity	Public Sector Bodies Accessibility Regulations 2018 (SI 2018/952), WCAG 2.1 AA / EN 301 549 [210↗, 211↗]; GDS (monitoring), EHRC (enforcement)	Standing conformance + published accessibility statement; GDS samples, EHRC may issue unlawful-act notices

2.4 Brazil — light regime (distributed federal stack)

Brazil carries the spine through a distributed federal stack with no single omnibus cybersecurity statute: the LGPD (data protection and breach notification), the national cyber strategy and federal incident-management decrees, the Inclusion Law (accessibility), the Access to Information Law (transparency) and the Federal Administrative Procedure Law (due process). Federal public universities are in scope as *autarquias / fundações públicas* of the federal public administration.

Table 27: Brazil — F1–F6 instantiation (light regime).

Obligation	Instrument and authority	Deadline / mechanism
F1 Data protection / security of processing	LGPD (Lei nº 13.709/2018), esp. Art. 46 [212↗]; ANPD	Continuous duty: technical and administrative security measures; ANPD may set minimum standards; applies to public-power controllers
F2 Cybersecurity governance / risk management	E-Ciber national cyber strategy (Decreto nº 10.222/2020) [213↗]; Marco Civil da Internet baseline [214↗]; GSI/PR	Federal bodies (incl. universities) implement strategic actions under GSI coordination; strategy-cycle instrument plus GSI normative instructions
F3 Incident / breach notification	LGPD Art. 48 operationalised by Resolução CD/ANPD nº 15/2024 [215↗]; federal cyber track via Decreto nº 10.748/2021 (CTIR.Gov) [216↗]; ANPD, GSI/PR–CTIR.Gov	Personal-data breaches: notify ANPD and subjects ≤3 business days (supplementable ≤20 business days); 5-year retention; federal cyber incidents via CTIR.Gov
F4 Cross-border transfers	LGPD international-transfer regime (Chapter V of Lei 13.709/2018) [212↗]; ANPD	Transfer on an adequacy / safeguards / consent / contractual basis; ANPD supervises (no EU-style adequacy list)
F5 Accessibility / inclusion (trust-equivalent duty)	Lei Brasileira de Inclusão (Lei nº 13.146/2015), Arts. 63 ff., operationalised by e-MAG [217↗]; MEC, Governo Digital	Standing accessibility duty assessed against e-MAG; conditions MEC course authorisation/recognition
F6 Accountability / transparency / due process	Access to Information Law (Lei nº 12.527/2011) [218↗]; Federal Administrative Procedure Law (Lei nº 9.784/1999) [219↗]; CGU, each federal body	Active + passive disclosure with statutory response deadlines; baseline procedural guarantees governing decisions arising from F1–F5

2.5 South Africa — light regime (single national jurisdiction)

South Africa carries the spine through a single national jurisdiction with no member-state transposition layer and no standalone unified Cybersecurity Act. POPIA supplies data protection, breach notification and cross-border transfer; the Cybercrimes Act supplies incident / offence reporting; the ECT Act supplies trust services; and accessibility is principle-based under the Equality Act. The African Union's Malabo Convention is regional *context* only — South Africa has signed but not ratified it, so no transfer obligation flows from it to ZA institutions [220↗].

Table 28: South Africa — F1–F6 instantiation (light regime).

Obligation	Instrument and authority	Deadline / mechanism
F1 Data protection / security of processing	POPIA (Act 4 of 2013), Condition 7, s.19 [221↗, 222↗]; Information Regulator	Continuous risk-based duty: appropriate, reasonable technical and organisational measures; no threshold / size carve-out
F2 Cyber-security risk governance	POPIA Condition 7 security safeguards read with the Cybercrimes Act baseline [221↗, 223↗]; Information Regulator, SAPS	Risk-based security duty; no standalone unified Cybersecurity Act, so the security limb is carried by POPIA
F3 Incident / breach notification	POPIA s.22 [221↗]; Cybercrimes Act s.54 (offence reporting) [223↗]; Information Regulator, SAPS	POPIA: notify Regulator and subjects as soon as reasonably possible after discovery (no hour-count); Cybercrimes Act: report qualifying offence $\leq$72 h where the university is an ECS provider
F4 Cross-border transfers	POPIA s.72 [221↗, 222↗]; Information Regulator (oversight), responsible party self-assesses adequacy	Transfer on adequate-protection / BCR / binding-agreement / consent / contractual-necessity basis; adequacy self-assessed and documented per transfer (no adequacy list)
F5 eID / trust services	ECT Act (Act 25 of 2002), ss.13 and 37–40 [224↗]; South African Accreditation Authority	Legal recognition of data messages and signatures; advanced electronic signature requires an accredited provider's certificate (rebuttable presumption of validity)
F6 Accountability / accessibility (non-discrimination)	PEPUDA / Equality Act (Act 4 of 2000), s.9 [225↗]; Equality Courts, SAHRC	Standing reasonable-accommodation duty; no dedicated web-accessibility statute, WCAG as de-facto benchmark

3 Mapping method: deriving a row for an unlisted regime

The five profiles above are worked instantiations, not an exhaustive list. An adopter in any other jurisdiction derives its own row by the same procedure: the spine of Section 1.1 is fixed, the control set of Table 23 is fixed, and only the *instrument* column has to be filled. The playbook below fills it.

Step 1 — Identify your data-protection authority and its security duty (F1).
Find the competent authority for personal data (a national DPA, a sectoral regulator, or — as in the US — several). Locate its *security-of-processing* duty and confirm whether a size/de-minimis threshold exists. In every regime examined, the security duty has *no* size exemption; treat its absence as the default and verify it explicitly. Map the duty to the F1 row of Table 23.

Step 2 — Identify your lawful-basis and risk-governance regime (F2).
Determine the lawful basis on which the institution processes personal data (public task, legitimate interest, consent) and the statute or framework that requires a documented, risk-based security programme. Where no dedicated cyber statute exists (as in Brazil or South Africa), the risk-governance duty is usually carried by the security limb of the data-protection law; record which instrument carries it.

Step 3 — Identify your breach / incident deadline (F3).
Find every applicable notification clock — the data-protection breach clock and any cyber-incident clock — and record the *shortest* one, because the observability and incident-response capability must satisfy the tightest deadline that can bite. Note both the recipient (DPA, CSIRT, police) and the trigger (risk-of-harm, affected-count, offence type).

Step 4 — Identify your essential-entity / cyber-duty status (F2/F3 scope).
Determine whether the institution falls into an essential- or important-entity (or equivalent) category, and on what basis — function-performed (as under NIS2) or sector listing. This sets the depth at which F2 and F3 apply and whether tiered (24 h / 72 h / final) reporting is in scope.

Step 5 — Identify your transfer regime (F4).
Establish how personal data may lawfully leave the jurisdiction: an adequacy-list mechanism (EU/UK style), self-assessed adequacy plus safeguards (Brazil / South Africa style), or a functional substitute such as export control (US style). Record the documented artefact the regime expects (transfer-impact assessment, binding agreement, technology-control plan).

Step 6 — Identify your sector overlays (F5/F6).
Add the sector-specific layers the institution triggers: a trust-services / eID regime for signed diplomas and contracts; an AI-governance regime for deployed AI; export / controlled-technology rules for restricted research; health, financial-aid or accessibility statutes for the relevant units. Each overlay maps to F5 (governed technology) or F6 (conformity / accountability).

Step 7 — Bind each finding to the control set.
For each of Steps 1–6, write the local instrument, authority and deadline into the instrument column against the corresponding F row, leaving the SUIT control-mechanism column of Table 23 unchanged. The result is the adopter's own regime profile in the same shape as the five worked profiles above — and the same architectural evidence base discharges it.

Closing note on transferability. The procedure terminates because the spine is finite and size-invariant: there are six functions, each maps to a fixed control capability, and the only per-jurisdiction work is reading the local instrument that carries each function. An adopter that completes Steps 1–7 has reproduced, for its own regime, the proof the five worked profiles already

carry — that discharging F1–F6 is the regulator-facing minimum, and that the SUIT control set is the same in every jurisdiction. The mapping is interpretive engineering guidance and must be confirmed against the adopter's own legal framework and counsel before being relied upon.

Part V

Pointer to the standalone Technical Reference

About this part

The architectural and migration content sketched throughout the present dossier is developed in depth in a standalone document: Sustainable University IT — A Technical Reference for Architecture and Migration *[6]. This part summarises the three foundational ideas of that document and reproduces its annotated table of contents, so that readers of this volume can locate the technical depth they may need without leaving the dossier. It is not a substitute for the standalone document; readers requiring implementation-level detail should consult the Technical Reference directly.*

The three foundational ideas of the Technical Reference

1. The sovereignty grid

The Technical Reference's normative pivot is a five-dimension grid that operationalises sovereignty in university Information Technology (IT). The five dimensions are **Data sovereignty** (where data is stored, under which jurisdiction, accessible to which actors), **Technical sovereignty** (the capacity to inspect, modify, and replace components), **Financial sovereignty** (predictable cost without captive escalation), **Operational sovereignty** (skills available locally or through trusted partners), and **Institutional sovereignty** (decision authority retained over architectural choices). Each dimension is independently scored on a four-point scale (Absent, Partial, Established, Robust); no aggregation is permitted; the grid is a deliberation instrument, not an audit scoring system.

2. The reference architecture on open foundations

The Technical Reference develops a vendor-neutral architecture organised in nine functional layers grouped in three planes: a **Subject and Trust plane** (Identity, Endpoint, Cryptographic services), an **Execution plane** (Network, Compute, Storage), and a **Control and Governance plane** (Policy, Observability, Orchestration). The architecture's normative content is the set of interface contracts (open standards) that connect the layers; products are illustrative, not prescriptive. A reference instantiation is given on open foundations (Keycloak, OPA, OpenStack, Kubernetes, Ceph, Vector, step-ca, Argo and others) to demonstrate realisability; proprietary alternatives that respect the contracts remain admissible.

3. The migration playbook for mixed estates

The Technical Reference proposes a wave-based migration playbook that takes any institution from its current brownfield position toward the target architecture. Ten waves (Wave 0 to Wave 9) unfold under a documented dependency graph. Each wave declares its goal, pre-requisites, coexistence pattern, three principal trajectories (greenfield, brownfield single-suite-centric, brownfield hybrid), reversibility criteria, and exit criteria gated by a structured conformance suite. Three indicative pace options (5-, 7-, or 10-year horizons) allow the playbook to be adapted to the institution's strategic context. Reversibility is non-negotiable: every wave is reversible at acceptable cost during a published window.

Annotated table of contents of the Technical Reference

Citation: the document's lead author, *Sustainable University IT — A Technical Reference for Architecture and Migration*, the adopting institution and its computer science research unit, May 2026 [6].

Part I — Foundations

Ch. 1 Synthesis
Self-contained executive overview of the entire Technical Reference (approximately twelve pages); the opening chapter of the standalone document.

Ch. 2 Conceptual frame
The TAC concept, end-to-end activation sequence, endpoint operating-system integration matrix, lifecycle state machine.

Ch. 3 The sovereignty grid
Full development: five dimensions, twenty indicators, scoring guidance, three worked examples on identity instantiations, common misuses, governance use.

Ch. 4 Institutional self-assessment
Self-administered diagnostic organised in five sections; produces the trajectory selection input for Part III.

Part II — Reference Architecture on Open Foundations

Ch. 5 Architectural principles
Interfaces over products; replaceability as first-class property; standards landscape table; layer decomposition.

Ch. 6 Identity and subject trust
Reference: Keycloak + System for Cross-domain Identity Management (SCIM) + eduGAIN. Alternatives: Microsoft Entra ID; Shibboleth + Keycloak hybrid.

Ch. 7 Policy decision and enforcement
Reference: Open Policy Agent (OPA) with bundle distribution and decision log. Alternatives: Cedar; native identity-provider authorisation.

Ch. 8 Network and segmentation
Reference: VLAN/VRF + FreeRADIUS + Open vSwitch + Science DMZ. Zone catalogue; discussion of SASE/ZTNA outside the reference.

Ch. 9 Compute and workload context
Reference: OpenStack + Kubernetes + Harbor + SLSA. Alternatives: VMware-based; hybrid cloud burst.

Ch. 10 Storage and data classification
Reference: Ceph + Vault + label-based access. Alternatives: NetApp + KMIP HSM; hybrid with strict Bring Your Own Key (BYOK).

Ch. 11 Endpoint management
Reference (with explicit OSS gap on iOS/Android at scale): Munki + osquery + Ansible + MicroMDM. Alternatives: Jamf + Intune; Workspace ONE.

Ch. 12 Observability and audit
Canonical TAC event schema (required and recommended fields). Reference: Vector + Kafka + OpenSearch + Loki. Alternatives: Splunk; Microsoft Sentinel.

Ch. 13 Cryptographic services
Reference: step-ca + Vault + SoftHSM or Nitrokey HSM. Alternatives: Active Directory Certificate Services + commercial HSM; external CA via ACME.

Ch. 14 Orchestration plane
The architecture's principal acknowledged gap (no single standard). Reference: Argo Workflows + Crossplane + GitOps.

Ch. 15 Sizing reference points
Indicative orders of magnitude anchored on a large research-intensive profile as one worked instantiation; FTE envelopes per layer; scaling levers and breakpoints down to the minimal functional set.

Ch. 16 Conformance and replaceability tests
Suite of conformance tests in four categories (interface fidelity, data portability, exit rehearsal, decision auditability).

Part III — Migration Playbook for Mixed Estates

Ch. 17 How to read this playbook
Vocabulary; wave dependency map; trajectory selection matrix; pace options; reversibility philosophy.

Ch. 18 Wave 0 — Foundations
Governance, baseline inventory, sovereignty grid adoption. Entry point for every trajectory.

Ch. 19 Wave 1 — Identity and federation
Dual identity-provider coexistence; per-cohort migration.

Ch. 20 Wave 2 — Observability baseline
Purely additive; collectors deployed in shadow mode before any analytical-store commitment.

Ch. 21 Wave 3 — Network segmentation
Cut-over per building, faculty or segment; Science DMZ established early.

Ch. 22 Wave 4 — Policy plane
Shadow mode mandatory before enforcing; per-policy transition.

Ch. 23 Wave 5 — TAC pilot
Three illustrative scenarios: Researcher-LLM-API; Teaching cyber-range; Compliance workspace.

Ch. 24 Wave 6 — Endpoint and posture
Posture signals advisory before enforcing; explicit OSS gap surfaced for iOS/Android.

Ch. 25 Wave 7 — TAC-aware audit and IR
Correlation across layers; refreshed incident-response runbooks.

Ch. 26 Wave 8 — Workload classification and scale-out
TAC scope extended to compute and storage workloads at scale.

Ch. 27 Wave 9 — Lifecycle automation and maturity
Self-service, GitOps, mature operational stage.

Ch. 28 Cross-cutting concerns
Change management, communication, training, risk register, financial planning, procurement.

Ch. 29 Reversibility playbook
Per-wave rollback procedures; data preservation; communication during rollback.

Ch. 30 Coexistence patterns library
AD ↔ Keycloak; SCCM ↔ Ansible; Splunk ↔ OpenSearch; VMware ↔ K8s; NetApp ↔ Ceph; eduroam ↔ TAC-aware Wi-Fi.

Part IV — References and Operational Material

Ch. 31 Institutional precedents
Public-documentation review of identified university IT architectures (CERN, MIT, Stanford, ETH Zürich, Cambridge, Indiana, NUS Singapore, USP Brazil, Michigan, KU Leuven, Oxford, ANU Australia, Tsinghua, UNAM Mexico, Toronto and others).

Ch. 32 External references and standards
NIST publications, ISO/IEC, EU regulatory framework, sector publications, open-source specifications.

Ch. 33 Regulatory mapping
Interpretive mapping of the architecture contracts and migration waves to the regulations most likely to apply to a research-intensive university, organised by regulation and by article or control as one worked EU instantiation (GDPR, NIS2, EU AI Act, the applicable cross-border data-transfer regime, NIST CSF 2.0, eIDAS 2, ISO/IEC 27001/27002/27005, COBIT 2019). The chapter folds into the shared Regulatory Applicability annex (Part IV of this dossier), whose size- and jurisdiction-invariant obligation → mechanism matrix is the shared anchor for the Policy ↔ Solution traceability.

© SUITOAAD

Glossary of Acronyms and Key Terms

Technical Infrastructure

ACL Access Control List — a set of rules on a network device that permits or denies traffic based on source/destination addresses and ports.

API Application Programming Interface — a standardised interface allowing software systems to communicate with each other.

BYOD Bring Your Own Device — the practice of employees or students using personal devices to access institutional resources.

DHCP Dynamic Host Configuration Protocol — automatically assigns IP addresses to devices on a network.

DMZ Demilitarised Zone — a network segment between an internal network and the Internet, hosting externally accessible services.

DNS Domain Name System — translates human-readable domain names into IP addresses.

DPI Deep Packet Inspection — a method of examining the content of network packets as they pass through a checkpoint.

DTN Data Transfer Node — a server optimised for high-throughput scientific data transfers in a Science DMZ.

EDR Endpoint Detection and Response — security software monitoring endpoints for threats.

HPC High-Performance Computing — computing systems designed for large-scale scientific simulations and data processing.

IAM Identity and Access Management — systems and processes for managing digital identities and controlling access to resources.

IDS Intrusion Detection System — monitors network traffic for suspicious activity (detection only, no inline blocking).

IPS Intrusion Prevention System — monitors and actively blocks detected threats inline.

LMS Learning Management System — platform for delivering and managing educational content (e.g. Moodle).

MFA Multi-Factor Authentication — requiring two or more verification factors to access a resource.

NAC Network Access Control — system enforcing authentication, device posture assessment, and dynamic VLAN assignment at the network edge (e.g. PacketFence, Cisco ISE).

PKI Public Key Infrastructure — framework for managing digital certificates and encryption keys.

RBAC Role-Based Access Control — access permissions assigned to roles rather than to individual users.

Science DMZ Science Demilitarised Zone — a network architecture pattern developed by ESnet for high-performance scientific data transfers, bypassing enterprise firewalls in favour of ACLs and dedicated IDS.

SDN Software-Defined Networking — centralised, programmable control of network behaviour.

SIEM Security Information and Event Management — centralised platform for collecting and analysing security logs and alerts.

SOC Security Operations Centre — team and facility responsible for monitoring and responding to security incidents.

SSO Single Sign-On — authentication allowing access to multiple systems with one set of credentials.

© SUITOAAA

TAC Trusted Activity Context — a coherent, validated environment assembling data, tools, services, and access rights for a specific university activity (concept introduced in this report).

VDI Virtual Desktop Infrastructure — technology delivering desktop environments from a centralised server to any device.

VLAN Virtual Local Area Network — a logical subdivision of a physical network, isolating traffic between groups of devices.

VPN Virtual Private Network — encrypted tunnel for secure remote connectivity.

Governance Frameworks and Standards

ABAC Attribute-Based Access Control — access decisions based on attributes of the user, resource, and environment (NIST SP 800-162).

COBIT Control Objectives for Information and Related Technologies — Control Objectives for Information and Related Technologies, IT governance framework by ISACA distinguishing governance from management.

FAIR Factor Analysis of Information Risk — Factor Analysis of Information Risk, a quantitative methodology for assessing and managing information risk.

ISMS Information Security Management System — the set of policies and procedures for systematically managing security (ISO 27001).

Zero Trust Zero Trust architecture — security model based on never trust, always verify; access decisions based on identity and device posture rather than network location (NIST SP 800-207).

European Regulations and Legal Instruments

AI Act European AI Act — Regulation (EU) 2024/1689 on artificial intelligence, risk-based classification of AI systems.

CJEU Court of Justice of the European Union — the EU highest court, interpreting EU law.

DPO Data Protection Officer — person responsible for overseeing GDPR compliance within an organisation.

ECtHR European Court of Human Rights — court enforcing the ECHR, based in Strasbourg.

EDPB European Data Protection Board — EU body ensuring consistent application of the GDPR.

EDPS European Data Protection Supervisor — independent EU authority overseeing the application of GDPR by EU institutions and bodies (distinct from the EDPB which coordinates national DPAs).

ENISA European Union Agency for Cybersecurity — European Union Agency for Cybersecurity.

GDPR General Data Protection Regulation — General Data Protection Regulation (EU) 2016/679 – EU regulation on the protection of personal data.

ICRADP Independent Commission for Reasonable Adjustments of Digital Policies — Independent Commission for Reasonable Adjustments of Digital Policies (proposed in this report; French: CARPN).

NIS2 NIS2 Directive — NIS2 Directive (EU) 2022/2555 – directive on measures for a high common level of cybersecurity.

Cross-border Data Transfers

SCC Standard Contractual Clauses — pre-approved European Commission contractual clauses for transfers of personal data outside the EEA; valid under Schrems II only when supplemented by a Transfer Impact Assessment and supplementary measures.

TIA Transfer Impact Assessment — documented assessment of whether a third country offers a level of personal-data protection essentially equivalent to EU law, required by CJEU Schrems II for transfers outside the EEA when relying on Standard Contractual Clauses.

© SUITOAAA

Sovereignty Grid and Technical Reference Vocabulary

BYOK Bring Your Own Key — a key-management arrangement in which the customer generates and provides the encryption keys used by a third-party service, retaining custody and rotation control.

HYOK Hold Your Own Key — an arrangement stronger than BYOK in which the customer retains the keys in their own infrastructure (typically an HSM) and the service never has cleartext access; cryptographic operations require live customer participation.

IoT Internet of Things — networked devices typically embedded in physical objects (sensors, controllers, lab instruments) with limited or no user interface and constrained security update mechanisms.

IT Information Technology — the systems, software, networks and processes used to store, manipulate and transmit institutional information.

OPA Open Policy Agent — CNCF graduated open-source policy decision engine using the Rego language; widely adopted as a general-purpose authorisation and admission-control PDP.

PDP Policy Decision Point — the component that evaluates a request against the policy corpus and returns a decision; distinct from the Policy Enforcement Point (PEP) that applies the decision.

PEP Policy Enforcement Point — the component that intercepts an access request, queries the PDP, and applies the returned decision (allow/deny plus obligations).

RFP Request for Proposal — a procurement document issued by an institution to solicit proposals from suppliers, specifying functional, technical, and contractual requirements.

SCIM System for Cross-domain Identity Management — IETF standard (RFC 7643/7644) for automating the exchange of user identity information between identity domains.

TLS Transport Layer Security — IETF cryptographic protocol (RFC 8446 for TLS 1.3) providing confidentiality and integrity for network communications; the foundation of HTTPS.

Research Networks and Organisations

CSIRT Computer Security Incident Response Team — team responsible for detecting, analysing, and responding to cybersecurity incidents.

eduGAIN eduGAIN interfederation service — global interfederation service connecting identity federations, enabling cross-institutional single sign-on.

eduroam Education Roaming — Education Roaming, federated Wi-Fi service allowing users to connect at any participating institution worldwide using their home credentials.

FIRST Forum of Incident Response and Security Teams — Forum of Incident Response and Security Teams, global network of CSIRTs facilitating coordination across national and sectoral incident-response teams.

GEANT GEANT pan-European research network — pan-European backbone network connecting 40+ NRENs, serving 50 million users in 10,000+ institutions.

NREN National Research and Education Network — a specialised ISP dedicated to supporting research and education (each country operates one).

© SUITO

Bibliography

[1] Nicolas Guelfi et al. *SUIT — Sustainable University IT Infrastructure & Technology*. SUIT Working Group reference document suite. Reference document suite of the SUIT Working Group, chaired by Nicolas Guelfi. Always-living document. 2026. URL: https://github.com/suit-working-group/suit-suite.

[2] *Magna Charta Universitatum*. Bologne, 18 septembre 1988 (révisée 2020) — For university IT governance, the MCU 2020 provides the principled foundation for institutional independence in digital infrastructure decisions, protection of academic freedom in digital environments, and ethical frameworks for technology deployment. 1988. URL: https://www.magna-charta.org/magna-charta-universitatum/mcu2020.

[3] BleepingComputer. *European supercomputers hacked in mysterious cyberattacks*. May 2020 coordinated intrusion campaign against European HPC centres (ARCHER at Edinburgh, several bwHPC clusters, HLRS Stuttgart, and the Swiss National Supercomputing Centre (CSCS), operated by ETH Zurich). Investigated by the EGI-CSIRT. 2020. URL: https://www.bleepingcomputer.com/news/security/european-supercomputers-hacked-in-mysterious-cyberattacks/.

[4] National competent authority. *Classification of a research university as an essential entity under the NIS2 Directive transposition*. Cited as an illustrative essential-entity determination under the NIS2 directive baseline; the supervisory authority and classification instrument vary by jurisdiction. 2026.

[5] National legislature. *National law transposing Directive (EU) 2022/2555 (NIS2) into domestic law*. Illustrative national transposition of the NIS2 directive baseline; an adopting institution substitutes the equivalent instrument and supervisory authority of its own jurisdiction. 2024.

[6] Nicolas Guelfi. *Sustainable University IT — A Technical Reference for Architecture and Migration*. Technical reference and migration playbook. First version created by Nicolas Guelfi, Chairman of the SUIT Working Group. Companion technical document to the report *Infrastructure and Organisation of Information Systems for a Research University*. Always-living document; version 2.1, May 2026. SUIT Working Group, 2026.

[7] CJUE (Grande Chambre). *Data Protection Commissioner c. Facebook Ireland et Schrems*. Aff. C-311/18, 16 juillet 2020 — This decision profoundly impacts university IT infrastructure, requiring institutions to reassess all data transfers to third countries, particularly when using US-based cloud computing platforms, learning management systems, and research collaboration tools. 2020. URL: https://curia.europa.eu/juris/liste.jsf?num=C-311/18.

[8] National competent authority. *National single-window cybersecurity risk-management and reporting platform*. 2026.

[9] Jisc. *Cyber Security Guidance for Boards and Senior Leaders in Higher Education*. Written by David Batho, Jisc's Director of Security. Directly addresses how university leadership should approach cybersecurity oversight and institutional defense strategies as a board-level priority, drawing from the Association of Colleges Governance Professionals Conference. 2024. URL: https://www.jisc.ac.uk/blog/cyber-resilience-a-strategic-board-level-priority.

[10] Bruce Schneier. *Secrets and Lies: Digital Security in a Networked World*. Foundational book on digital security covering security technologies, their limitations, and practical risk management strategies for digitally-dependent organizations. Widely cited in cybersecurity policy discussions; relevant to university IT security governance and infrastructure protection planning. Wiley, 2000. ISBN: 978-0-471-45380-2. URL: https://www.schneier.com/books/secrets-and-lies/.

[11] *Règlement (UE) 2016/679 du Parlement européen et du Conseil relatif à la protection des personnes physiques à l'égard du traitement des données à caractère personnel (RGPD)*. Article 32 : Sécurité du traitement — The GDPR imposes compliance requirements on student and employee data handling, research data management, cybersecurity incident response protocols, and IT infrastructure standards. Article 32 specifically mandates appropriate technical and organizational security measures. 2016. URL: https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32016R0679.

[12] *Directive (UE) 2022/2555 du Parlement européen et du Conseil concernant des mesures destinées à assurer un niveau élevé commun de cybersécurité dans l'ensemble de l'Union (NIS2)*. Universities operating data centers, cloud services, or critical research networks may fall within the directive's scope, requiring them to structure cybersecurity governance and risk management in compliance with its provisions. 2022. URL: https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32022L2555.

[13] GEANT. *Shadow IT in Research and Education: What to Look Out For*. 2022. URL: https://connect.geant.org/2022/10/31/shadow-it-in-research-and-education-what-to-look-out-for.

[14] Auvik. *Shadow IT Statistics and Projections (Gartner data compiled by Auvik)*. Gartner survey data compiled by Auvik. 41% of employees acquired technology outside IT visibility in 2022; projected 75% by 2027. 2023. URL: https://www.auvik.com/franklyit/blog/shadow-it-stats/.

[15] NIST. *Security and Privacy Controls for Information Systems and Organizations*. Tech. rep. NIST SP 800-53 Rev. 5. For academic institutions, adopting these controls strengthens cybersecurity posture while meeting requirements under the Federal Information Security Modernization Act (FISMA) and other regulatory mandates that apply to federally-funded research operations. National Institute of Standards and Technology, 2020. DOI: 10.6028/NIST.SP.800-53r5. URL: https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final.

[16] ISO/IEC. *ISO/IEC 27001:2022 — Information Security, Cybersecurity and Privacy Protection — Information Security Management Systems — Requirements*. ISO/IEC 27001:2022 is the world's best-known standard for information security management systems (ISMS). For universities, it provides a comprehensive framework for managing information security risks across IT infrastructure, research data, and institutional operations. The 2022 revision updates the standard to address emerging threats in cloud security and data privacy. 2022. URL: https://www.iso.org/standard/27001.

[17] ETH Zurich. *IT Baseline Protection Rules*. ETH Zurich Informatikdienste. Description derived from ETH Zurich Staffnet and ITS Blog announcements (direct PDF not parseable). — AI-generated contextual summary: these baseline protection rules are a foundational element of ETH Zurich's cybersecurity governance, ensuring a consistent minimum security posture across diverse departmental IT infrastructures through mandatory standards for system configuration, access control, and data protection. URL: https://ethz.ch/content/dam/ethz/main/eth-zurich/organisation/rechtssammlung/203.23en.pdf.

[18] University of Oxford. *Information Security — Policy Framework and Governance*. University of Oxford Information Security. Original description extracted from infosec.ox.ac.uk/guidance-policy. — AI-generated contextual summary: the resource functions as the institutional backbone for ensuring consistent security practices across Oxford's collegiate structure, outlining how security accountability flows through divisional and departmental leadership. URL: https://www.infosec.ox.ac.uk/guidance-policy.

[19] Verizon Business. *2024 Data Breach Investigations Report*. Verizon. Comprehensive annual analysis of cybersecurity incidents and data breaches across multiple industry sectors, including education. Draws on thousands of real-world incidents, identifies prevailing attack patterns, threat actor profiles, and vulnerability exploitation trends. Findings on ransomware prevalence, credential theft, and social engineering are directly applicable to university cybersecurity governance and risk management strategies. 2024. URL: https://www.verizon.com/business/resources/reports/dbir.html.

[20] Lois Brooks. *Working Smarter Together through Modernization & Federation*. UW-Madison IT — CIO Blog. Original description extracted from it.wisc.edu CIO blog post. — AI-generated contextual summary: the piece emphasizes that effective IT modernization depends on prioritizing collaboration, professional development, and people-centered governance to support the university's diverse academic and research missions while reducing cybersecurity risks and administrative costs. URL: https://it.wisc.edu/lois-brooks-cio-blog/working-smarter-together-through-modernization-and-federation/.

[21] ETH Zurich, D-INFK. *Agreement Regarding Administrator Rights*. ISG D-INFK, ETH Zurich. Original description extracted from isg.inf.ethz.ch/Main/AboutUsDocuments. — AI-generated contextual summary: these documents establish governance frameworks for institutional IT infrastructure usage, acceptable conduct, and system maintenance protocols, directly supporting institutional compliance and proper stewardship of departmental computing resources. URL: https://www.isg.inf.ethz.ch/Main/AboutUsDocuments.

[22] CloudLab. *Flexible, Scientific Infrastructure for Research*. Original description extracted from cloudlab.us. — AI-generated contextual summary: the facility supports transformative research across cloud computing, distributed systems, networking, databases, and security, designed for experiments requiring control and visibility over system components typically unavailable in traditional cloud environments. URL: https://www.cloudlab.us/.

[23] Chameleon. *A Configurable Experimental Environment for Large-Scale Cloud Research*. Original description extracted from chameleoncloud.org. — AI-generated contextual summary: the platform serves as a testbed supporting researchers in AI, machine learning, and high-performance computing, making it relevant to universities seeking flexible research computing infrastructure. URL: https://www.chameleoncloud.org/.

[24] Jupyter Project. *Zero to JupyterHub with Kubernetes*. Original description extracted from z2jh.jupyter.org. — AI-generated contextual summary: for university IT, it offers a blueprint for managing shared computational resources across Kubernetes clusters while supporting large user populations in a cost-effective manner. URL: https://z2jh.jupyter.org/.

[25] NIST / NICE. *NICE Cyber Range Guidance*. National Initiative for Cybersecurity Education. Voir aussi NIST SP 800-181 Rev. 1 (NICE Workforce Framework for Cybersecurity). The guide supports the development of cybersecurity training programs aligned with the NICE Workforce Framework, helping university institutions build competencies needed to protect academic networks and sensitive research data. 2020. URL: https://www.nist.gov/document/cyber-range.

[26] Klaas Wierenga and Licia Florio. "eduroam: Past, Present and Future". In: *Computational Methods in Science and Technology* 11.2 (2005). Last consulted 15 February 2026. Foundational component of modern university IT infrastructure, establishing the concepts and protocols for secure roaming services. eduroam now spans over 100 countries and is a key element of federated identity management for academic institutions., pp. 169–173. DOI: 10.12921/cmst.2005.11.02.169-173. URL: https://cmst.eu/articles/eduroam-past-present-and-future/.

[27] Benjamin Franklin. *Letter to the Governor from the Pennsylvania Assembly*. 11 November 1755. — Upon learning of Indian attacks at Penn's Creek and other places in the Susquehanna Valley, Governor Morris summoned the Assembly for Nov. 3, 1755. The Assembly's reply, drafted by a committee including Benjamin Franklin, defends their dual approach of investigating the causes of Native American defection to the French while simultaneously offering $60 000 for defense, and critiques the Governor's repeated rejection of supply bills. Contains the famous quotation: "Those who would give up essential Liberty, to purchase a little temporary Safety, deserve neither Liberty nor Safety." As an epigraph, it underscores the tension between security measures and fundamental freedoms. 1755. URL: https://founders.archives.gov/documents/Franklin/01-06-02-0107.

[28] *Shadow IT in Higher Education: Survey and Case Study*. Tech. rep. Highlights the tension between academic freedom and institutional cybersecurity controls, offering recommendations for managing shadow IT in decentralized campus settings. UMBC Center for Information Security and Assurance (CISA), 2021. URL: https://cisa.umbc.edu/shadow-it-in-higher-education-survey-and-case-study-for-cybersecurity/.

[29] Eli Dart, Lauren Rotman, Brian Tierney, Mary Hester, and Jason Zurawski. "The Science DMZ: A Network Design Pattern for Data-Intensive Science". In: *Proceedings of the International Conference for High Performance Computing, Networking, Storage and Analysis (SC'13)*. Last consulted 15 February 2026. Introduces the Science DMZ network design pattern for data-intensive scientific workflows. Developed at ESnet and widely adopted by universities and research laboratories as a reference architecture for segregating high-performance research traffic from enterprise networks. ACM, 2013. DOI: 10.1145/2503210.2503245. URL: https://dl.acm.org/doi/10.1145/2503210.2503245.

[30] ThreatLocker. *The Risks Associated with Shadow IT*. Blog post predicting that 75 percent of employees will engage in shadow IT by 2027. Cites average data breach costs of 4.88 million dollars. Proposes solutions including application allowlisting and containment tools to detect and prevent unauthorized software deployment, relevant to university environments where decentralized technology adoption can undermine institutional security controls. 2025. URL: https://www.threatlocker.com/blog/the-risks-associated-with-shadow-it.

[31] Stefan Klotz, Andreas Kopper, Markus Westner, and Susanne Strahringer. "IT Governance Revisited: The Promising Role of Shadow IT". In: *International Journal of Information Systems and Project Management* 7.1 (2019). URL: https://aisel.aisnet.org/ijispm/vol7/iss1/3/.

[32] Mario Silic and Andrea Back. "Shadow IT — A View from Behind the Curtain". In: *Computers & Security* 45 (2014), pp. 274–283. DOI: 10.1016/j.cose.2014.06.007.

[33] Gabriela L. Mallmann, Antonio Carlos Gastaud Macada, and Mirian Oliveira. "The influence of shadow IT usage on knowledge sharing: An exploratory study with IT users". In: *Business Information Review* 35.1 (2018), pp. 17–28. DOI: 10.1177/0266382118760143.

[34] Algirdas Avizienis, Jean-Claude Laprie, Brian Randell, and Carl Landwehr. "Basic Concepts and Taxonomy of Dependable and Secure Computing". In: *IEEE Transactions on Dependable and Secure Computing* 1.1 (2004). Seminal taxonomy paper that formalises dependability as an integrating concept encompassing availability, reliability, safety, integrity, maintainability, and security. Introduces the orthogonal classification of threats (faults, errors, failures), attributes, and means (prevention, tolerance, removal, forecasting)., pp. 11–33. DOI: 10.1109/TDSC.2004.2. URL: https://ieeexplore.ieee.org/document/1335465.

[35] Patrizio Pelliccione, Henry Muccini, Nicolas Guelfi, and Alexander Romanovsky. *Software Engineering of Fault Tolerant Systems*. Series on Software Engineering and Knowledge Engineering. World Scientific, 2007. ISBN: 9789812705037. URL: https://books.google.lu/books?id=kudoDQAAQBAJ.

[36] Ron Ross, Victoria Pillitteri, Richard Graubart, Deborah Bodeau, and Rosalie McQuaid. *Developing Cyber-Resilient Systems: A Systems Security Engineering Approach*. Tech. rep. NIST SP 800-160 Vol. 2 Rev. 1. Fourteen cyber-resiliency techniques including segmentation. Foundational reference for university IT architecture resilience. National Institute of Standards and Technology, 2021. DOI: 10.6028/NIST.SP.800-160v2r1. URL: https://csrc.nist.gov/publications/detail/sp/800-160/vol-2-rev-1/final.

[37] Vincent C. Hu, David Ferraiolo, Rick Kuhn, Adam Schnitzer, Kenneth Sandlin, Robert Miller, and Karen Scarfone. *Guide to Attribute Based Access Control (ABAC) Definition and Considerations*. Tech. rep. NIST SP 800-162. Defines ABAC as the access control methodology where decisions are based on subject, object, action, and environment attributes evaluated against policies. National Institute of Standards and Technology, 2014. DOI: 10.6028/NIST.SP.800-162. URL: https://csrc.nist.gov/publications/detail/sp/800-162/final.

[38] Ravi S. Sandhu, Edward J. Coyne, Hal L. Feinstein, and Charles E. Youman. "Role-Based Access Control Models". In: *Computer* 29.2 (1996). Defines RBAC0-RBAC3 and session-based role activation. Foundational reference for the contextual role management concept in this report., pp. 38–47. DOI: 10.1109/2.485845. URL: https://ieeexplore.ieee.org/document/485845.

[39] NIST. *Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations*. Tech. rep. NIST SP 800-171 Rev. 2. For universities, compliance with SP 800-171 is often mandatory when handling federal research data, participating in government contracts, or maintaining systems processing sensitive government information in defense-related projects. National Institute of Standards and Technology, 2020. DOI: 10.6028/NIST.SP.800-171r2. URL: https://csrc.nist.gov/publications/detail/sp/800-171/rev-2/final.

[40] Roshan K. Thomas and Ravi S. Sandhu. "Task-Based Authorization Controls (TBAC): A Family of Models for Active and Enterprise-Oriented Authorization Management". In: *Proceedings of the IFIP WG11.3 Workshop on Database Security*. Foundational paper introducing the concept of tying authorization to task lifecycles rather than static role assignments. Directly relevant to the Trusted Activity Context concept. 1997, pp. 166–181. URL: https://profsandhu.com/journals/tissec/p113-thomas.pdf.

[41] Baron de Montesquieu Charles de Secondat. *De l'Esprit des Lois*. Book XXIX, Chapter 16. — This is volume 1 from the Complete Works. The Spirit of Laws is Montesquieu's best known work in which he reflects on the influence of climate on society, the separation of political powers, and the need for checks on a powerful executive office. The work's framework of checks and balances is conceptually applicable to the governance of university IT infrastructure, where separation of duties and distributed authority are key principles. Geneva: Barillot & Fils, 1748. URL: https://oll.libertyfund.org/titles/montesquieu-complete-works-vol-1-the-spirit-of-laws.

[42] *Regulation (EU) 2024/1689 of the European Parliament and of the Council laying down harmonised rules on artificial intelligence (Artificial Intelligence Act)*. OJ L, 12 July 2024. Articles 2(6), 2(8): exemptions for scientific research and R&D — This regulation requires institutions deploying AI in education, admissions, or research to conduct conformity assessments, maintain documentation, and ensure human oversight while benefiting from research exemptions. 2024. URL: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32024R1689.

[43] European Commission. *Commission Implementing Regulation (EU) 2024/2690 of 17 October 2024 laying down rules for the application of Directive (EU) 2022/2555 (NIS2) regarding technical and methodological requirements for cybersecurity risk-management measures*. 2024. URL: https://eur-lex.europa.eu/eli/reg_impl/2024/2690/oj.

[44] EDPB. *Guidelines on Security of Processing under GDPR*. European Data Protection Board. The EDPB page is a filterable directory for guidelines, recommendations, and enforcement decisions related to GDPR Article 32 on the security of personal data processing. It serves as a hub for guidance documents that help organizations understand and implement appropriate technical and organizational measures to protect personal data. For universities handling research data, student records, and employee information, these guidelines are essential for establishing compliant data security policies and cybersecurity obligations under EU law. URL: https://www.edpb.europa.eu/gdpr-articles/article-32-security-processing_en.

[45] ENISA. *Risk-Based Approach to Data Processing Security*. European Union Agency for Cybersecurity. Although originally targeting SMEs, the guidelines are broadly applicable to any organization subject to GDPR requirements. For universities managing sensitive research and student data, it provides actionable guidance for developing appropriate security measures that balance risk mitigation with operational constraints. URL: https://www.enisa.europa.eu/publications/guidelines-for-smes-on-the-security-of-personal-data-processing.

[46] Clark Kerr. *The Uses of the University*. Landmark work in higher education studies that introduced the concept of the "multiversity" — the modern research university as a complex institution serving multiple, sometimes conflicting constituencies including students, faculty, government, and industry. Kerr analyzed the governance challenges arising from institutional complexity, including the tension between centralized administration and academic autonomy. Foundational for understanding how IT infrastructure and policy

decisions are made in large, decentralized academic institutions. Cambridge, MA: Harvard University Press, 1963. ISBN: 978-0-674-00532-1. URL: https://www.hup.harvard.edu/books/9780674005327.

[47] UNESCO. *Recommendation on Open Science*. Adopted by the UNESCO General Conference at its 41st session, Paris, 23 November 2021 — The recommendation addresses investments in digital infrastructures, cybersecurity considerations for data protection, and governance structures for managing research outputs, all directly relevant to university IT policy and academic governance. 2021. URL: https://www.unesco.org/en/legal-affairs/recommendation-open-science.

[48] Open Knowledge Foundation. *The Open Definition 2.1*. Open Definition Website. Consulté le 12 février 2026. — For academic institutions, this definition provides standardized criteria for evaluating open-source software, licensing compliance, and data management practices, guiding university policies on transparency and knowledge accessibility. 2015. URL: https://opendefinition.org/od/2.1/en/.

[49] Tim Berners-Lee. *Linked Data - Design Issues*. W3C Website. World Wide Web Consortium (W3C). Consulté le 12 février 2026. — Introduces the four principles of Linked Data: using URIs to name things, using HTTP URIs for lookup, serving useful information via RDF standards at those URIs, and including links to other data sources. For university IT infrastructure, these principles underpin institutional open data initiatives, research data interoperability, and semantic web-based knowledge management systems. 2006. URL: https://www.w3.org/DesignIssues/LinkedData.html.

[50] Mark D. Wilkinson, Michel Dumontier, Barend Mons, et al. "The FAIR Guiding Principles for Scientific Data Management and Stewardship". In: *Scientific Data* 3 (2016). Last consulted 15 February 2026. The FAIR framework has become a foundational reference for university research data governance, institutional repository design, and open science policies across higher education., p. 160018. DOI: 10.1038/sdata.2016.18. URL: https://www.nature.com/articles/sdata201618.

[51] Sun Tzu. *The Art of War*. Translated by Lionel Giles. — Ancient Chinese military treatise from the 5th–6th century BC, composed of 13 chapters exploring military strategy, tactics, intelligence operations, and the art of warfare. For nearly 1 500 years it served as the lead text in China's Seven Military Classics. As an epigraph, its strategic principles are metaphorically applicable to cybersecurity defense planning and institutional risk management in university IT governance. London: Luzac & Co., 1910. URL: https://www.gutenberg.org/ebooks/132.

[52] GÉANT. *GÉANT — Pan-European Research and Education Network*. Original description extracted from about.geant.org/about/ (main site blocks bots with 403). — AI-generated contextual summary: GÉANT provides critical infrastructure for university IT connectivity, cybersecurity collaboration, and international academic research networking, enabling European researchers to lead international collaboration. URL: https://geant.org.

[53] Edoardo Martelli and Simone Stancu. "LHCOPN and LHCONE: Status and Future Evolution". In: *Journal of Physics: Conference Series* 664.5 (2015). Last consulted 15 February 2026. Describes two major networking infrastructures supporting CERN's LHC data transfer operations. Directly relevant to universities participating in large-scale scientific computing collaborations and managing high-bandwidth research network connectivity through NRENs., p. 052025. DOI: 10.1088/1742-6596/664/5/052025. URL: https://iopscience.iop.org/article/10.1088/1742-6596/664/5/052025.

[54] University of Chicago. *Globus — Research Data Management*. Original description extracted from globus.org. — AI-generated contextual summary: the service addresses critical university IT infrastructure needs around managing distributed research data while maintaining security and access control through campus authentication systems, so researchers can focus on their work rather than managing data transfer challenges. URL: https://www.globus.org/.

[55] *perfSONAR — Network Measurement Toolkit*. Original description extracted from perfsonar.net. — AI-generated contextual summary: the global infrastructure assists engineering teams in troubleshooting and helps increase productivity when utilizing network resources, making it particularly valuable for universities managing complex research and educational networks. URL: https://www.perfsonar.net/.

[56] *Zeek (formerly Bro) — Network Security Monitor*. Original description extracted from docs.zeek.org/en/master/about.html (homepage dynamically rendered). — AI-generated contextual summary: Zeek is particularly relevant to university IT infrastructure as it enables institutions to monitor network activity, detect intrusions, and maintain situational awareness across campus networks. URL: https://zeek.org/.

[57] ESnet. *Science DMZ: Breaking Down Data Barriers, Speeding up Science*. Energy Sciences Network. ESnet has been a pioneer in high-performance networking, contributing to the development of internet protocols, data management architecture, and software-defined networking. For academic institutions, ESnet's Science DMZ model and networking innovations offer relevant blueprints for optimizing large-scale research data transfers. URL: https://www.es.net/about/esnet-history/.

[58] NSF. *Campus Cyberinfrastructure (CC*) Program*. National Science Foundation. Original description extracted from nsf.gov/funding/opportunities/cc-campus-cyberinfrastructure. — AI-generated contextual summary: this funding initiative directly supports university IT modernization by addressing disparities in cyber-connectivity and emphasizing science-driven infrastructure needs to enhance institutional competitiveness. URL: https://www.nsf.gov/funding/opportunities/cc-campus-cyberinfrastructure.

[59] ESnet. *Science DMZ at the University of Florida*. Energy Sciences Network — Science DMZ Case Studies. Single-institution case (University of Florida, CMS Tier-2). Source of the 20x / 200 Gbps figures used in the suite. URL: https://www.es.net/science-engagement/knowledge-base/case-studies/science-dmz-case-studies/science-dmz-at-the-university-of-florida/.

[60] ESnet. *Science DMZ Implemented at CU Boulder*. Energy Sciences Network — Science DMZ Case Studies. Single-institution case (CU Boulder, RCNet "Core Split"). Source of the Core-Split architecture description used in the suite. URL: https://www.es.net/science-engagement/knowledge-base/case-studies/science-dmz-case-studies/science-dmz-implemented-at-cu-boulder/.

[61] ESnet. *Science DMZ for Pennsylvania State University and Virginia Tech Transportation Institute*. Energy Sciences Network — Science DMZ Case Studies. Single-institution case (Penn State College of Engineering / VTTI). Source of the 50 Mbps -> 5x/ 12x figures used in the suite. The degradation is a single documented case, not a general property of stateful firewalls. URL: https://www.es.net/science-engagement/knowledge-base/case-studies/science-dmz-case-studies/science-dmz-for-pennsylvania-state-university-and-virginia-tech-transportation-institute/.

[62] University of Michigan. *Science DMZ*. ITS, University of Michigan. Site blocks bots with HTTP 403; no original description recoverable. — AI-generated contextual summary: the University of Michigan Science DMZ is a dedicated network infrastructure segment designed to support high-performance data transfer for research applications. A Science DMZ separates research traffic from general campus network traffic, providing a friction-free, high-bandwidth path optimized for large-scale scientific data flows between campus researchers and external collaborators. This demonstrates how institutions can accommodate specialized research computing needs while maintaining security on the broader campus network. URL: https://its.umich.edu/enterprise/wifi-networks/researchers/science-dmz.

[63] Rutgers University. *Science DMZ and SDN Multi-Campus Research Fabric (CICNet)*. Rutgers OARC. Original description extracted from oarc.rutgers.edu/resources/cicnet/. — AI-generated contextual summary: this federated network architecture supports data-intensive research across multiple campuses while enhancing connectivity to broader national research platforms. URL: https://oarc.rutgers.edu/resources/cicnet/.

[64] Matthew Mathis, Jeffrey Semke, Jamshid Mahdavi, and Teunis Ott. "The Macroscopic Behavior of the TCP Congestion Avoidance Algorithm". In: *ACM SIGCOMM Computer Communication Review* 27.3 (1997). Foundational paper establishing the Mathis equation for TCP throughput modelling. Directly relevant to the Science DMZ rationale., pp. 67–82. DOI: 10.1145/263932.264023. URL: https://doi.org/10.1145/263932.264023.

[65] *Science DMZ Networks: How Different Are They Really?* NSF Public Access Repository. Last consulted 15 February 2026. Two-year quantitative study finding that Science DMZ networks exhibit lower latency, higher throughput, and lower jitter, but also non-intuitive results. Relevant to universities evaluating Science DMZ deployment for research network performance. 2024. URL: https://doi.org/10.1109/LCN60385.2024.10639626.

[66] Scott Rose, Oliver Borchert, Stu Mitchell, and Sean Connelly. *Zero Trust Architecture*. Tech. rep. NIST SP 800-207. This framework is particularly relevant for university IT infrastructure as institutions increasingly support remote work, personal devices, and cloud-based services that fall outside traditional network boundaries, necessitating resource-level protection rather than perimeter-based defenses. National Institute of Standards and Technology, Aug. 2020. DOI: 10.6028/NIST.SP.800-207. URL: https://csrc.nist.gov/publications/detail/sp/800-207/final.

[67] GÉANT. *eduGAIN — Global Interfederation Service*. Original description extracted from edugain.org. — AI-generated contextual summary: for university IT departments, eduGAIN is directly relevant to identity management and access governance, providing a scalable solution for supporting global resource access while maintaining institutional security and user privacy controls. URL: https://edugain.org/.

[68] Sean Peisert, Eli Dart, William K. Barnett, James Cuff, Robert L. Grossman, Edward Balas, Ari Berman, Anurag Shankar, and Brian Tierney. "The Medical Science DMZ: A Network Design Pattern for Data-Intensive Medical Science". In: *Journal of the American Medical Informatics Association* 25.3 (2018). Last consulted 15 February 2026. Highly relevant to academic institutions managing sensitive research data, offering three production implementations from Indiana University, Harvard, and the University of Chicago as practical models for balancing HIPAA regulatory compliance with infrastructure performance., pp. 267–274. DOI: 10.1093/jamia/ocx104. URL: https://pmc.ncbi.nlm.nih.gov/articles/PMC7651886/.

[69] Isaac Newton. *Letter to Robert Hooke*. 5 February 1675/1676. — Contains the celebrated phrase "If I have seen further it is by standing on the shoulders of Giants." Newton's acknowledgment of building upon prior scientific work is foundational to academic collaboration and knowledge sharing. As an epigraph, it speaks to the cumulative nature of institutional knowledge and the importance of building on established frameworks in university IT infrastructure development. 1675. URL: https://digitallibrary.hsp.org/index.php/Detail/objects/9792.

[70] EPFL. *Research Computing Platform (RCP)*. École Polytechnique Fédérale de Lausanne. Original description extracted from epfl.ch/research/facilities/rcp/. — AI-generated contextual summary: this infrastructure enables scalable research computing without requiring individual labs to maintain expensive hardware, supporting EPFL's mission to facilitate cutting-edge scientific investigation across all disciplines. URL: https://www.epfl.ch/research/facilities/rcp/.

[71] CERN. *The Network Challenge*. CERN. Original description extracted from home.cern/science/computing/network. — AI-generated contextual summary: this resource provides a case study in large-scale academic and research networking, demonstrating how dedicated infrastructure enables cross-institutional scientific collaboration and massive data management. URL: https://home.cern/science/computing/network.

[72] Comparitech et al. *RansomHouse claims ransomware attack on Université Paris-Saclay – 1TB allegedly stolen*. Comparitech. The incident highlights the growing threat that ransomware poses to university IT infrastructure, potentially exposing sensitive research and administrative information. It illustrates the vulnerability of higher education institutions to organized cybercriminal operations targeting large-scale academic networks. 2024. URL: https://www.comparitech.com/news/ransomhouse-claims-ransomware-attack-on-universite-paris-saclay-1tb-allegedly-stolen/.

[73] MIT Information Systems & Technology. *About IS&T*. Massachusetts Institute of Technology. Original description extracted from ist.mit.edu/about landing page. — AI-generated contextual summary: IS&T is the central IT organization of MIT, managing MITnet, cloud and hybrid infrastructure, enterprise applications, security operations, and end-user support, documenting the organizational model and strategic direction of a world-leading university's centralized IT department. URL: https://ist.mit.edu/about.

[74] MIT News. *Looking Back at Project Athena*. MIT News Office. Original description extracted from news.mit.edu article. — AI-generated contextual summary: Project Athena documents the historical origins of campus-wide academic computing, illustrating how institutional investment in shared IT infrastructure can generate transformative technologies with applications far beyond the original academic context. 2018. URL: https://news.mit.edu/2018/mit-looking-back-project-athena-distributed-computing-for-students-1111.

[75] MIT. *Computing on Campus*. MIT Facts. Original description extracted from facts.mit.edu page. — AI-generated contextual summary: this resource provides an official overview of how MIT organizes and delivers computing services to its academic community, centering on IS&T as the central IT organization. URL: https://facts.mit.edu/academic-campus-resources/computing-on-campus/.

[76] CSAIL — The Infrastructure Group (TIG). *About TIG*. MIT CSAIL. Original description extracted from tig.csail.mit.edu landing page. — AI-generated contextual summary: TIG exemplifies the decentralized IT model where individual research units maintain their own specialized infrastructure alongside the central university IT organization, illustrating the federated approach common in research-intensive institutions. URL: https://tig.csail.mit.edu/.

[77] MIT IS&T. *MITnet Rules of Use*. Massachusetts Institute of Technology. Original rules extracted from ist.mit.edu/network/rules. — AI-generated contextual summary: the MITnet Rules of Use demonstrate how a leading research institution balances open academic network access with security requirements and legal obligations through a clear, enforceable policy framework. Violations may result in disciplinary proceedings, loss of network privileges, and civil or criminal prosecution. URL: https://ist.mit.edu/network/rules.

[78] S. P. Miller, B. Clifford Neuman, Jeffrey I. Schiller, and Jerome H. Saltzer. *Kerberos Authentication and Authorization System*. Tech. rep. Section E.2.1. Original abstract from the technical report (verified via Semantic Scholar). — AI-generated contextual summary: Kerberos uses a trusted third-party ticket-granting mechanism to allow users and services to prove their identity without transmitting passwords over the network. Developed as a core component of the Athena campus computing project, Kerberos became a foundational technology for university IT infrastructure and has since been adopted as a standard authentication protocol across higher education and enterprise environments worldwide. MIT Project Athena Technical Plan, 1987. URL: https://web.mit.edu/Saltzer/www/publications/athenaplan/e.2.1.pdf.

[79] Stanford University IT. *University IT (UIT)*. Stanford University. Original description extracted from uit.stanford.edu/about. — AI-generated contextual summary: UIT serves as the central IT support hub connecting students, faculty, and staff with technology services across the university, functioning as a centralized gateway for IT help, training, and announcements relevant to digital infrastructure and cybersecurity initiatives. URL: https://uit.stanford.edu/.

[80] Stanford University IT. *SUNet — Stanford University Network*. Stanford University. Original description extracted from uit.stanford.edu/service/network. — AI-generated contextual summary: SUNet outlines connectivity responsibilities shared between University IT and individual departments, serving as a comprehensive reference for IT providers with links to network-related services including VPN, firewalls, Wi-Fi, and cloud networking solutions. URL: https://uit.stanford.edu/service/network.

[81] Stanford School of Engineering. *SoE IT — School of Engineering Information Technology*. Stanford University. Original mission and vision extracted from soeithelp.stanford.edu/about-us. — AI-generated contextual summary: this decentralized model enables the engineering school to deliver customized IT infrastructure aligned with the distinctive needs of various academic and research programs. URL: https://soeithelp.stanford.edu/about-us.

[82] Stanford School of Medicine. *Technology & Digital Solutions (TDS)*. Stanford Medicine. Original tagline and service categories extracted from med.stanford.edu/irt.html. — AI-generated contextual summary: TDS coordinates essential technical operations from data security and network management to administrative systems and compliance that enable the institution's clinical, research, and educational missions, illustrating school-level IT governance within a large research university. URL: https://med.stanford.edu/irt.html.

[83] SLAC National Accelerator Laboratory. *SLAC IT Services*. SLAC / Stanford University. Page is a service portal with no unified description or mission statement; only service categories (accounts, device support, cybersecurity, collaboration tools, procurement). — AI-generated contextual summary: the SLAC IT portal serves as the central IT services hub for SLAC National Accelerator Laboratory, providing employees and contractors access to comprehensive technology support. A key initiative emphasizes data protection with new email forwarding policies prohibiting automatic forwarding of Controlled Unclassified Information. The platform reflects institutional commitment to modernizing IT infrastructure through identity and access management, cloud services, and zero trust architecture. URL: https://it.slac.stanford.edu/.

[84] Stanford Research Computing Center. *Sherlock — High-Performance Computing Cluster*. Stanford University. Original description extracted from srcc.stanford.edu. — AI-generated contextual summary: Sherlock centralizes computational research support while reducing individual departments' hardware administration burdens, supporting a fair-share scheduling model with optional purchasing opportunities for dedicated resources. URL: https://srcc.stanford.edu/sherlock-high-performance-computing-cluster.

[85] University of Cambridge. *How the University and Colleges Work*. University of Cambridge. Original description extracted from cam.ac.uk. — AI-generated contextual summary: this resource is relevant to understanding the distributed decision-making structure that informs institutional policies around data protection, information security, and compliance across the university's autonomous units. URL: https://www.cam.ac.uk/about-the-university/how-the-university-and-colleges-work.

[86] University Information Services (UIS). *University Data Network (UDN)*. University of Cambridge. Original description extracted from help.uis.cam.ac.uk. — AI-generated contextual summary: the UDN's primary purpose is to enable communication and resource-sharing across the university's distributed campuses while maintaining network security and service quality for academic and administrative operations. URL: https://help.uis.cam.ac.uk/service/network-services/datanetwork.

[87] University Information Services (UIS). *Institutional Connections — IP Routing*. University of Cambridge. Original description extracted from help.uis.cam.ac.uk. — AI-generated contextual summary: this resource provides comprehensive guidance for institutional network managers implementing resilient network architectures, essential for maintaining reliable campus network operations. URL: https://help.uis.cam.ac.uk/service/network-services/datanetwork/institutional-connections.

[88] University Information Services (UIS). *Cambridge IP Address Ranges*. University of Cambridge. Original description extracted from help.uis.cam.ac.uk. — AI-generated contextual summary: the guide highlights important cybersecurity considerations around IP-based access control unreliability, since hosts using UDN addresses do not necessarily belong to or are used by a member of the University. URL: https://help.uis.cam.ac.uk/service/network-services/ip/cam-ip-ranges.

[89] ETH Zurich. *Departments*. ETH Zurich. Page contains only a navigational listing of 16 departments in five groups with no descriptive text. — AI-generated contextual summary: the page presents the organizational structure of ETH Zurich, listing 16 academic departments organized into five thematic groups (Architecture and Civil Engineering, Engineering Sciences, Natural Sciences and Mathematics, System-oriented Natural Sciences, and Management and Social Sciences), illustrating the departmental structure relevant to understanding how academic governance and IT service delivery are organized at the faculty level. URL: https://ethz.ch/en/the-eth-zurich/organisation/departments-and-competence-centres/departments.html.

[90] ISG D-INFK. *IT Service Group — Department of Computer Science*. ETH Zurich. Original description extracted from isg.inf.ethz.ch. — AI-generated contextual summary: this resource demonstrates the departmental-level IT support model at ETH Zurich, where specialized IT groups operate alongside central IT services to meet discipline-specific computing needs. URL: https://www.isg.inf.ethz.ch/.

[91] James H. Morris, Mahadev Satyanarayanan, Michael H. Conner, John H. Howard, David S. Rosenthal, and F. Donelson Smith. "Andrew: A Distributed Personal Computing Environment". In: *Communications of the ACM* 29.3 (Mar. 1986). Last consulted 15 February 2026. One of the earliest large-scale implementations of distributed computing in higher education. Established foundational concepts for campus-wide IT infrastructure including AFS (scalable file sharing), authentication services, and user environment management. Directly relevant as a historical model for university IT infrastructure policy., pp. 184–201. DOI: 10.1145/5666.5671. URL: https://doi.org/10.1145/5666.5671.

[92] SCS Computing Facilities. *Kerberos at SCS*. Carnegie Mellon University. Original description extracted from computing.cs.cmu.edu/help-support/kerberos. — AI-generated contextual summary: Kerberos is fundamental to SCS computing security, protecting against network eavesdropping and unauthorized access attempts through limited-lifetime credential tickets. URL: https://computing.cs.cmu.edu/help-support/kerberos.

[93] Software Engineering Institute. *About the SEI*. Carnegie Mellon University. Original description extracted from sei.cmu.edu/about/. — AI-generated contextual summary: its work is directly relevant to university IT infrastructure and cybersecurity through its development of frameworks such as the CMMI maturity model and the CERT Coordination Center for vulnerability disclosure. URL: https://www.sei.cmu.edu/about/.

[94] University of Michigan — ITS. *About ITS*. University of Michigan. Site blocks bots with HTTP 403; no original description recoverable. — AI-generated contextual summary: the University of Michigan Information and Technology Services (ITS) is the central IT organization providing shared technology services and infrastructure to the university community. ITS supports core enterprise systems, networking, security, and digital services that underpin academic, research, and administrative operations across all three campuses. URL: https://its.umich.edu/about.

[95] University of Michigan. *About Michigan IT*. University of Michigan. Site blocks bots with HTTP 403; no original description recoverable. — AI-generated contextual summary: Michigan IT is the broader IT community at the University of Michigan, encompassing ITS and distributed IT professionals across schools, colleges, and administrative units. It represents a collaborative model of IT governance and service delivery that coordinates technology strategy, shared services, and best practices across the university's decentralized organizational structure. URL: https://it.umich.edu/community/about.

[96] University of Michigan — ITS. *Core Network*. University of Michigan. Site blocks bots with HTTP 403; no original description recoverable. — AI-generated contextual summary: the University of Michigan Core Network is the high-speed backbone network infrastructure managed by ITS that interconnects campus buildings, data centers, and external research networks. It provides essential wired and wireless connectivity supporting academic, research, and administrative computing across the university's campuses. URL: https://its.umich.edu/enterprise/wifi-networks/core-network.

[97] Merit Network. *History of Merit Network*. Merit Network. Site blocks bots with HTTP 403; no original description recoverable. — AI-generated contextual summary: Merit Network is a nonprofit organization founded in 1966 by Michigan's public universities to develop and operate a shared computer network. It played a pioneering role in the development of the Internet, notably operating the NSFNET backbone in the late 1980s and early 1990s, and continues to serve as a regional research and education network provider for Michigan institutions. URL: https://www.merit.edu/about/history/.

[98] University of Michigan. *IT Council*. University of Michigan. Site blocks bots with HTTP 403; no original description recoverable. — AI-generated contextual summary: the University of Michigan IT Council is a governance body that provides strategic direction and oversight for information technology across the university. It brings together IT leaders from schools, colleges, and administrative units to coordinate technology planning, policy development, and resource allocation in support of the university's academic and research missions. URL: https://it.umich.edu/governance/it-council.

[99] Michigan Medicine. *Health Information Technology & Services (HITS)*. University of Michigan. Site blocks bots with HTTP 403; no original description recoverable. — AI-generated contextual summary: Michigan Medicine's Health Information Technology & Services (HITS) provides dedicated IT services for the University of Michigan's academic medical center. HITS manages healthcare-specific technology infrastructure including clinical systems, electronic health records support, and secure computing environments for medical research and patient care. This unit illustrates how large universities maintain specialized, sector-specific IT organizations alongside central IT services to address regulatory and operational requirements unique to healthcare. URL: https://www.michiganmedicine.org/health-information-technology-services.

[100] University of Michigan — CAEN. *Computer Aided Engineering Network*. Michigan Engineering. Site blocks bots with HTTP 403; no original description recoverable. — AI-generated contextual summary: the Computer Aided Engineering Network (CAEN) provides dedicated IT infrastructure and computing services to the University of Michigan's College of Engineering. CAEN operates computing labs, software licensing, network services, and technical support tailored to engineering education and research needs. This resource exemplifies the federated IT model at large research universities, where individual colleges maintain their own specialized computing facilities alongside central university IT services. URL: https://caen.engin.umich.edu/.

[101] University of Michigan — ARC. *Advanced Research Computing*. University of Michigan. Site blocks bots with HTTP 403; no original description recoverable. — AI-generated contextual summary: the University of Michigan's Advanced Research Computing (ARC) division provides high-performance computing clusters, large-scale data storage, and specialized research computing support to faculty and researchers across the university. ARC offers resources including the Great Lakes HPC cluster, Turbo Research Storage, and consulting services that enable computationally intensive research. This service demonstrates how major

research universities centralize advanced computing infrastructure to support cross-disciplinary research needs. URL: https://its.umich.edu/advanced-research-computing/.

[102] University of Michigan. *Safe Computing — Data Classification Levels*. University of Michigan. Site blocks bots with HTTP 403; no original description recoverable. — AI-generated contextual summary: the University of Michigan Safe Computing website defines the institution's data classification framework, categorizing institutional data into sensitivity levels (High, Moderate, Low) to guide appropriate handling, storage, and protection measures. This classification system establishes security requirements proportional to data sensitivity, covering everything from public information to regulated data such as HIPAA and FERPA records. The framework is central to the university's cybersecurity governance, enabling consistent data protection policies across a large, decentralized institution. URL: https://safecomputing.umich.edu/protect-the-u/safely-use-sensitive-data/classification-levels.

[103] CERN Computer Security Team. *Computer Security: TN v3.0*. CERN. Original description extracted from home.cern/news/news/computing/computer-security-tn-v30. — AI-generated contextual summary: this resource demonstrates how large research institutions implement progressive network segmentation strategies to balance security with operational needs, protecting critical accelerator control systems while accommodating modern technologies. URL: https://home.cern/news/news/computing/computer-security-tn-v30.

[104] WLCG. *Worldwide LHC Computing Grid*. CERN. Original description extracted from wlcg.web.cern.ch. — AI-generated contextual summary: this resource exemplifies a federated model of large-scale research computing that depends on coordinated cybersecurity policies, resource sharing agreements, and multi-institutional governance frameworks organized into tiered computing centers. URL: https://wlcg.web.cern.ch/.

[105] CERN Computer Security Team. *Computer Security vs. Academic Freedom*. CERN. Original description extracted from home.web.cern.ch/news/news/computing/computer-security-vs-academic-freedom. — AI-generated contextual summary: this resource provides a principled framework for how academic institutions can protect their infrastructure through transparent communication and proportionate measures without creating an overly restrictive environment that stifles research and innovation. URL: https://home.web.cern.ch/news/news/computing/computer-security-vs-academic-freedom.

[106] ETH Zurich. *Data Stewardship at ETH Zurich*. ETH Library — Research Data Management. Original description extracted from library.ethz.ch data stewardship page. — AI-generated contextual summary: the resource profiles individual data stewards from various departments and explains their roles in implementing open research data practices, managing research workflows, and ensuring compliance with institutional guidelines, aligning with national open science initiatives. URL: https://library.ethz.ch/en/researching-and-publishing/data-management-and-policies/research-data-management/data-stewardship.html.

[107] Debbie Carraway and Marc Hoit. "Redesigning IT Governance for Digital Transformation at North Carolina State University". In: *EDUCAUSE Review* (Mar. 2019). EDUCAUSE Review blocks bots with HTTP 403; no original abstract recoverable. — AI-generated contextual summary: this article describes how North Carolina State University redesigned its IT governance structure to support digital transformation, detailing the transition from a traditional committee-based governance model to a more agile framework that aligns IT decision-making with institutional strategic priorities, emphasizing stakeholder engagement and portfolio management approaches. The article provides a practical case study of how a large research university can modernize IT governance to be more responsive to rapidly evolving technology needs while maintaining broad campus participation. URL: https://er.educause.edu/articles/2019/3/redesigning-it-governance-for-digital-transformation-at-north-carolina-state-university.

[108] Penn State. *IT Transformation: Participatory Governance with SLAs*. Penn State University. Original description extracted from psu.edu news article. — AI-generated contextual summary: this initiative represents a shift toward centralized IT governance and shared services, with dedicated workstreams addressing seven areas including IT governance, financial taxonomy, and solution delivery. URL: https://www.psu.edu/news/administration/story/it-begins-transition-shared-services-model.

[109] Université Paris-Saclay — DSI. *Services numériques du campus*. Université Paris-Saclay. Original description extracted from universite-paris-saclay.fr/en/campus-life/digital-services. — AI-generated contextual summary: the resource illustrates the standard portfolio of campus IT services provided by a major French research university, including identity management, network access, productivity tools, and learning platforms. URL: https://www.universite-paris-saclay.fr/en/campus-life/digital-services.

[110] Sorbonne Université. *LIP6 — Laboratoire d'Informatique de Paris 6*. Sorbonne Université. Original description extracted from sorbonne-universite.fr/structures-de-recherche/lip6. — AI-generated contextual summary: its work in security systems, network architecture, and computational reliability is directly applicable to university digital operations and technology strategy. URL: https://www.sorbonne-universite.fr/structures-de-recherche/lip6.

[111] Sorbonne Université. *Plateforme de Calcul et de Stockage (LPNHE)*. Sorbonne Université. Original description extracted from sorbonne-universite.fr/plateformes-techniques/plateforme-de-calcul-et-de-stockage. — AI-generated contextual summary: this platform represents a critical shared research computing infrastructure at Sorbonne, supporting major physics experiments at CERN's LHC and offering equipment hosting services to other laboratories. URL: https://www.sorbonne-universite.fr/plateformes-techniques/plateforme-de-calcul-et-de-stockage.

[112] EDUCAUSE. *The Higher Education IT Service Catalog*. EDUCAUSE. The catalog enables cross-institutional comparison and collaboration by establishing a common language for IT service delivery in the academic sector, tailored to the diverse population of higher education — students, faculty, staff, alumni, and governance committees. 2019. URL: https://library.educause.edu/resources/2019/11/higher-education-it-service-catalog-second-edition.

[113] Université de Pau et des Pays de l'Adour (UPPA). *Charte des usagers du numérique*. UPPA. Landing page for UPPA's Digital Users Charter (Charte des usagers du numérique), which governs appropriate use of all university digital services including user accounts, collaborative messaging via the Partage platform, WiFi connectivity via Eduroam, and Office 365 access. Establishes governance standards for IT infrastructure and user conduct across the academic community. URL: https://moncompte.univ-pau.fr/charte/.

[114] Université Le Havre Normandie. *Charte relative à l'utilisation des TIC*. Université Le Havre Normandie. Defines user responsibilities, security protocols, and acceptable use standards across networked systems, including email, Wi-Fi, and data storage. Emphasizes compliance with French data protection laws and intellectual property regulations while outlining consequences for violations, making it a central document in the university's IT governance framework. URL: https://www-iut.univ-lehavre.fr/charte-informatique/.

[115] Richard P. Feynman. "Cargo Cult Science". In: *Caltech Commencement Address*. Reprinted in *Surely You're Joking, Mr. Feynman!*, W.W. Norton, 1985. — Some remarks on science, pseudoscience, and learning how to not fool yourself. Warns against research that mimics the appearance of science while lacking fundamental rigor, coining the principle "you must not fool yourself — and you are the easiest person to fool." As an epigraph, its emphasis on intellectual honesty and verification practices is relevant to evidence-based IT governance and the avoidance of superficial compliance in university cybersecurity programs. 1974. URL: https://calteches.library.caltech.edu/51/2/CargoCult.htm.

[116] SOCCER Team. *Cyberattack on the Université Paris-Saclay: case study*. SOCCER – Cybersecurity for Academic Sector, AGH University of Krakow. Case study by the SOCCER project at AGH University of Krakow examining the August 2024 ransomware attack on Université Paris-Saclay: attackers encrypted critical data and locked the institution out of its own systems. Promotes the SOCCER initiative to establish Security Operations Centers at universities. 2024. URL: https://soccer.agh.edu.pl/en/detail/cyberattack-on-the-universite-paris-saclay-case-study.

[117] Ouest-France et al. *L'Université de Rennes victime d'une cyberattaque*. Ouest-France. March 2025; FunkSec group, ISTIC subnet. — L'Université de Rennes a annoncé le 10 mars 2025 avoir été victime d'une cyberattaque durant le week-end du 8–9 mars 2025 sur un sous-réseau pédagogique. FunkSec revendique 50 Go de données volées. Un VPN-SSL Fortinet utilisé par l'ISTIC a apparemment permis la compromission. 2025. URL: https://www.ouest-france.fr/bretagne/rennes-35000/luniversite-de-rennes-victime-dune-cyberattaque-5559d17c-fd9b-11ef-96f1-e130525ba9af.

[118] Numerama. *L'université Paris-Sorbonne victime d'une cyberattaque, un hacker a volé des données*. Numerama. October 2024 cyberattack on Paris 1 Panthéon-Sorbonne: a hacker extracted data from the public directory, compromising names, email addresses, photos, and status of 73 000 students and staff. The university notified the CNIL. Directly relevant to academic cybersecurity governance and the protection of sensitive student and faculty information. 2024. URL: https://www.numerama.com/cyberguerre/1823862-luniversite-paris-sorbonne-victime-dune-cyberattaque-un-hacker-a-vole-des-donnees.html.

[119] BleepingComputer. *Texas Tech University System data breach impacts 1.4 million patients*. BleepingComputer. 2024. URL: https://www.bleepingcomputer.com/news/security/texas-tech-university-system-data-breach-impacts-14-million-patients/.

[120] Multiple sources. *MOVEit Transfer vulnerability and university breaches (UCLA, Stanford Medicine, Georgia, etc.)* Cl0p ransomware group; Progress Software MOVEit zero-day; see e.g., University System of Georgia, UCLA breach notices. — The FBI and CISA joint advisory disseminates known CL0P ransomware IOCs and TTPs: beginning May 27, 2023, CL0P exploited a previously unknown SQL injection vulnerability (CVE-2023-34362) in Progress Software's MOVEit Transfer, installing a web shell called LEMURLOOT to steal data. Major universities including UCLA, Stanford Medicine, and the University System of Georgia were among the victims. 2023–2024. URL: https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-158a.

[121] BleepingComputer. *Howard University shuts down network after ransomware attack*. BleepingComputer. 2021. URL: https://www.bleepingcomputer.com/news/security/howard-university-shuts-down-network-after-ransomware-attack/.

[122] Information Security Media Group. *Western Sydney University Suffers Third Major Breach in 2024*. BankInfoSecurity. Single named-incident source (Western Sydney University, August 2024). Carries the compromised-IT-account -> Student Management System + data warehouse facts. Corroborating university disclosures at westernsydney.edu.au/news/cyber-incident. 2024. URL: https://www.bankinfosecurity.com/western-sydney-university-suffers-third-major-breach-in-2024-a-26718.

[123] Elisity. *Network Segmentation in Higher Education*. References recent breaches affecting universities including the 2023 MOVEit breach and incidents at the University of Georgia and Colorado State University. Addresses regulatory compliance requirements including FERPA, HIPAA, PCI DSS, and NIST frameworks relevant to universities and school districts, and advocates for contemporary zero-trust security strategies. 2024. URL: https://www.elisity.com/blog/network-segmentation-in-higher-education-protecting-universities-and-school-districts-from-lateral-movement-attacks.

[124] Breached.company et al. *Higher Education Under Siege: The 2025 University Data Breach Crisis*. Breached.company. Oracle EBS CVE-2025-61882, Cl0p campaign; Phoenix, Harvard, Penn, Dartmouth, Baker, etc. — From Ivy League to For-Profit: How Clop's Oracle Campaign and Social Engineering Attacks Have Exposed Millions of Student Records. The 2025 academic year will be remembered as one of the most devastating periods for higher education cybersecurity in history, with a perfect storm of zero-day exploits, sophisticated social engineering campaigns, and chronic underfunding of university security programs. 2025. URL: https://breached.company/higher-education-under-siege-the-2025-university-data-breach-crisis/.

[125] Sophos. *The State of Ransomware in Education 2025*. Sophos. Explores the technical and organizational root causes of attacks, encryption rates, ransom demands, and the human impact on security teams. Critical resource for university IT leaders seeking to understand vulnerability patterns and develop institutional defenses against increasingly sophisticated ransomware threats targeting the education sector. 2025. URL: https://www.sophos.com/en-us/whitepaper/state-of-ransomware-in-education.

[126] NIST. *Guide to a Secure Enterprise Network Landscape*. Tech. rep. SP 800-215. For university IT infrastructure, this resource is directly relevant as academic institutions increasingly adopt distributed cloud resources and remote access models, making zero-trust security frameworks critical for protecting sensitive research data and institutional systems. National Institute of Standards and Technology, 2021. URL: https://csrc.nist.gov/pubs/sp/800/215/final.

[127] Tim Berners-Lee and Mark Fischetti. *Weaving the Web: The Original Design and Ultimate Destiny of the World Wide Web*. Memoir chronicling the invention of the World Wide Web, exploring both its technical foundations and social implications. The open, decentralized principles underlying modern internet infrastructure and the philosophical choices that shaped web standards development. As an epigraph, it underscores the foundational role of open standards and interoperability in university IT infrastructure and network governance. HarperSanFrancisco, 1999. ISBN: 978-0-06-251587-2. URL: https://www.w3.org/People/Berners-Lee/Weaving/.

[128] RENATER. *RENATER — Réseau National de télécommunications pour la Technologie, l'Enseignement et la Recherche*. Original description extracted from renater.fr. — AI-generated contextual summary: RENATER maintains active engagement in cybersecurity through its CERT and information security programs, serving over 400 academic institutions with connectivity, security solutions, and federated identity management. URL: https://www.renater.fr.

[129] DFN. *DFN — Deutsches Forschungsnetz*. 2024. URL: https://www.dfn.de/en/.

[130] SWITCH. *SWITCH — Swiss National Research and Education Network*. 2024. URL: https://www.switch.ch/en/.

[131] ESnet. *Science DMZ Case Studies*. Energy Sciences Network. ESnet case studies demonstrating how high-speed network infrastructure resolves scientific computing challenges at national laboratories and research institutions, including OSCARS circuit management and Science DMZ architecture. Directly relevant to university IT professionals seeking practical guidance on deploying research data infrastructure. URL: https://www.es.net/science-engagement/knowledge-base/case-studies/.

[132] Dwight D. Eisenhower. *Remarks at the National Defense Executive Reserve Conference*. 14 November 1957. — Contains the famous observation "plans are worthless, but planning is everything." Eisenhower emphasized that advance preparation for emergencies, despite their unpredictability, enables effective organizational response through coordination across agencies. As an epigraph, directly applicable to IT disaster recovery planning, incident response preparedness, and cross-functional security governance at universities. 1957. URL: https://www.presidency.ucsb.edu/documents/remarks-the-national-defense-executive-reserve-conference.

[133] NIST. *The NIST Cybersecurity Framework (CSF) 2.0*. Tech. rep. NIST CSWP 29. The CSF 2.0 is a foundational tool for academic institutions seeking to establish or enhance their cybersecurity governance posture and align risk management efforts with standardized best practices across all sectors. National Institute of Standards and Technology, Feb. 2024. DOI: 10.6028/NIST.CSWP.29. URL: https://www.nist.gov/cyberframework.

[134] REN-ISAC. *REN-ISAC — Research and Education Networking ISAC*. Original description extracted from ren-isac.net/what-we-do/Overview.html. — AI-generated contextual summary: members gain access to a community of cybersecurity experts and professional development opportunities including webinars and workshops, strengthening institutional security postures. URL: https://ren-isac.net/what-we-do/Overview.html.

[135] NIST. *Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations*. Tech. rep. NIST SP 800-171 Rev. 3. Final, 14 May 2024; 97 requirements consolidated from 110 in Rev. 2. National Institute of Standards and Technology, 2024. DOI: 10.6028/NIST.SP.800-171r3. URL: https://csrc.nist.gov/pubs/sp/800/171/r3/final.

[136] ISACA. *COBIT 2019 Framework: Introduction and Methodology*. For universities, COBIT offers tools for optimizing IT governance, managing risks, establishing controls, and supporting digital transformation initiatives critical to protecting institutional data and ensuring regulatory compliance. ISACA, 2018. URL: https://www.isaca.org/resources/cobit.

[137] Peter Weill and Jeanne W. Ross. *IT Governance: How Top Performers Manage IT Decision Rights for Superior Results*. Highly relevant to university governance as it provides actionable models for structuring IT decision-making authority, accountability, and strategic alignment within complex organizations. Harvard Business School Press, 2004. ISBN: 978-1591392538. URL: https://hbsp.harvard.edu/product/4783-HBK-ENG.

[138] Jack Freund and Jack Jones. *Measuring and Managing Information Risk: A FAIR Approach*. Highly relevant to university IT infrastructure and cybersecurity governance, as the FAIR methodology enables institutions to quantify and prioritize security risks across complex academic environments. Butterworth-Heinemann, 2014. ISBN: 978-0124202313. URL: https://shop.elsevier.com/books/measuring-and-managing-information-risk/freund/978-0-12-420231-3.

[139] Alan M. Turing. "Computing Machinery and Intelligence". In: *Mind* LIX.236 (1950). Last consulted 15 February 2026. No formal abstract exists for this 1950 philosophical paper. Turing's foundational work introduced the "Turing Test" as a criterion for machine intelligence by posing the question "Can machines think?" The paper systematically addresses objections to machine intelligence. As a section epigraph, it speaks to the transformative role of computing and AI in modern university infrastructure and the philosophical questions surrounding governance of emerging technologies in academic settings., pp. 433–460. DOI: 10.1093/mind/LIX.236.433. URL: https://academic.oup.com/mind/article-abstract/LIX/236/433/986238.

[140] Antoine de Saint-Exupéry. *Terre des Hommes*. Chapter III. — Philosophical memoir reflecting on human experience through the lens of aviation, exploring themes of responsibility, human connection, and the relationship between technology and humanity. Chapter III meditates on the purpose of tools and machines as instruments that serve human ends rather than as ends in themselves. As an epigraph, it underscores the principle that IT infrastructure should serve the academic mission and human needs of the university. Paris: Gallimard, 1939. URL: https://www.gallimard.fr/Catalogue/GALLIMARD/Folio/Folio/Terre-des-hommes.

[141] CEDH (Grande Chambre). *Bărbulescu c. Roumanie*. Req. n° 61496/08, 5 septembre 2017 — This case is of paramount relevance to university IT infrastructure governance, as it directly shapes policies on monitoring of email, messaging, and internet use on institutional networks, requiring transparent, proportionate, and well-documented surveillance practices. The Court set out six criteria (the "Barbulescu criteria") that domestic courts must assess when balancing employer monitoring against employee privacy. 2017. URL: https://hudoc.echr.coe.int/fre?i=001-177082.

[142] Gregory M. Kurtzer, Vanessa Sochat, and Michael W. Bauer. "Singularity: Scientific Containers for Mobility of Compute". In: *PLOS ONE* 12.5 (2017). Last consulted 15 February 2026. Containerization platform for scientific and HPC environments that prevents privilege escalation, suitable for institutional HPC clusters. Fundamental to protecting academic IT infrastructure while enabling computational reproducibility., e0177459. DOI: 10.1371/journal.pone.0177459. URL: https://journals.plos.org/plosone/article?id=10.1371/journal.pone.0177459.

[143] UNESCO. *Recommendation concerning the Status of Higher-Education Teaching Personnel*. 1997. URL: https://www.unesco.org/en/legal-affairs/recommendation-concerning-status-higher-education-teaching-personnel.

[144] AAUP, ACE, and AGB. *Statement on Government of Colleges and Universities*. 1966. URL: https://www.aaup.org/reports-publications/aaup-policies-reports/topical-reports/statement-government-colleges-and.

[145] Harvard University. *IT Governance at Harvard*. 2024. URL: https://huit.harvard.edu/it-governance.

[146] University of Kentucky Senate. *Senate Generative AI Committee*. 2024. URL: https://universitysenate.uky.edu/committee/senate-generative-ai-committee.

[147] Academic Senate for California Community Colleges. *ASCCC AI Resources*. 2024. URL: https://www.asccc.org/sites/default/files/ASCCC_AI_Resources_2024.pdf.

[148] Trusted CI. *Trusted CI — The NSF Cybersecurity Center of Excellence*. Original description extracted from trustedci.org. — AI-generated contextual summary: it addresses unique cybersecurity challenges in higher education, including protection against emerging threats like ransomware while balancing the openness required for collaborative research. URL: https://trustedci.org/.

[149] FIRST. *FIRST — Forum of Incident Response and Security Teams*. Original description extracted from first.org. — AI-generated contextual summary: for universities, FIRST membership offers frameworks and community resources essential for developing robust IT security operations and coordinated incident handling capabilities. URL: https://www.first.org/.

[150] JRES. *JRES — Journées Réseaux de l'Enseignement et de la Recherche*. 2024. URL: https://www.jres.org/.

[151] Eleanor Roosevelt. *In Your Hands*. Speech delivered at the United Nations, New York, 27 March 1958. — Emphasized that human rights begin "in small places, close to home" and that their protection depends on the actions of individuals in their local communities and institutions. Articulated the principle that universal rights must be implemented through concrete institutional practices. As an epigraph, relevant to the governance of digital rights, privacy protections, and equitable access to IT resources within university settings. 1958. URL: https://www.un.org/en/about-us/udhr/history-of-the-declaration.

[152] *Directive 2000/78/CE du Conseil du 27 novembre 2000 portant création d'un cadre général en faveur de l'égalité de traitement en matière d'emploi et de travail*. Its relevance to academic governance lies in establishing mandatory compliance frameworks for university hiring, staff management, promotion policies, and the obligation to provide reasonable accommodations for persons with disabilities. 2000. URL: https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=celex:32000L0078.

[153] CJUE. *Chacón Navas c. Eurest Colectividades SA*. Aff. C-13/05, 11 juillet 2006 — This case shapes how institutions define disability for the purpose of reasonable accommodation obligations toward employees and, by extension, students. 2006. URL: https://curia.europa.eu/juris/liste.jsf?num=C-13/05.

[154] CJUE. *Ring et Skouboe Werge*. Aff. jointes C-335/11 et C-337/11, 11 avril 2013 — This ruling expands the scope of reasonable accommodation obligations for staff and students with chronic conditions or long-term health impairments. 2013. URL: https://curia.europa.eu/juris/liste.jsf?num=C-335/11.

[155] Nations Unies. *Convention relative aux droits des personnes handicapées (CDPH)*. Adoptée le 13 décembre 2006, entrée en vigueur le 3 mai 2008 — The Convention requires institutions to ensure accessible IT infrastructure, inclusive digital learning environments, and reasonable accommodations for students and staff with disabilities. 2006. URL: https://social.desa.un.org/issues/disability/crpd/convention-on-the-rights-of-persons-with-disabilities-crpd.

[156] *Charte des droits fondamentaux de l'Union européenne*. JO C 326, 26.10.2012, pp. 391–407. Articles 1, 7, 8, 10, 11, 13, 31, 52 — The Charter codifies binding fundamental rights for EU member states. It establishes critical protections including the right to personal data protection (Article 8), freedom of expression and information (Article 11), academic freedom (Article 13), and the right to education (Article 14). These provisions directly inform university compliance frameworks, data governance policies, and the protection of research and teaching activities. 2012. URL: https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:12012P/TXT.

[157] *Convention européenne de sauvegarde des droits de l'homme et des libertés fondamentales*. Conseil de l'Europe, telle qu'amendée. Articles 8, 9, 10 — Articles 8 (right to respect for private life and correspondence), 9 (freedom of thought, conscience and religion), and 10 (freedom of expression) set the legal baseline for policies on electronic surveillance, data protection, conscientious objection, and academic freedom of expression in institutional settings. 1950. URL: https://www.echr.coe.int/fr/european-convention-on-human-rights.

[158] CEDH. *Sorguç c. Turquie*. Req. n° 17089/03, 23 juin 2009 — This case establishes that universities must protect freedom of academic expression, including critical discourse, and cannot use disciplinary or IT-related measures to suppress legitimate scholarly debate. 2009. URL: https://hudoc.echr.coe.int/eng?i=001-93161.

[159] CEDH. *Mustafa Erdoğan et autres c. Turquie*. Req. n°s 346/04, 39779/04, 27 mai 2014 — This case reinforces that institutional policies – including IT acceptable-use policies and publication guidelines – must not be used to silence legitimate academic criticism or restrict scholarly discourse. 2014. URL: https://hudoc.echr.coe.int/eng?i=001-144129.

[160] CEDH. *Yildirim c. Turquie*. Req. n° 3111/10, 18 décembre 2012 — This case establishes that network-level blocking or filtering measures must be narrowly targeted and proportionate, prohibiting overbroad internet restrictions on campus networks. 2012. URL: https://hudoc.echr.coe.int/eng?i=001-115705.

[161] CJUE. *Scarlet Extended SA c. SABAM*. Aff. C-70/10, 24 novembre 2011 — This ruling limits the scope of network filtering and surveillance measures that institutions can impose on their networks. Indiscriminate monitoring of all electronic communications on a network is incompatible with the EU Charter of Fundamental Rights. 2011. URL: https://curia.europa.eu/juris/liste.jsf?num=C-70/10.

[162] CEDH (Grande Chambre). *Bayatyan c. Arménie*. Req. n° 23459/03, 7 juillet 2011 — This case establishes that institutions must accommodate sincerely held conscientious objections, which may extend to objections against certain uses of technology, surveillance systems, or mandatory digital tools on ethical or religious grounds. 2011. URL: https://hudoc.echr.coe.int/eng?i=001-105611.

[163] CEDH. *Eweida et autres c. Royaume-Uni*. Req. n°s 48420/10, 59842/10, 51671/10, 36516/10, 15 janvier 2013 — This case informs policies on religious expression and accommodation in academic workplaces, including dress codes, scheduling around religious observances, and the limits of institutional authority over personal expression. 2013. URL: https://hudoc.echr.coe.int/eng?i=001-115881.

[164] Conseil des droits de l'homme de l'ONU. *La promotion, la protection et l'exercice des droits de l'homme sur Internet*. Résolution A/HRC/RES/20/8, 5 juillet 2012 — This resolution underpins the principle that academic freedom of expression and access to information must be equally protected in digital environments, shaping IT acceptable-use policies and internet access governance. 2012. URL: https://undocs.org/A/HRC/RES/20/8.

[165] Conseil des droits de l'homme de l'ONU. *The Promotion, Protection and Enjoyment of Human Rights on the Internet*. Résolution A/HRC/RES/32/13, 18 juillet 2016 — The resolution condemns measures to intentionally prevent or disrupt access to information online and calls upon States to bridge digital divides, including in educational settings. It reinforces obligations regarding open internet access, digital inclusion for persons with disabilities, and the protection of online academic freedoms. 2016. URL: https://digitallibrary.un.org/record/845727.

[166] Conseil des droits de l'homme de l'ONU. *The Promotion, Protection and Enjoyment of Human Rights on the Internet*. Résolution A/HRC/RES/47/16, 13 juillet 2021 — This resolution is relevant to governance of AI-based systems in academic administration, surveillance and monitoring policies on campus networks, and ensuring that digital transformation respects fundamental rights. 2021. URL: https://undocs.org/A/HRC/RES/47/16.

[167] UNESCO. *Recommendation on Science and Scientific Researchers*. Adoptée le 13 novembre 2017, 39e session de la Conférence générale, 195 pays — For universities, it provides a framework for governance of research infrastructure, responsible use of digital tools and data, and the protection of researchers' intellectual freedom within institutional IT and cybersecurity policies. 2017. URL: https://www.unesco.org/en/legal-affairs/recommendation-science-and-scientific-researchers.

[168] CJUE (Grande Chambre). *Digital Rights Ireland et Seitlinger*. Aff. jointes C-293/12 et C-594/12, 8 avril 2014 — This decision constrains how institutions may retain and process network traffic metadata and communications logs. The blanket obligation to retain metadata of all communications constituted a disproportionate interference with the fundamental rights to privacy and data protection under Articles 7 and 8 of the EU Charter. 2014. URL: https://curia.europa.eu/juris/liste.jsf?num=C-293/12.

[169] CJUE (Grande Chambre). *Schrems c. Data Protection Commissioner*. Aff. C-362/14, 6 octobre 2015 — This ruling is critical for universities relying on US-based cloud services and IT infrastructure, as it requires rigorous assessment of data protection standards before transferring personal data outside the EU. 2015. URL: https://curia.europa.eu/juris/liste.jsf?num=C-362/14.

[170] Craig Brod. *Technostress: The Human Cost of the Computer Revolution*. Reading, MA: Addison-Wesley, 1984. ISBN: 978-0201112115. URL: https://openlibrary.org/books/OL18321953M/Technostress.

[171] Monideepa Tarafdar, Qiang Tu, and T. S. Ragu-Nathan. "The Impact of Technostress on Role Stress and Productivity". In: *Journal of Management Information Systems* 24.1 (2007). Last consulted 15 February 2026. Relevant to university IT infrastructure management as it provides evidence that stress caused by rapid technology adoption and complexity in academic computing environments can significantly reduce staff and faculty productivity. Proposes a diagnostic tool applicable to institutional IT governance., pp. 301–328. DOI: 10.2753/MIS0742-1222240109. URL: https://doi.org/10.2753/MIS0742-1222240109.

[172] Monideepa Tarafdar, Ellen Bolman Pullins, and T. S. Ragu-Nathan. "Technostress: Negative Effect on Performance and Possible Mitigations". In: *Information Systems Journal* 25.2 (2015). Last consulted 15 February 2026. Relevant to university IT governance: mere technical training is insufficient; institutions must also foster digital self-efficacy and participatory approaches to technology adoption to maintain academic productivity., pp. 103–132. DOI: 10.1111/isj.12042. URL: https://doi.org/10.1111/isj.12042.

[173] Marisa Salanova, Susana Llorens, and Eva Cifre. "The Dark Side of Technologies: Technostress among Users of Information and Communication Technologies". In: *International Journal of Psychology* 48.3 (2013). Last consulted 15 February 2026. Relevant to university environments where both staff and students face varying levels of mandatory technology use, highlighting the need for institutional policies that support healthy technology engagement., pp. 422–436. DOI: 10.1080/00207594.2012.680460. URL: https://doi.org/10.1080/00207594.2012.680460.

[174] Giuseppe La Torre, Angela Esposito, Ilaria Sciarra, and Marta Chiappetta. “Definition, Symptoms and Risk of Techno-stress: A Systematic Review”. In: *International Archives of Occupational and Environmental Health* 92 (2019). Last consulted 15 February 2026. Comprehensive synthesis relevant to university IT infrastructure planning as it provides an evidence base for designing institutional policies and support systems that mitigate the occupational health risks associated with pervasive technology use in academic settings., pp. 13–35. DOI: 10.1007/s00420-018-1352-1. URL: https://doi.org/10.1007/s00420-018-1352-1.

[175] T. S. Ragu-Nathan, Monideepa Tarafdar, Bhanu S. Ragu-Nathan, and Qiang Tu. “The Consequences of Technostress for End Users in Organizations: Conceptual Development and Empirical Validation”. In: *Information Systems Research* 19.4 (2008). Last consulted 15 February 2026. Validated measurement instruments for technostress creators and inhibitors. Highly relevant to universities seeking to assess and mitigate the negative effects of IT system deployments on staff well-being and retention., pp. 417–433. DOI: 10.1287/isre.1070.0165. URL: https://doi.org/10.1287/isre.1070.0165.

[176] Brett T. Litz, Nathan Stein, Eileen Delaney, Leslie Lebowitz, William P. Nash, Caroline Silva, and Shira Maguen. “Moral Injury and Moral Repair in War Veterans: A Preliminary Model and Intervention Strategy”. In: *Clinical Psychology Review* 29.8 (2009). Last consulted 15 February 2026. The concept of moral injury has broader relevance to academic governance as it provides a framework for understanding psychological harm caused by institutional decisions that force individuals to act against their professional or ethical values., pp. 695–706. DOI: 10.1016/j.cpr.2009.07.003. URL: https://doi.org/10.1016/j.cpr.2009.07.003.

[177] Victoria Williamson, Sharon A. M. Stevelink, and Neil Greenberg. “Occupational Moral Injury and Mental Health: Systematic Review and Meta-analysis”. In: *British Journal of Psychiatry* 212.6 (2018). Last consulted 15 February 2026. Relevant to academic governance: demonstrates that organizational environments which compel employees to act against their ethical principles can produce measurable psychological harm, informing how universities should design management and decision-making structures., pp. 339–346. DOI: 10.1192/bjp.2018.55. URL: https://doi.org/10.1192/bjp.2018.55.

[178] Paul Hanna, Mark Erickson, and Carl Walker. “UK Higher Education Staff Experiences of Moral Injury during the COVID-19 Pandemic”. In: *Higher Education* 86 (2023). Last consulted 15 February 2026. Directly relevant to academic governance: demonstrates how top-down IT and policy decisions in universities can inflict psychological harm on staff when those decisions conflict with professional values and duty of care., pp. 985–1002. DOI: 10.1007/s10734-022-00956-z. URL: https://link.springer.com/article/10.1007/s10734-022-00956-z.

[179] Lily M. Abadal and Garrett W. Potts. “A MacIntyrean Account of Chronic Moral Injury: Assessing the Implications of Bad Management and Marginalized Practices at Work”. In: *Frontiers in Sociology* 7 (2022). Last consulted 15 February 2026. Relevant to academic governance as it provides a theoretical basis for evaluating how university management practices and IT governance structures can either support or undermine the ethical integrity and well-being of academic staff., p. 1019804. DOI: 10.3389/fsoc.2022.1019804. URL: https://www.frontiersin.org/articles/10.3389/fsoc.2022.1019804/full.

[180] William Samuelson and Richard Zeckhauser. “Status Quo Bias in Decision Making”. In: *Journal of Risk and Uncertainty* 1.1 (1988). Last consulted 15 February 2026. Highly relevant to university IT governance: explains institutional resistance to infrastructure modernization, policy reform, and adoption of new cybersecurity frameworks, illuminating why organizations often persist with suboptimal legacy systems and outdated governance structures., pp. 7–59. DOI: 10.1007/BF00055564. URL: https://link.springer.com/article/10.1007/BF00055564.

[181] Steven De Haes and Wim Van Grembergen. *Enterprise Governance of Information Technology*. 2nd. Management for Professionals. Directly relevant to university IT governance as it defines processes and structures that enable boards and IT professionals to align technology decisions with institutional strategic objectives. Springer, 2015. DOI: 10.1007/978-3-319-14547-1. URL: https://link.springer.com/book/10.1007/978-3-319-14547-1.

[182] International Ombudsman Association (IOA). *IOA Standards of Practice and Code of Ethics*. Révisé 2017. Adopted March 17, 2022 by the Board of Directors of the International Ombuds Association, with seven significant changes. — These standards are relevant to academic governance because many universities maintain ombuds offices to handle disputes, complaints, and conflicts, providing an informal and confidential mechanism for conflict resolution that complements formal grievance procedures. 2009. URL: https://www.ombudsassociation.org/standards-of-practice-code-of-ethics.

[183] Richard M. Ryan and Edward L. Deci. “Self-Determination Theory and the Facilitation of Intrinsic Motivation, Social Development, and Well-Being”. In: *American Psychologist* 55.1 (2000). Last consulted 15 February 2026. Relevant to academic governance and university IT policy: provides a psychological framework for understanding how organizational structures, management practices, and technology policies affect the motivation and engagement of academic staff and students., pp. 68–78. DOI: 10.1037/0003-066X.55.1.68. URL: https://doi.org/10.1037/0003-066X.55.1.68.

[184] Victor Hugo. *Histoire d'un Crime*. Conclusion. — Political memoir documenting Napoleon III's 1851 coup d'état, written as both a historical account and a denunciation of authoritarian power. The conclusion contains reflections on the fragility of democratic institutions and the responsibility of citizens to defend them against tyranny. As an epigraph, speaks to the importance of institutional safeguards, transparency, and accountability in governance structures, principles applicable to the oversight of university IT infrastructure and academic freedom. Paris: Calmann Lévy, 1877. URL: https://fr.wikisource.org/wiki/Histoire_d%E2%80%99un_crime.

[185] EDUCAUSE. *Top 10 IT Issues 2024: Institutional Resilience*. EDUCAUSE Review. Flagship annual publication directly relevant to strategic planning for university IT infrastructure and academic governance, addressing critical issues including cybersecurity, data governance, enrollment management, student success analytics, and cost reduction. 2024. URL: https://www.educause.edu/research-and-publications/research/top-10-it-issues-technologies-and-trends/2024.

[186] EDUCAUSE. *IT Governance in Higher Education*. EDUCAUSE. The EDUCAUSE IT Governance resource collection provides frameworks, toolkits, checklists, and case studies for implementing effective IT governance, risk, and compliance (GRC) programs in higher education institutions, including the IT Governance Toolkit and the Higher Education IT Governance Checklist. URL: https://library.educause.edu/topics/it-professional-services/it-governance.

[187] Vern Paxson. "Bro: A System for Detecting Network Intruders in Real-Time". In: *Computer Networks* 31.23–24 (1999). Last consulted 15 February 2026. Foundational network intrusion detection system enabling comprehensive security monitoring across heterogeneous computing environments without host-level agents. Particularly relevant to universities managing thousands of diverse devices. Now maintained as the Zeek project., pp. 2435–2463. DOI: 10.1016/S1389-1286(99)00112-7. URL: https://www.icir.org/vern/papers/bro-CN99.html.

[188] IBM Security and Ponemon Institute. *Cost of a Data Breach Report 2024*. Tech. rep. Global all-industry average; the education sector sits below this figure. IBM Security, 2024. URL: https://www.ibm.com/reports/data-breach.

[189] Gartner. *Forecasts for Information Security and Risk-Management Spending*. Gartner Newsroom. Cross-industry guidance: security 8–12% of IT budget (typical), 10–15% under high threat exposure. 2024. URL: https://www.gartner.com/en/newsroom/press-releases/2024-08-28-gartner-forecasts-global-information-security-spending-to-grow-15-percent-in-2025.

[190] EDUCAUSE. *IT Spending and Staffing — Core Data Service Interactive Almanac*. EDUCAUSE Analytics Services. Higher-ed benchmarks: 3.6% of IT budget on information security; USD 1,600 central-IT spend per student FTE (median). 2024. URL: https://www.educause.edu/research-and-publications/research/analytics-services/it-spending-and-staffing-interactive-almanac.

[191] European Commission. *Commission Implementing Decision (EU) 2021/914 of 4 June 2021 on standard contractual clauses for the transfer of personal data to third countries pursuant to Regulation (EU) 2016/679 of the European Parliament and of the Council*. OJ L 199, 7 June 2021, p. 31. CELEX: 32021D0914. Entry into force 27 June 2021; legacy SCCs (Decisions 2001/497/EC and 2010/87/EU) repealed 27 September 2021; transition period for pre-existing contracts ended 27 December 2022 — Direct operational anchor for university adoption of non-EU AI cloud services, paired with a Transfer Impact Assessment and technical safeguards (encryption, pseudonymisation, data classification). 2021. URL: https://eur-lex.europa.eu/eli/dec_impl/2021/914/oj.

[192] European Commission. *Commission Implementing Decision (EU) 2023/1795 of 10 July 2023 pursuant to Regulation (EU) 2016/679 of the European Parliament and of the Council on the adequate level of protection of personal data under the EU–US Data Privacy Framework*. OJ L 231, 20 September 2023, p. 118. CELEX: 32023D1795. Competent authority for the adequacy determination is the European Commission; supervision of individual transfers and complaints remains with national data protection authorities coordinated by the EDPB. Where a recipient is not DPF-certified, transfers fall back to Article 46 SCCs (Decision (EU) 2021/914) plus a Transfer Impact Assessment. 2023. URL: https://eur-lex.europa.eu/eli/dec_impl/2023/1795/oj.

[193] European Parliament and Council of the European Union. *Regulation (EU) 2024/1183 of the European Parliament and of the Council of 11 April 2024 amending Regulation (EU) No 910/2014 as regards establishing the European Digital Identity Framework (eIDAS 2)*. OJ L, 2024/1183, 30 April 2024. CELEX: 32024R1183. Entered into force 20 May 2024 (20 days after publication). Directly applicable, no national transposition; the base instrument it amends is Regulation (EU) No 910/2014 (CELEX 32014R0910). Supervision is by each Member State's designated eIDAS/trust-services supervisory body, with the European Commission setting the wallet's technical architecture and reference framework through implementing acts. 2024. URL: https://eur-lex.europa.eu/eli/reg/2024/1183/oj.

[194] United States Congress. *Family Educational Rights and Privacy Act (FERPA)*. 20 U.S.C. § 1232g; 34 C.F.R. Part 99. Primary student-privacy obligation (F1) for US universities. No fixed breach-notification deadline in FERPA itself; enforced by withdrawal of federal education funding. 1974. URL: https://studentprivacy.ed.gov/ferpa.

[195] California State Legislature. *California Consumer Privacy Act of 2018, as amended by the California Privacy Rights Act (CCPA/CPRA)*. Cal. Civ. Code §§ 1798.100 et seq.; exemptions at § 1798.145. State consumer-privacy layer (F1). Non-profit / GLBA / HIPAA / FERPA exemptions place most universities outside direct scope; residual exposure via vendors and for-profit affiliates. Enforced by CPPA and California AG. 2023. URL: https://oag.ca.gov/privacy/ccpa.

[196] US Federal Trade Commission. *Standards for Safeguarding Customer Information (FTC Safeguards Rule)*. Tech. rep. 16 C.F.R. Part 314. Security-program (F3) + breach-notification (F4) obligation for Title-IV universities. FTC notification: no later than 30 days after discovery for events affecting 500+ consumers (16 CFR 314.4(j)). Enforced by the FTC. US Federal Trade Commission, 2023. URL: https://www.ftc.gov/business-guidance/resources/ftc-safeguards-rule-what-your-business-needs-know.

[197] US Department of Health and Human Services. *HIPAA Security Rule: Security Standards for the Protection of Electronic Protected Health Information*. Tech. rep. 45 C.F.R. Part 160 and Part 164, Subparts A and C. Health-data security obligation (F2/F3) for university covered components; hybrid-entity scoping is the key design move. Enforced by HHS OCR. US Department of Health and Human Services, Office for Civil Rights, 2003. URL: https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html.

[198] US Department of Health and Human Services. *HIPAA Breach Notification Rule*. Tech. rep. 45 C.F.R. Part 164, Subpart D (§§ 164.400–164.414). Health-data incident-notification deadline (F4): 60 calendar days to individuals/HHS; HHS notified contemporaneously for breaches of 500+. Enforced by HHS OCR. US Department of Health and Human Services, Office for Civil Rights, 2009. URL: https://www.hhs.gov/hipaa/for-professionals/breach-notification/index.html.

[199] US Department of Commerce, Bureau of Industry and Security. *Export Administration Regulations (EAR)*. 15 C.F.R. Parts 730–774; fundamental research exclusion at § 734.8. Export-control obligation (F5) for research IT, dual-use technology. Administered by BIS; fundamental research exclusion at 15 CFR 734.8 is the operative carve-out; controlled inputs/deemed exports remain in scope. 2024. URL: https://www.bis.doc.gov/index.php/regulations/export-administration-regulations-ear.

[200] US Department of State, Directorate of Defense Trade Controls. *International Traffic in Arms Regulations (ITAR)*. 22 C.F.R. Parts 120–130; fundamental research carve-out at § 120.34(a)(8). Strictest export-control obligation (F5) for defence-related research. Administered by DDTC; no general fundamental-research safe harbour for controlled technical data; releases to foreign nationals are deemed exports needing DDTC authorisation. 2024. URL: https://www.pmddtc.state.gov/ddtc_public?id=ddtc_kb_article_page&sys_id=24d528fddbfc930044f9ff621f961987.

[201] US Department of Defense. *Cybersecurity Maturity Model Certification (CMMC) Program*. Tech. rep. 32 C.F.R. Part 170. Defense-research security certification (F3) and its transfer mechanism (F6). 32 CFR Part 170 effective 16 December 2024; DFARS clause effective 10 November 2025, phased over 3 years. Administered by US DoD; Level 2 via C3PAO assessment. US Department of Defense, 2024. URL: https://www.federalregister.gov/documents/2024/10/15/2024-22905/cybersecurity-maturity-model-certification-cmmc-program.

[202] United Kingdom. *The UK GDPR: Regulation (EU) 2016/679 as retained, amended and incorporated into UK law by section 3 of the European Union (Withdrawal) Act 2018 and the Data Protection, Privacy and Electronic Communications (Amendments etc) (EU Exit) Regulations 2019*. Information Commissioner's Office (ICO), https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/. F1 (data protection) and F2 (security of processing) anchor for the UK regime. Competent authority: ICO (transitioning to the Information Commission under the DUAA 2025). Breach notification: 72 hours to the ICO. 2021. URL: https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/.

[203] United Kingdom. *Data Protection Act 2018 (c. 12)*. The National Archives, https://www.legislation.gov.uk/ukpga/2018/12/contents. F1 (data protection) primary statute for the UK; pairs with uk-gdpr. Competent authority: Information Commissioner (ICO). Amended by the Data (Use and Access) Act 2025. 2018. URL: https://www.legislation.gov.uk/ukpga/2018/12/contents.

[204] United Kingdom. *Data (Use and Access) Act 2025 (c. 18)*. The National Archives, https://www.legislation.gov.uk/ukpga/2025/18/contents. Amends F1 (data protection) and F4 (international transfers) for the UK. Restructures the ICO into the Information Commission; key provisions in force 5 February 2026. 2025. URL: https://www.legislation.gov.uk/ukpga/2025/18/contents.

[205] United Kingdom. *The Network and Information Systems Regulations 2018 (SI 2018/506)*. The National Archives, https://www.legislation.gov.uk/uksi/2018/506/contents. F3 (network and information security) anchor for the UK. Competent authority: sector CAs for OES, ICO for RDSPs; NCSC is SPOC/CSIRT. Notification: 72 hours. 2018. URL: https://www.legislation.gov.uk/uksi/2018/506/contents.

[206] National Cyber Security Centre. *NCSC: the UK technical authority for cyber security and NIS single point of contact and CSIRT*. National Cyber Security Centre, https://www.ncsc.gov.uk/. F3 supporting authority for the UK: NCSC as NIS single point of contact and national CSIRT / technical authority. 2026. URL: https://www.ncsc.gov.uk/.

[207] United Kingdom. *Cyber Security and Resilience (Network and Information Systems) Bill*. UK Parliament, https://bills.parliament.uk/. F3 (network and information security) — forthcoming UK successor to SI 2018/506; in legislative progress, not yet enacted. 2025. URL: https://bills.parliament.uk/.

[208] Information Commissioner's Office. *International Data Transfer Agreement (IDTA) and the UK Addendum to the EU SCCs*. Information Commissioner's Office (ICO), https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/international-transfers/. F4 (international / cross-border data transfers) transfer mechanism for the UK. Authority: ICO. Mechanism: adequacy decision, else IDTA or EU SCCs + UK Addendum + transfer risk assessment. 2022. URL: https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/international-transfers/.

[209] United Kingdom. *The Electronic Identification and Trust Services for Electronic Transactions Regulations 2016 (SI 2016/696), and Regulation (EU) No 910/2014 as retained (UK eIDAS)*. The National Archives, https://www.legislation.gov.uk/uksi/2016/696. F5 (electronic identification / trust services) anchor for the UK. Supervisory body: the Information Commissioner (ICO). UK eIDAS = retained Regulation (EU) 910/2014 + SI 2016/696 + 2019 EU Exit amendments. 2016. URL: https://www.legislation.gov.uk/uksi/2016/696.

[210] United Kingdom. *The Public Sector Bodies (Websites and Mobile Applications) (No. 2) Accessibility Regulations 2018 (SI 2018/952)*. The National Archives, https://www.legislation.gov.uk/uksi/2018/952/contents/made. F6 (digital accessibility) anchor for the UK. Standard: WCAG 2.1 AA via EN 301 549 (WCAG 2.2 from Oct 2024). Monitoring: GDS; enforcement: EHRC. 2018. URL: https://www.legislation.gov.uk/uksi/2018/952/contents/made.

[211] Jisc. *Accessibility regulations: what you need to know (higher and further education guidance)*. Jisc, https://www.jisc.ac.uk/guides/accessibility-regulations-what-you-need-to-know. Authoritative HE-sector secondary source for F6 (digital accessibility) in the UK. 2024. URL: https://www.jisc.ac.uk/guides/accessibility-regulations-what-you-need-to-know.

[212] Brazil, Presidência da República. *Lei nº 13.709, de 14 de agosto de 2018 — Lei Geral de Proteção de Dados Pessoais (LGPD)*. Federal statute, Diário Oficial da União. Art. 46 (security of processing) and Art. 48 (incident communication to ANPD and data subjects) are the operative pegs for the data-protection and incident-notification functional obligations. Public bodies, including federal universities, are within scope (Chapter IV, public-power processing). 2018. URL: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm.

[213] Brazil, Presidência da República. *Decreto nº 10.222, de 5 de fevereiro de 2020 — Estratégia Nacional de Segurança Cibernética (E-Ciber)*. Federal decree, Diário Oficial da União. Cyber-governance baseline for the federal public administration; GSI/PR is the coordinating authority. Operational incident-handling structures are established by Decreto 10.748/2021 (Rede Federal de Gestão de Incidentes Cibernéticos, CTIR.Gov). 2020. URL: https://www.planalto.gov.br/ccivil_03/_ato2019-2022/2020/decreto/d10222.htm.

[214] Brazil, Presidência da República. *Lei nº 12.965, de 23 de abril de 2014 — Marco Civil da Internet*. Federal statute, Diário Oficial da União. Foundational connectivity and online-privacy framework; the granular personal-data security and breach-notification duties are carried by the LGPD (Law 13.709/2018), with Marco Civil providing the constitutional-style Internet-rights baseline. 2014. URL: https://www.planalto.gov.br/ccivil_03/_ato2011-2014/2014/lei/l12965.htm.

[215] Brazil, Autoridade Nacional de Proteção de Dados (ANPD). *Resolução CD/ANPD nº 15, de 24 de abril de 2024 — Regulamento de Comunicação de Incidente de Segurança*. ANPD board resolution, Diário Oficial da União. Sets the operative 3-business-day notification deadline (with 20-business-day supplementation) under LGPD Art. 48. The ANPD is the competent authority. Companion to the official CIS reporting channel at gov.br/anpd. 2024. URL: https://www.gov.br/anpd/pt-br/canais_atendimento/agente-de-tratamento/comunicado-de-incidente-de-seguranca-cis.

[216] Brazil, Presidência da República. *Decreto nº 10.748, de 16 de julho de 2021 — Rede Federal de Gestão de Incidentes Cibernéticos*. Federal decree, Diário Oficial da União. Establishes mandatory federal cyber-incident coordination via CTIR.Gov (GSI/PR). Together with LGPD Art. 48 + ANPD Res. 15/2024 (personal-data breaches) it forms the dual incident-notification track for a federal university. 2021. URL: https://www.planalto.gov.br/ccivil_03/_ato2019-2022/2021/decreto/d10748.htm.

[217] Brazil, Presidência da República. *Lei nº 13.146, de 6 de julho de 2015 — Lei Brasileira de Inclusão da Pessoa com Deficiência (Estatuto da Pessoa com Deficiência)*. Federal statute, Diário Oficial da União. Accessibility functional obligation. Web/digital conformance is operationalised through the e-MAG standard (gov.br / governo digital); higher-education accessibility also touches MEC course-recognition requirements (Portaria MEC 3.284/2003). 2015. URL: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2015/lei/l13146.htm.

[218] Brazil, Presidência da República. *Lei nº 12.527, de 18 de novembro de 2011 — Lei de Acesso à Informação (LAI)*. Federal statute, Diário Oficial da União. Transparency functional obligation; CGU is the federal oversight authority. Procedural gaps are filled subsidiarily by the federal administrative-procedure law (Lei 9.784/1999). 2011. URL: https://www.planalto.gov.br/ccivil_03/_ato2011-2014/2011/lei/l12527.htm.

[219] Brazil, Presidência da República. *Lei nº 9.784, de 29 de janeiro de 1999 — Processo Administrativo no âmbito da Administração Pública Federal*. Federal statute, Diário Oficial da União. Administrative due-process / governance functional obligation; applies to federal universities as autarquias/fundações and subsidiarily to LAI and other procedural regimes. 1999. URL: https://www.planalto.gov.br/ccivil_03/leis/l9784.htm.

[220] African Union. *African Union Convention on Cyber Security and Personal Data Protection (Malabo Convention)*. Regional context instrument (analogous to AU-level framing). Adopted 27 June 2014; in force 8 June 2023 (Art. 36, 15th ratification). South Africa: signed, NOT ratified — no transfer/transposition obligation flows to South African institutions; provides continental policy baseline only. Depositary/authority: African Union Commission. 2014. URL: https://au.int/en/treaties/african-union-convention-cyber-security-and-personal-data-protection.

[221] Republic of South Africa, Parliament. *Protection of Personal Information Act 4 of 2013 (POPIA), Republic of South Africa*. F1 security of processing: s.19 (Condition 7). F2 breach notification: s.22 (notify Information Regulator and data subjects as soon as reasonably possible). F4 transborder flow: s.72 (adequate-protection / binding-agreement / consent / contractual-necessity transfer mechanism, self-assessed, no EU-style adequacy list). Competent authority: Information Regulator (South Africa). 2013. URL: https://popia.co.za/.

[222] Information Regulator (South Africa). *Information Regulator (South Africa) — supervisory authority under POPIA and PAIA*. Competent authority for F1 (security of processing) and F2 (breach notification, s.22 recipient) under POPIA. Independent body under POPIA s.39; also enforces PAIA. Receives security-compromise notifications and may direct publicity of a compromise. 2021. URL: https://inforegulator.org.za/.

[223] Republic of South Africa, Parliament. *Cybercrimes Act 19 of 2020, Republic of South Africa*. F3 incident/offence reporting: s.54 — report to SAPS without undue delay, where feasible within 72 hours; applies to electronic communications service providers and financial institutions. Authority: South African Police Service (SAPS) with national 24/7 point of contact. Note: South Africa has no standalone unified Cybersecurity Act; the Cybercrimes Act is the operative criminal/incident instrument. 2020. URL: https://www.michalsons.com/focus-areas/cybercrime-law-around-the-world/cybercrimes-act-south-africa.

[224] Republic of South Africa, Parliament. *Electronic Communications and Transactions Act 25 of 2002 (ECT Act), Republic of South Africa*. F5 electronic transactions / trust services and electronic signatures: ECT Act ss.13, 37–40 (advanced electronic signature, accreditation). Authority: South African Accreditation Authority (SAAA) under the Department of Communications and Digital Technologies. eIDAS-equivalent function; no EU-style mutual-recognition regime. 2002. URL: https://www.gov.za/documents/electronic-communications-and-transactions-act.

[225] Republic of South Africa, Parliament. *Promotion of Equality and Prevention of Unfair Discrimination Act 4 of 2000 (PEPUDA / Equality Act), Republic of South Africa*. F6 digital accessibility / non-discrimination: PEPUDA s.9 and disability provisions (reasonable accommodation; removal of obstacles). Authority/forum: Equality Courts; South African Human Rights Commission (SAHRC). No standalone web-accessibility statute — obligation is principle-based, WCAG used as de facto benchmark. 2000. URL: https://www.saflii.org/za/legis/consol_reg/rrttpoeapoud2003887/.